Tema 39 · Bloque II | 60 preguntas de test

Principios básicos del Esquema Nacional de Seguridad y el Esquema Nacional de Interoperabilidad

El artículo 156 de la Ley 40/2015 y la cadena normativa · ENS: los siete principios básicos del artículo 5 · las cinco dimensiones C-I-T-A-D · niveles, categorías y la regla del máximo · las 73 medidas del anexo II y la Declaración de Aplicabilidad · autoevaluación frente a certificación · ENI: los tres principios específicos · las tres dimensiones más la temporal · las normas técnicas · gobernanza, CCN y los cuatro puentes entre ambos esquemas

Enunciado oficial del programa (BOAM n.º 10.032, de 23 de diciembre de 2025): Principios básicos del Esquema Nacional de Seguridad y el Esquema Nacional de Interoperabilidad.

EXTENSIÓN
~26.000 palabras · 19 diagramas · 60 preguntas de test

TIEMPO ESTIMADO DE ESTUDIO
23–25 horas (primera vuelta completa, sin contar repasos)

Índice

- [ ] **1. Marco regulatorio de la administración digital**
  - [ ] **1.1. Fundamentos normativos de la administración electrónica**
  - [ ] **1.1.1. El principio de seguridad y la dimensión de la interoperabilidad**
- [ ] **2. El Esquema Nacional de Seguridad**
  - [ ] **2.1. Marco conceptual y ámbito de aplicación**
  - [ ] **2.2. Principios básicos del Esquema Nacional de Seguridad**
  - [ ] **2.3. Dimensiones de seguridad de la información**
  - [ ] **2.4. Categorización de los sistemas de información**
  - [ ] **2.5. Medidas de seguridad y evaluación de la conformidad**
- [ ] **3. El Esquema Nacional de Interoperabilidad**
  - [ ] **3.1. Marco conceptual y ámbito de aplicación**
  - [ ] **3.2. Principios específicos del Esquema Nacional de Interoperabilidad**
  - [ ] **3.3. Dimensiones de la interoperabilidad**
  - [ ] **3.4. Normas técnicas de interoperabilidad**
- [ ] **4. Gobernanza y sinergias entre el ENS y el ENI**
  - [ ] **4.1. Órganos de gobernanza y coordinación**
  - [ ] **4.2. Integración operativa de seguridad e interoperabilidad**
- [ ] **Los diez datos que no se pueden fallar**

Conceptos clave para memorizar

Concepto	Dato clave
Norma de cabecera de ambos esquemas	**Artículo 156 de la Ley 40/2015**: apartado **1 = ENI**, apartado **2 = ENS**. Es el precepto que hay que citar cuando se pregunta «dónde están creados»
ENS vigente	**Real Decreto 311/2022, de 3 de mayo** (BOE núm. 106, de 4 de mayo de 2022). **Deroga** el RD 3/2010. Última modificación: **RD 1125/2024, de 5 de noviembre**
ENI vigente	**Real Decreto 4/2010, de 8 de enero** (BOE núm. 25, de 29 de enero de 2010). **Sigue vigente**, modificado por el RD 1495/2011, el **RD 203/2021** y el **RD 1125/2024**
Principios básicos del ENS	**Siete**, en el **artículo 5**, desarrollados en los **artículos 6 a 11** (seis artículos para siete principios: el art. 10 agrupa dos)
Principios específicos del ENI	**Tres**, en el **artículo 4**: cualidad integral, carácter multidimensional y enfoque de soluciones multilaterales
Dimensiones de seguridad	**Cinco**: **C**onfidencialidad, **I**ntegridad, **T**razabilidad, **A**utenticidad y **D**isponibilidad. Orden del anexo I: **C, I, T, A, D**
Dimensiones de la interoperabilidad	**Tres** (organizativa, semántica y técnica) **más la dimensión temporal**. El marco europeo maneja **cuatro capas**, porque añade la **jurídica**
Niveles y categorías	Niveles de dimensión: **BAJO, MEDIO, ALTO**. Categorías de sistema: **BÁSICA, MEDIA, ALTA**. **Manda siempre la dimensión más alta**
Medidas del anexo II	**73 medidas** en **3 grupos**: `org` (4), `op` (33) y `mp` (36). Documento que las formaliza: **Declaración de Aplicabilidad**
Conformidad	**BÁSICA → autoevaluación** (declaración). **MEDIA y ALTA → auditoría de certificación**. Auditoría ordinaria **al menos cada dos años**
Normas técnicas de interoperabilidad	La disposición adicional primera del ENI prevé **23**; hay **12 publicadas** en el BOE (letras `a)` a `l)`), la última en **2013**
Instrucciones técnicas de seguridad	**Cuatro** publicadas: Auditoría, Conformidad, Informe del estado de la seguridad y Notificación de incidentes. La más reciente es de **2018**

Concepto	Dato clave
Órgano de coordinación técnica	**Comisión Sectorial de Administración Electrónica** (disposición adicional novena de la Ley 40/2015). Propone tanto las NTI como las ITS
Centro Criptológico Nacional	Adscrito al **CNI**. Elabora las **guías CCN-STIC serie 800**, opera el **CCN-CERT** y es el órgano competente para la interoperabilidad en **ciberseguridad y criptografía** (art. 35.2 del ENS)
Red de comunicaciones de las AA. PP.	La presta la **Red SARA** (art. 13 del ENI)
Puente entre los dos esquemas	**Artículo 22 del ENI**: para conservar documentos electrónicos **se aplica el ENS**. Y **artículo 35.2 del ENS**: el CCN garantiza la interoperabilidad en criptografía

Contenido

Convenciones del documento

Este tema incluye cuatro tipos de **cajas callout** para facilitar el estudio:

> **DATO CLAVE**
> Información de alta densidad memorística: números de artículo, plazos, listas cerradas de principios y dimensiones, códigos de medida del anexo II y referencias de BOE.

> **EJERCICIO RESUELTO**
> Problema resuelto paso a paso: categorizar un sistema, decidir qué medidas aplican, determinar si procede auditoría o autoevaluación, elegir el formato de un documento.

> **EJEMPLO DE APLICACIÓN EN EL AYTO**
> Aplicación de la norma al entorno municipal: la Política de Seguridad de la Información del Ayuntamiento, el Padrón, el sistema de expedientes, la sede electrónica y el papel del IAM.

> **RELACIÓN CON OTROS TEMAS**
> Enlace conceptual a otros temas del temario oficial.

Cómo leer este tema. El enunciado oficial nombra dos objetos —el **Esquema Nacional de Seguridad** y el **Esquema Nacional de Interoperabilidad**— y acota la materia con dos palabras que conviene tomarse en serio: **principios básicos**. No pide el articulado completo de los dos reales decretos, sino su **arquitectura conceptual**: qué protegen, con qué criterios, quién responde de qué y cómo se comprueba. Ahora bien, los principios no se entienden del todo sin las **dimensiones**, las **categorías**, los **plazos de auditoría** y los **códigos de medida**. Por eso este tema desarrolla los principios con la profundidad que pide el enunciado y añade, con el mismo rigor, esas cuatro piezas que los acompañan.

El error de estudio más frecuente en este tema, y cómo evitarlo. Es un tema **íntegramente normativo**, y eso engaña: parece que basta con memorizar listas. El problema es que las listas de los dos esquemas **se parecen entre sí, y ambas se parecen a las del real decreto derogado**. Un opositor que memorice sin distinguir acabará escribiendo «seis principios básicos» (los del RD 3/2010, derogado), «prevención, reacción y recuperación» (rúbrica de 2010) en lugar de «prevención, detección, respuesta y conservación» (rúbrica de 2022), o el orden **D-A-I-C-T** de las dimensiones cuando el anexo I vigente las enumera **C-I-T-A-D**. La única defensa es **anclar cada**

lista a su artículo y a su norma, que es como está escrito este tema: no hay una sola enumeración sin su precepto al lado.

La asimetría que hay que entender antes de empezar. Los dos esquemas se citan siempre juntos, nacen del mismo artículo y comparten estructura de capítulos, pero **no están en el mismo momento de su vida**. El ENS se **rehízo entero en 2022**: real decreto nuevo, principios ampliados, medidas reordenadas y un régimen de conformidad exigente. El ENI **sigue siendo el real decreto de 2010**, con retoques: su artículo 1 continúa remitiendo al artículo 42 de una ley —la 11/2007— que fue **derogada en 2015**, y de las **veintitrés** normas técnicas que prevé su disposición adicional primera solo hay **doce publicadas**, la última en **2013**. Esa asimetría no es una anécdota: explica el tono de cada mitad del tema y es, en sí misma, un dato que conviene retener.

Fronteras con otros temas, declaradas de entrada. Este tema toca materia de otros cinco y conviene fijar el reparto para que el solapamiento del temario oficial no se lea como omisión ni como repetición:

- El **Tema 32** cubre los **conceptos de seguridad**: seguridad física y lógica, amenazas y vulnerabilidades, criptografía y firma digital. Aquí no se explica **qué es** un cifrado ni **cómo funciona** una firma: se explica **qué obliga la norma** a cifrar y a firmar, y con qué código de medida.
- El **Tema 36** cubre la **seguridad en redes**: perímetro, acceso remoto, VPN y puesto de usuario. Aquí las medidas de comunicaciones aparecen solo como parte del catálogo del anexo II, sin desarrollar su técnica.
- Los **Temas 30 y 37** cubren la **red local**, que se administra y se describe allí. Aquí solo interesa que la separación de flujos tiene un código y una tabla de aplicación.
- El **Tema 12** cubre la **digitalización** y los periféricos que la hacen posible; aquí se ve la **norma técnica** que la gobierna, no el escáner.
- Los **Temas 6 y 7** cubren la **Ley 39/2015** desde la perspectiva del procedimiento y de los derechos. Aquí esa misma ley se lee al revés: se citan solo los tres preceptos —artículos 26, 27 y 70— que convierten a los dos esquemas en **derecho aplicable al expediente**.

Caso de referencia usado en todo el tema (contexto Ayuntamiento de Madrid, supuesto simplificado): el **sistema de tramitación de expedientes de la sede electrónica municipal**, operado por el **Organismo Autónomo Informática del Ayuntamiento de Madrid (IAM)**, que recibe solicitudes de la ciudadanía, consulta datos de otras Administraciones a través de la plataforma de intermediación, forma expedientes electrónicos, los remite cuando procede a otros organismos y los conserva. Ese sistema permite instanciar el tema entero: hay que **categorizarlo** (§2.4), aplicarle **medidas** (§2.5), acreditar su **conformidad** (§2.5.2), hacerlo **interoperable** en sus tres dimensiones (§3.3), construir sus documentos y expedientes conforme a las **normas técnicas** (§3.4) y conservarlos, lo que obliga a aplicar los dos esquemas a la vez (§4.2).

1. Marco regulatorio de la administración digital

1.1. Fundamentos normativos de la administración electrónica

La administración electrónica española no se construyó de una vez. Su normativa se ha reescrito tres veces en veinte años, y entender esa secuencia es lo que permite explicar por qué los dos esquemas están donde están y por qué uno se ha renovado y el otro no.

El punto de partida: la Ley 11/2007. La Ley 11/2007, de 22 de junio, de acceso electrónico de los ciudadanos a los servicios públicos, fue la primera norma que reconoció un **derecho** —no una posibilidad— a relacionarse con la Administración por medios electrónicos. Para que ese derecho fuera efectivo hacía falta que los sistemas de las distintas Administraciones **se entendieran entre sí** y que fueran **seguros**. La ley resolvió esa necesidad creando dos instrumentos gemelos en sus artículos 42 y 43: el **Esquema Nacional de Interoperabilidad** y el **Esquema Nacional de Seguridad** `[ENI, art. 1]`. Ambos se desarrollaron por sendos reales decretos aprobados **el mismo día**, el **8 de enero de 2010**: el **RD 3/2010** para el ENS y el **RD 4/2010** para el ENI `[ENS, disp. derog.]` `[ENI]`.

La reforma de 2015: dos leyes en lugar de una. La Ley 11/2007 fue **derogada** por la pareja de leyes de 1 de octubre de 2015, que repartió su contenido: la **Ley 39/2015**, del Procedimiento Administrativo Común, se quedó con la **relación con el ciudadano** —registro, notificación, documento, expediente—, y la **Ley 40/2015**, de Régimen Jurídico del Sector Público, con el **funcionamiento interno y las relaciones entre Administraciones**, incluida la administración electrónica de carácter estructural. Los dos esquemas pasaron a la Ley 40/2015, y allí siguen, en un único precepto: el **artículo 156** `[L40, art. 156]`.

La renovación de 2022, y la que no llegó. El ENS se rehízo entero mediante el **Real Decreto 311/2022, de 3 de mayo**, que **derogó expresamente** el RD 3/2010 `[ENS, disp. derog.]`. El ENI, en cambio, **no se ha rehecho**: sigue vigente el RD 4/2010, con las modificaciones puntuales del RD 1495/2011, del **RD 203/2021** `[RD203]` y del **RD 1125/2024** `[RD1125]`.

> DATO CLAVE
>
> El **artículo 156 de la Ley 40/2015** es el precepto que hay que citar siempre. Su rúbrica es «**Esquema Nacional de Interoperabilidad y Esquema Nacional de Seguridad**» —en ese orden, primero el ENI—, su **apartado 1 define el ENI** y su **apartado 2 define el ENS**. El artículo 1.1 del RD 311/2022 remite expresamente al **artículo 156.2**. Confundir los apartados es un fallo clásico.

El texto del artículo 156 merece leerse literalmente, porque las dos definiciones **no son simétricas**. El apartado 1 dice que el ENI «comprende el conjunto de **criterios y recomendaciones** en materia

de **seguridad, conservación y normalización de la información**, de los formatos y de las aplicaciones que deberán ser tenidos en cuenta por las Administraciones Públicas para la **toma de decisiones tecnológicas** que garanticen la interoperabilidad» `[L40, art. 156.1]`. El apartado 2 dice que el ENS «tiene por objeto establecer la **política de seguridad** en la utilización de medios electrónicos en el ámbito de la presente Ley, y está constituido por los **principios básicos y requisitos mínimos** que garanticen adecuadamente la seguridad de la información tratada» `[L40, art. 156.2]`.

Tres diferencias saltan a la vista. Primera: el ENI se define por **criterios y recomendaciones**; el ENS, por **principios básicos y requisitos mínimos**. La palabra «recomendaciones» es del ENI, no del ENS. Segunda: el ENI mira a la **toma de decisiones tecnológicas**; el ENS, a la **política de seguridad**. Y tercera, la más curiosa: el ENI, que es el esquema de la interoperabilidad, **menciona la seguridad en su propia definición**, porque la conservación segura de la información es condición de que esa información siga siendo interoperable dentro de veinte años.

El diagrama D1 representa el artículo 156 con sus dos apartados y el real decreto que cuelga de cada uno, con sus fechas y sus reformas.

1.1.1. El principio de seguridad y la dimensión de la interoperabilidad

Hay un error de encuadre que conviene desmontar antes de entrar en materia: pensar que el ENS y el ENI son **normas técnicas** que obligan a los informáticos. No lo son. Son **normas jurídicas** que obligan a la Administración como tal, y su fundamento no está en la técnica sino en los principios generales de actuación administrativa.

El anclaje en el artículo 3 de la Ley 40/2015. El artículo 3.1 de la Ley 40/2015 enumera **once principios** de actuación de las Administraciones Públicas, de la letra `a)` a la `k)`: servicio efectivo a los ciudadanos; simplicidad, claridad y proximidad; participación, objetividad y transparencia; racionalización y agilidad; buena fe, confianza legítima y lealtad institucional; responsabilidad por la gestión pública; planificación y dirección por objetivos; eficacia; economía, suficiencia y adecuación de los medios; eficiencia en la asignación de recursos; y cooperación, colaboración y coordinación entre Administraciones `[L40, art. 3.1]`. El apartado 2 del mismo artículo es el que convierte todo eso en obligación tecnológica, y conviene citarlo literal: las Administraciones «se relacionarán entre sí y con sus órganos, organismos públicos y entidades vinculados o dependientes **a través de medios electrónicos, que aseguren la interoperabilidad y seguridad de los sistemas y soluciones adoptadas por cada una de ellas**, garantizarán la protección de los datos de carácter personal, y facilitarán preferentemente la **prestación conjunta de servicios** a los interesados» `[L40, art. 3.2]`.

Ese apartado 2 contiene, comprimidas en una frase, las cuatro exigencias que desarrollan los dos esquemas: **relación electrónica obligatoria** entre Administraciones, **interoperabilidad**, **seguridad** y **protección de datos**. No es casual que el precepto ponga la interoperabilidad y la

seguridad **en el mismo inciso y unidas por una conjunción**: en el diseño legal español no son dos objetivos alternativos entre los que elegir, sino **dos condiciones simultáneas** de la misma actuación.

> DATO CLAVE
>
> Los dos esquemas tienen **títulos competenciales distintos**. El **ENI** se dicta al amparo del **artículo 149.1.18.ª** de la Constitución (bases del régimen jurídico de las Administraciones Públicas) `[ENI, disp. final 1.ª]`. El **ENS** invoca **tres**: el **149.1.18.ª**, el **149.1.21.ª** (telecomunicaciones) y el **149.1.29.ª** (seguridad pública) `[ENS, disp. final 1.ª]`. La razón es material: el ENS toca la seguridad del Estado y por eso necesita más base competencial.

Por qué los esquemas obligan de verdad: los tres preceptos de la Ley 39/2015. Un opositor puede preguntarse qué pasa si una Administración no cumple los esquemas. La respuesta está en la Ley 39/2015, que ata el cumplimiento a la **validez de los actos**, no a una sanción:

- El **artículo 26.2** fija los **cinco requisitos** para que un documento electrónico administrativo sea válido: contener información archivada en soporte electrónico con formato identificable; disponer de datos de identificación que permitan su individualización; incorporar una **referencia temporal** del momento de emisión; incorporar los **metadatos mínimos exigidos**; e incorporar las **firmas electrónicas** que correspondan `[L39, art. 26.2]`. Los metadatos mínimos y la referencia temporal no los define esa ley: los define una **norma técnica de interoperabilidad**.
- El **artículo 27.3** condiciona el carácter de **copia auténtica** a que la Administración se ajuste «a lo previsto en el **Esquema Nacional de Interoperabilidad, el Esquema Nacional de Seguridad y sus normas técnicas de desarrollo**» `[L39, art. 27.3]`. Es la mención conjunta más explícita de los dos esquemas en toda la legislación.
- El **artículo 70.3** ordena que, cuando haya que remitir un expediente electrónico, se haga «de acuerdo con lo previsto en el **Esquema Nacional de Interoperabilidad** y en las correspondientes **Normas Técnicas de Interoperabilidad**», y que se envíe **completo, foliado, autentificado y acompañado de un índice, asimismo autentificado** `[L39, art. 70.3]`.

La consecuencia práctica es contundente: un expediente remitido sin índice firmado conforme a la norma técnica **no es un expediente válidamente remitido**; una copia hecha al margen de los esquemas **no es una copia auténtica**. El incumplimiento no se castiga con una multa, se castiga con la **ineficacia jurídica** de lo actuado.

EJEMPLO DE APLICACIÓN EN EL AYTO

Un juzgado de lo contencioso-administrativo requiere al Ayuntamiento de Madrid la remisión del expediente de una licencia. Si el sistema de tramitación exporta un conjunto de PDF sueltos en un disco, sin índice electrónico firmado y sin los metadatos de la norma técnica, el requerimiento **no queda cumplido**: no se ha remitido «el expediente» en el sentido del artículo 70.3 de la Ley 39/2015. Esa es la razón por la que un requisito que parece burocrático —el índice firmado— es en realidad el elemento que da **integridad** al conjunto y permite acreditar que no se ha añadido ni quitado nada.

El marco europeo, que es el que se mueve. Sobre esta arquitectura española se ha superpuesto, desde 2024, normativa europea de aplicación directa. El **Reglamento (UE) 2024/903, sobre la Europa Interoperable**, entró en vigor el **11 de abril de 2024** y es aplicable desde el **12 de julio de 2024** `[IEA]`. No exige transposición: obliga por sí mismo. Sus piezas principales son la **evaluación de la interoperabilidad** —un análisis previo obligatorio cuando se va a modificar un sistema que soporta intercambios transfronterizos—, el **portal Europa Interoperable** como ventanilla única de soluciones reutilizables, las **cajas de arena regulatorias** para experimentar con garantías, y la obligación de que cada Estado designe **autoridades nacionales competentes** y un **punto de contacto único** `[IEA]`. En materia de seguridad, la pieza equivalente es la **Directiva (UE) 2022/2555 (NIS2)**, que a agosto de 2026 **sigue sin transponerse en España**: el anteproyecto de Ley de Coordinación y Gobernanza de la Ciberseguridad se aprobó en Consejo de Ministros el **14 de enero de 2025** y no se ha publicado en el BOE `[NIS2]`.

RELACIÓN CON OTROS TEMAS

El detalle técnico de la **firma electrónica** y de los **certificados** que este apartado da por sabido se desarrolla en el **Tema 32**. Los **formatos de fichero** que la conservación exige preservar, en el **Tema 13**. Y la **digitalización** de documentos en papel, con sus resoluciones y sus equipos, en el **Tema 12**.

El diagrama D2 encadena los cinco niveles de la pirámide normativa que se acaba de recorrer: Constitución, ley, real decreto, norma técnica o instrucción técnica, y normativa municipal.

---

2. El Esquema Nacional de Seguridad

2.1. Marco conceptual y ámbito de aplicación

2.1.1. Objeto y normativa vigente del Esquema Nacional de Seguridad

La norma. El ENS vigente es el **Real Decreto 311/2022, de 3 de mayo**, publicado en el **BOE núm. 106, de 4 de mayo de 2022** `[ENS]`. Su estructura es la siguiente, y merece memorizarse porque permite situar cualquier pregunta:

Parte	Contenido
Capítulo I (arts. 1-4)	Disposiciones generales: objeto, ámbito, datos personales y definiciones
Capítulo II (arts. 5-11)	**Principios básicos**
Capítulo III (arts. 12-30)	Política de seguridad y **requisitos mínimos**
Capítulo IV (arts. 31-34)	Auditoría, informe del estado de la seguridad e incidentes
Capítulo V (arts. 35-38)	Normas de conformidad
Capítulo VI (art. 39)	Actualización permanente
Capítulo VII (arts. 40-41)	**Categorización** de los sistemas
Anexo I	Categorías de seguridad: dimensiones, niveles y categorías
Anexo II	**Medidas de seguridad**: 73 medidas y su tabla de aplicación
Anexo III	Auditoría de la seguridad
Anexo IV	Glosario

Son **41 artículos en 7 capítulos**, 3 disposiciones adicionales, 1 transitoria, 1 derogatoria, 3 finales y **4 anexos**.

> DATO CLAVE
>
> La colocación de la **categorización** en el **capítulo VII**, al final del articulado y **después** de las normas de conformidad, es contraintuitiva. Lógicamente la categorización debería ir antes que las medidas; el real decreto la coloca al final porque su desarrollo real está en el **anexo I**, y el capítulo VII solo contiene dos artículos de remisión: el **40** (categorías) y el **41** (facultades).

El objeto. El artículo 1.2 define el ENS como el conjunto de «**principios básicos y requisitos mínimos** necesarios para una protección adecuada de la información tratada y los servicios prestados», con un objetivo enunciado mediante **siete propiedades**: asegurar «el **acceso**, la **confidencialidad**, la **integridad**, la **trazabilidad**, la **autenticidad**, la **disponibilidad** y la **conservación** de los datos, la información y los servicios utilizados por medios electrónicos» `[ENS, art. 1.2]`.

DATO CLAVE

Esas **siete propiedades del artículo 1.2** no son lo mismo que las **cinco dimensiones del anexo I**. Las dimensiones son cinco —**C, I, T, A, D**—; el artículo 1.2 añade **acceso** y **conservación**, que no son dimensiones valorables. Una pregunta que ofrezca «acceso» o «conservación» como dimensión de seguridad es falsa; una que las ofrezca como finalidad del artículo 1.2, verdadera.

El artículo 1.3 añade una declaración de alcance que conviene tener: lo dispuesto en el real decreto, por cuanto afecta a los sistemas de información utilizados para la prestación de servicios públicos, «deberá considerarse comprendido en los **recursos y procedimientos integrantes del Sistema de Seguridad Nacional**» recogidos en la **Ley 36/2015, de 28 de septiembre, de Seguridad Nacional** `[ENS, art. 1.3]` `[LSN]`. El ENS no es, por tanto, una norma de gestión informática: es una pieza del **sistema de seguridad del Estado**.

El ámbito de aplicación. El artículo 2 lo fija en cuatro apartados y el segundo y el tercero son los más relevantes:

1. **Todo el sector público**, en los términos del artículo 2 de la Ley 40/2015 —Administración General del Estado, Administraciones autonómicas, **Entidades Locales** y el sector público institucional— `[ENS, art. 2.1]`.
2. Los sistemas que tratan **información clasificada**, sin perjuicio de la Ley 9/1968 de Secretos Oficiales, «pudiendo resultar necesario adoptar **medidas complementarias** de seguridad» `[ENS, art. 2.2]`.
3. **Las entidades del sector privado** que, «de acuerdo con la normativa aplicable y en virtud de una **relación contractual**, presten servicios o provean soluciones a las entidades del sector público para el ejercicio por estas de sus competencias y potestades administrativas», **incluida la obligación de contar con política de seguridad**, que en su caso aprueba «el órgano que ostente las **máximas competencias ejecutivas**» `[ENS, art. 2.3]`.
4. Las entidades públicas que instalen, despliegen o exploten **redes 5G**, a las que además se aplica el **Real Decreto-ley 7/2022** `[ENS, art. 2.4]`.

El apartado 3 es **el precepto de mayor impacto práctico de todo el real decreto** y el que más ha cambiado el mercado. Antes de 2022 el ENS obligaba a la Administración; desde 2022 obliga también al **contratista** y —lo que va más lejos— «esta cautela se extenderá también a la **cadena de suministro** de dichos contratistas, en la medida que sea necesario y de acuerdo con los resultados del correspondiente **análisis de riesgos**» `[ENS, art. 2.3]`. Y lo instrumenta por la vía de la contratación: los pliegos «contemplarán todos aquellos requisitos necesarios para asegurar la conformidad con el ENS», tales como la presentación de las correspondientes **Declaraciones o Certificaciones de Conformidad** `[ENS, art. 2.3]`.

EJEMPLO DE APLICACIÓN EN EL AYTO

El Ayuntamiento licita el mantenimiento evolutivo del sistema de tramitación de expedientes. En virtud del artículo 2.3, el pliego debe exigir a la empresa adjudicataria la **conformidad con el ENS** de los sistemas en los que se sustente el servicio, con su Declaración o Certificación según la categoría, y la exigencia alcanza a los **subcontratistas** que participen en la medida que resulte del análisis de riesgos. La consecuencia organizativa es que la conformidad con el ENS ha dejado de ser un asunto del IAM para convertirse en una **cláusula de los pliegos** que redacta el órgano de contratación.

La concurrencia con la protección de datos. El artículo 3 resuelve la relación entre el ENS y el RGPD con una regla de tres pasos: se aplica la normativa de protección de datos «sin perjuicio de los requisitos establecidos en el presente real decreto» (apartado 1); el responsable o encargado, **asesorado por el delegado de protección de datos**, realiza el análisis de riesgos del artículo 24 del RGPD y, cuando proceda, la **evaluación de impacto** del artículo 35 (apartado 2); y «en todo caso, **prevalecerán las medidas** a implantar como consecuencia del análisis de riesgos y, en su caso, de la evaluación de impacto (…) en caso de resultar **agravadas** respecto de las previstas en el presente real decreto» (apartado 3) `[ENS, art. 3]` `[RGPD]`.

DATO CLAVE

La regla del **artículo 3.3** solo funciona **en una dirección**: si la protección de datos exige **más**, gana la protección de datos; si exigiera menos, sigue mandando el ENS. Las medidas del ENS son **mínimos**, nunca máximos, y el artículo 28.2 lo repite: son «**mínimos exigibles, siendo ampliables** a criterio del responsable de la seguridad».

El plazo de adecuación. La disposición transitoria única concedió a los sistemas preexistentes **veinticuatro meses** para alcanzar la plena adecuación, plazo que venció el **5 de mayo de 2024**, y mantuvo mientras tanto la vigencia de los distintivos obtenidos bajo el RD 3/2010. Los **sistemas nuevos** aplican el real decreto «desde su **concepción**» `[ENS, disp. trans. única]`.

El diagrama D3 presenta la estructura completa del RD 311/2022 y sirve de mapa para localizar cualquier pregunta.

2.2. Principios básicos del Esquema Nacional de Seguridad

Este es el corazón del enunciado oficial. El **artículo 5** del ENS abre el capítulo II con una declaración de finalidad y una lista cerrada de **siete principios**:

> El objeto último de la seguridad de la información es garantizar que una organización podrá cumplir sus objetivos, desarrollar sus funciones y ejercer sus competencias utilizando sistemas de información `[ENS, art. 5]`.

Y a continuación: `a)` **Seguridad como proceso integral**; `b)` **Gestión de la seguridad basada en los riesgos**; `c)` **Prevención, detección, respuesta y conservación**; `d)` **Existencia de líneas de defensa**; `e)` **Vigilancia continua**; `f)` **Reevaluación periódica**; `g)` **Diferenciación de responsabilidades** `[ENS, art. 5]`.

> DATO CLAVE
>
> Son **siete principios** enumerados en el **artículo 5** y desarrollados en **seis artículos**, del **6 al 11**. La asimetría tiene explicación: el **artículo 10** desarrolla **dos** principios a la vez, porque su rúbrica es «**Vigilancia continua y reevaluación periódica**». Quien memorice «un principio, un artículo» fallará. Y quien recuerde la lista del real decreto derogado dirá **seis** principios: los del RD 3/2010 eran seguridad integral, gestión de riesgos, **prevención, reacción y recuperación**, líneas de defensa, reevaluación periódica y **función diferenciada** `[RD3-2010]`.

Merece la pena detenerse en las **tres novedades de 2022** respecto de la lista anterior, porque cada una responde a una lección aprendida:

- La **detección** entra en la rúbrica del principio `c)`. En 2010 se hablaba de «prevención, **reacción** y recuperación», dando por supuesto que el incidente se conocía. La experiencia demostró lo contrario —el problema no era reaccionar, era **enterarse**—, y en 2022 la detección pasó a ser una fase con nombre propio.
- La **conservación** sustituye a la «recuperación» y amplía su alcance: ya no se trata solo de recuperar el sistema tras un incidente, sino de garantizar «la **conservación de los datos e información en soporte electrónico**» a lo largo de «todo el **ciclo vital de la información digital**», con una expresión que el real decreto toma prestada del mundo archivístico: la **preservación del patrimonio digital** `[ENS, art. 8.5]`.
- La **vigilancia continua** se desgaja de la reevaluación periódica y se convierte en principio autónomo, aunque comparta artículo con ella. Son dos cosas distintas: la vigilancia es **permanente y automática**; la reevaluación es **periódica y deliberada**.

El diagrama D4 despliega los siete principios con su artículo, su enunciado y la conducta que cada uno excluye.

2.2.1. Seguridad integral y gestión del riesgo

Principio `a)` : la seguridad como un proceso integral (artículo 6). El precepto define la seguridad como «un **proceso integral** constituido por **todos los elementos humanos, materiales, técnicos, jurídicos y organizativos** relacionados con el sistema de información», y añade la frase que le da fuerza normativa: la aplicación del ENS «estará presidida por este principio, que **excluye cualquier actuación puntual o tratamiento coyuntural**» `[ENS, art. 6.1]`.

Dos elementos de esa enumeración se olvidan siempre. El primero, los **elementos jurídicos**: la seguridad incluye los contratos, los pliegos, las cláusulas de confidencialidad y los encargos de tratamiento, no solo los cortafuegos. El segundo, y es el que el propio artículo subraya en su apartado 2, las **personas**: «se prestará la máxima atención a la **concienciación** de las personas que intervienen en el proceso **y la de los responsables jerárquicos**, para evitar que la **ignorancia**, la **falta de organización y de coordinación** o de **instrucciones adecuadas**, constituyan **fuentes de riesgo** para la seguridad» `[ENS, art. 6.2]`.

> DATO CLAVE
>
> El artículo 6.2 califica expresamente como **fuentes de riesgo** tres cosas que no son técnicas: la **ignorancia**, la **falta de organización y coordinación** y la **falta de instrucciones adecuadas**. Y menciona a los **responsables jerárquicos** junto al personal operativo, no después. Es la base normativa de las medidas `mp.per.3` (concienciación) y `mp.per.4` (formación) y de la **disposición adicional primera**, que encomienda al **CCN** y al **INAP** los programas de sensibilización, concienciación y formación `[ENS, disp. adic. 1.ª]`.

La consecuencia práctica del principio es que **no existe la seguridad como proyecto**. Un plan de adecuación con fecha de fin es un instrumento útil, pero la seguridad que resulta de él no termina cuando termina el plan: el artículo 27 exige la **mejora continua** del proceso, y el artículo 39 la **actualización permanente** del propio esquema.

Principio `b)`: la gestión de la seguridad basada en los riesgos (artículo 7). El artículo 7 lo enuncia en dos apartados de una precisión notable. El primero: «el **análisis y la gestión de los riesgos** es parte esencial del proceso de seguridad, debiendo constituir una **actividad continua y permanentemente actualizada**» `[ENS, art. 7.1]`. El segundo: la gestión de riesgos «permitirá el mantenimiento de un **entorno controlado, minimizando los riesgos a niveles aceptables**», y esa reducción se realizará «mediante una apropiada aplicación de medidas de seguridad, de manera **equilibrada y proporcionada** a la naturaleza de la información tratada, de los servicios a prestar y de los riesgos a los que estén expuestos» `[ENS, art. 7.2]`.

> DATO CLAVE
>
> El objetivo normativo **no es eliminar el riesgo**, sino **minimizarlo a niveles aceptables** manteniendo un **entorno controlado**. Cualquier opción de examen que afirme que el ENS busca «eliminar todo riesgo» o «alcanzar la seguridad total» es falsa: contradice literalmente el artículo 7.2. Las dos palabras que hay que retener son **equilibrada** y **proporcionada**.

Este principio es el que enlaza con el desarrollo del **artículo 14**, primero de los requisitos mínimos, que exige que el análisis de riesgos se realice y que sea **revisado y aprobado anualmente** —dato que el anexo III convierte en punto de auditoría obligatorio `[ENS, anexo III, ap. 1.1.d)]`—, y con la medida `op.pl.1` del anexo II.

El vocabulario del análisis de riesgos procede del glosario del anexo IV y de la metodología **MAGERIT** `[MAGERIT]`, y conviene tenerlo fijado:

Término	Definición operativa
Activo	Componente o funcionalidad de un sistema de información susceptible de ser atacado deliberada o accidentalmente con consecuencias para la organización `[ENS, anexo IV]`
Amenaza	Evento que puede desencadenar un incidente, produciendo daños en los activos
Vulnerabilidad	Debilidad de un activo que puede ser aprovechada por una amenaza
Impacto	Consecuencia sobre el activo de la materialización de la amenaza
Riesgo	Estimación del grado de exposición: combina la **probabilidad** de que la amenaza se materialice y el **impacto** que causaría
Salvaguarda o medida	Procedimiento o mecanismo que reduce el riesgo, actuando sobre la probabilidad, sobre el impacto o sobre ambos
Riesgo residual	El que permanece **después** de aplicar las salvaguardas. Es el que la dirección **acepta formalmente**

EJERCICIO RESUELTO

Sobre el sistema de expedientes municipal se identifica el activo «base de datos de expedientes de licencias»; la amenaza «cifrado por programa de secuestro»; la vulnerabilidad «servidores sin parchear y copias de seguridad accesibles desde la misma red»; y el impacto «paralización de la tramitación durante semanas». ¿Qué salvaguardas reducen **probabilidad** y cuáles reducen **impacto**? Reducen la **probabilidad** el mantenimiento y las actualizaciones de seguridad (`op.exp.4`), la protección frente a código dañino (`op.exp.6`), la separación de flujos en la red (`mp.com.4`) y el mecanismo de autenticación reforzado (`op.acc.6`). Reducen el **impacto** las copias de seguridad (`mp.info.6`) y, si el nivel de disponibilidad lo exige, el plan de continuidad y los medios alternativos (`op.cont.2` y `op.cont.4`). La respuesta completa incluye una observación: las copias de seguridad **solo reducen el impacto si están fuera del alcance del atacante**, y por eso el refuerzo `mp.info.6.R1` existe. Y el riesgo que quede después de todo eso es el **riesgo residual**, que alguien tiene que aceptar por escrito: el **responsable del sistema**, a la vista de las conclusiones del responsable de la seguridad.

El diagrama D5 representa la cadena activo-amenaza-vulnerabilidad-impacto-salvaguarda-riesgo residual sobre el caso de referencia municipal.

2.2.2. Prevención, detección, respuesta y conservación

El **principio** `c)`, desarrollado en el **artículo 8**, es el que estructura temporalmente toda la seguridad, y su rúbrica es de memorización obligada porque cambió en 2022. Sus cinco apartados dicen lo siguiente `[ENS, art. 8]`:

1. La seguridad del sistema debe contemplar las acciones relativas a los aspectos de **prevención, detección y respuesta**, al objeto de **minimizar sus vulnerabilidades** y lograr que las amenazas **no se materialicen** o que, si lo hacen, **no afecten gravemente** a la información o a los servicios.
2. Las **medidas de prevención**, que «podrán incorporar componentes orientados a la **disuasión** o a la **reducción de la superficie de exposición**», deben eliminar o reducir la posibilidad de que las amenazas lleguen a materializarse.
3. Las **medidas de detección** irán dirigidas a **descubrir la presencia de un ciberincidente**.
4. Las **medidas de respuesta**, que «se gestionarán en **tiempo oportuno**», estarán orientadas a la **restauración** de la información y los servicios afectados.
5. «Sin merma de los restantes principios básicos y requisitos mínimos establecidos, el sistema de información garantizará la **conservación de los datos e información en soporte electrónico**», y mantendrá disponibles los servicios «durante **todo el ciclo vital de la información digital**, a través de una concepción y procedimientos que sean la base para la **preservación del patrimonio digital**».

> DATO CLAVE
> Cuatro literales del artículo 8: la prevención puede incluir **disuasión** y **reducción de la superficie de exposición** (ap. 2); la detección busca descubrir un **ciberincidente** —el real decreto usa esa palabra, no «ataque»— (ap. 3); la respuesta se gestiona «**en tiempo oportuno**» y se orienta a la **restauración** (ap. 4); y la conservación se enuncia para «todo el **ciclo vital de la información digital**», con la expresión **preservación del patrimonio digital** (ap. 5).

La estructura del principio dibuja una **línea temporal del incidente** con cuatro tramos, y cada tramo tiene medidas del anexo II asociadas:

Fase	Qué persigue	Medidas típicas del anexo II
Prevención	Que el incidente no ocurra	`op.exp.2` configuración de seguridad · `op.exp.4` mantenimiento y actualizaciones · `op.acc.*` control de acceso · `mp.com.1` perímetro seguro
Detección	Enterarse de que está ocurriendo	`op.mon.1` detección de intrusión · `op.exp.8` registro de la actividad · `op.exp.6` protección frente a código dañino
Respuesta	Contener, erradicar y restaurar	`op.exp.7` gestión de incidentes · `op.exp.9` registro de la gestión de incidentes · `mp.info.6` copias de seguridad
Conservación	Que la información siga estando y siga valiendo	`mp.info.6` copias de seguridad · `op.cont.*` continuidad · y, fuera del ENS, la conservación del **ENI**

Esa última fila contiene el primer **puente entre los dos esquemas** del tema, y conviene señalarlo ya: la conservación que el ENS enuncia como principio la desarrolla operativamente el **ENI** en su capítulo X, y el propio ENI cierra el círculo remitiendo al ENS para la seguridad de esa conservación `[ENI, art. 22.1]`. Se vuelve sobre ello en §4.2.1.

RELACIÓN CON OTROS TEMAS

El desarrollo técnico de la **gestión de incidencias** —flujo de atención, escalado, prioridades y cierre— corresponde al **Tema 29**. Las **políticas y sistemas de copia de seguridad**, al **Tema 26**. Aquí interesa únicamente el mandato normativo y su código de medida.

EJEMPLO DE APLICACIÓN EN EL AYTO

Un ataque de secuestro de datos alcanza a un servidor departamental del Ayuntamiento. Las cuatro fases se leen así: la **prevención** falló porque el servidor llevaba meses sin parchear (`op.exp.4`); la **detección** funcionó en cuanto la sonda de vigilancia advirtió cifrado masivo de ficheros (`op.mon.1`); la **respuesta** consistió en aislar el segmento, abrir el incidente, notificar al **CCN-CERT** conforme al artículo 33.2 del ENS y a su instrucción técnica, y restaurar desde copia (`op.exp.7` , `mp.info.6`); y la **conservación** se acreditó al comprobar que los expedientes restaurados conservaban sus firmas y sus metadatos, es decir, que seguían valiendo como documentos administrativos. Nótese que el artículo 33.6 añade una obligación que se olvida: tras el incidente, el **CCN-CERT determina técnicamente el riesgo de reconexión** del sistema afectado `[ENS, art. 33.6]` .

El diagrama D6 sitúa las cuatro fases sobre la línea de tiempo de un incidente e indica en qué momento entra cada grupo de medidas.

2.2.3. Líneas de defensa, vigilancia continua, reevaluación y diferenciación de responsabilidades

Este epígrafe agrupa los **cuatro principios restantes** — `d)`, `e)`, `f)` y `g)` —, que son los que describen **cómo se organiza** la seguridad: en capas, bajo observación permanente, con revisión periódica y con las responsabilidades repartidas.

Principio `d)`: existencia de líneas de defensa (artículo 9). El sistema «ha de disponer de una estrategia de protección constituida por **múltiples capas de seguridad**», dispuesta de forma que, **cuando una de las capas sea comprometida**, permita `a)` «desarrollar una **reacción adecuada** frente a los incidentes que no han podido evitarse, reduciendo la probabilidad de que el sistema sea comprometido **en su conjunto**» y `b)` «**minimizar el impacto final** sobre el mismo». Y el apartado 2 cierra con la enumeración clave: «las líneas de defensa han de estar constituidas por medidas de naturaleza **organizativa, física y lógica**» `[ENS, art. 9]`.

> DATO CLAVE
>
> Las tres naturalezas de las líneas de defensa son **organizativa, física y lógica**, en ese orden y con la organizativa la primera. Y el supuesto de hecho del artículo 9.1 es «**cuando** una de las capas sea comprometida», no «si»: la norma **da por descontado que alguna capa fallará**. Ese matiz —diseñar asumiendo el fallo— es lo que distingue la defensa en profundidad de la simple acumulación de barreras.

Las tres naturalezas se corresponden con los tres grupos del anexo II, y esa correspondencia es la mejor manera de recordar ambas cosas a la vez: lo **organizativo** con `org` y buena parte de `op`, lo **físico** con `mp.if`, y lo **lógico** con `op.acc`, `op.exp`, `mp.com` y `mp.sw`.

Principios `e)` y `f)`: vigilancia continua y reevaluación periódica (artículo 10). El artículo tiene tres apartados y cada uno corresponde a una idea distinta `[ENS, art. 10]`:

1. «La **vigilancia continua** permitirá la **detección de actividades o comportamientos anómalos** y su oportuna respuesta.»
2. «La **evaluación permanente del estado de la seguridad de los activos** permitirá **medir su evolución**, detectando **vulnerabilidades** e identificando **deficiencias de configuración**.»
3. «Las medidas de seguridad se **reevaluarán y actualizarán periódicamente**, adecuando su eficacia a la evolución de los riesgos y los sistemas de protección, **pudiendo llegar a un replanteamiento de la seguridad**, si fuese necesario.»

DATO CLAVE

La diferencia entre los apartados 1 y 3 del artículo 10 es la diferencia entre los principios `e)` y `f)`. La **vigilancia continua** mira **el tráfico y el comportamiento** y es permanente. La **reevaluación periódica** mira **las medidas** y es discontinua: se hace cada cierto tiempo y puede terminar en un **replanteamiento** completo. El apartado 2 es el puente entre ambas: la evaluación permanente del estado de los activos, que es lo que en el anexo II se llama `op.mon.2` (sistema de métricas) y `op.mon.3` (vigilancia).

Principio `g)` : diferenciación de responsabilidades (artículo 11). Es el principio con más consecuencias organizativas de los siete, y el que el anexo III convierte en punto de auditoría con nombre propio `[ENS, anexo III, ap. 1.1.c)]`. Sus tres apartados dicen `[ENS, art. 11]`:

1. «En los sistemas de información se diferenciará el **responsable de la información**, el **responsable del servicio**, el **responsable de la seguridad** y el **responsable del sistema**.»
2. «La **responsabilidad de la seguridad** de los sistemas de información estará **diferenciada de la responsabilidad sobre la explotación** de los sistemas de información concernidos.»
3. «La **política de seguridad** de la organización detallará las **atribuciones de cada responsable** y los **mecanismos de coordinación y resolución de conflictos**.»

Los cuatro papeles responden a preguntas distintas y hay que saber distinguirlos:

Responsable	De qué responde	Decisión característica
Responsable de la información	Del **contenido**: qué es esa información y cuánto vale	**Valora los niveles** de las dimensiones de la información (art. 41.1)
Responsable del servicio	De la **prestación**: para qué sirve y qué pasa si se cae	**Valora los niveles** de las dimensiones del servicio (art. 41.1)
Responsable de la seguridad	De **que las medidas sean las adecuadas y funcionen**	**Determina la categoría** del sistema (art. 41.2); firma la **Declaración de Aplicabilidad** (art. 28.2); **analiza los informes de auditoría** (art. 31.5)
Responsable del sistema	De la **explotación**: que el sistema funcione día a día	**Adopta las medidas correctoras** tras la auditoría (art. 31.5); puede **suspender el tratamiento** en categoría ALTA ante deficiencias graves (art. 31.6)

DATO CLAVE

El reparto de facultades del **artículo 41** es esencial: **valorar** las dimensiones corresponde al **responsable de la información o del servicio** (ap. 1); **determinar la categoría** del sistema corresponde al **responsable de la seguridad** (ap. 2). Y la regla del **artículo 11.2** es igual de importante: **seguridad y explotación han de estar separadas**, es decir, el responsable de la seguridad **no puede ser** el responsable del sistema. Es la traducción al ENS del principio de segregación de funciones, que reaparece como medida `op.acc.3`.

La razón de fondo de esa separación es evitar el conflicto de interés más elemental de la informática: quien explota un sistema tiene incentivos para minimizar los avisos que le obligarían a pararlo. Si la misma persona firma la conformidad y opera el servicio, la conformidad no vale nada.

El **artículo 13** desarrolla el principio y añade tres reglas que casi ningún resumen recoge:

- **Regla de separación reforzada (art. 13.3).** «El responsable de la seguridad **será distinto** del responsable del sistema, **no debiendo existir dependencia jerárquica entre ambos**.» No basta con que sean dos personas: **no puede haber jerarquía** entre ellas. Y la norma prevé la excepción y su remedio: en situaciones excepcionales en que «la **ausencia justificada de recursos**» obligue a que ambas funciones recaigan en la misma persona o en personas con relación jerárquica, «deberán aplicarse **medidas compensatorias**» `[ENS, art. 13.3]`. Es la vía por la que un municipio pequeño puede cumplir sin duplicar plantilla.
- **Certificación de responsables de seguridad (art. 13.4).** «Una Instrucción Técnica de Seguridad regulará el **Esquema de Certificación de Responsables de la Seguridad**» `[ENS, art. 13.4]`. Conviene saber que **esa instrucción técnica todavía no se ha aprobado**: las publicadas siguen siendo cuatro, todas anteriores a 2019 (§4.1.1).
- **El punto de contacto en servicios externalizados (art. 13.5).** En servicios externalizados, la organización prestataria «deberá designar un **POC (Punto o Persona de Contacto)** para la seguridad», que será su propio responsable de seguridad, formará parte de su área o tendrá comunicación directa con ella. La norma cierra con la cautela decisiva: «todo ello sin perjuicio de que **la responsabilidad última resida en la entidad del sector público** destinataria de los citados servicios» `[ENS, art. 13.5]`.

DATO CLAVE

El artículo 13.5 contiene la regla que resuelve cualquier pregunta sobre externalización: **la responsabilidad última no se externaliza nunca**. Se puede contratar la operación, la vigilancia e incluso la respuesta a incidentes; la responsabilidad sigue siendo de la entidad pública. El proveedor aporta un **POC**, no una exoneración.

EJEMPLO DE APLICACIÓN EN EL AYTO

En el Ayuntamiento de Madrid este principio se materializa por escrito. La **Política de Seguridad de la Información del Ayuntamiento de Madrid y de sus Organismos Públicos**, aprobada por **Acuerdo de la Junta de Gobierno de 7 de julio de 2022** (BOAM núm. 9177, de 11 de julio de 2022), sustituyó a la de 2017 para adaptar el marco municipal al RD 311/2022 e incorporó la figura del **responsable de seguridad delegado**, que acerca la función a cada ámbito sectorial `[PSI-MAD]`. Por encima de ella, el **Decreto del Alcalde de 17 de noviembre de 2021** creó el **Comité Municipal de Seguridad de la Información**, órgano colegiado encargado de proponer sus modificaciones y actualizaciones `[CMSI]`, que es exactamente lo que exige la letra `d)` del artículo 12.1 del ENS. Y por debajo, la **Resolución de 6 de marzo de 2024 de la Coordinadora General de la Alcaldía** aprobó la **instrucción sobre los criterios generales de seguridad en el uso de los sistemas de información y servicios digitales** (BOAM núm. 9589, de 11 de marzo de 2024), que ocupa el nivel de **normativa de seguridad** (`org.2`) `[INSTR-MAD]`. Tres niveles —política, normativa e instrucciones— que reproducen las medidas `org.1`, `org.2` y `org.3` del anexo II.

Los diagramas D7 y D8 desarrollan, respectivamente, las capas de defensa con sus tres naturalezas y el reparto de los cuatro responsables con la regla de separación.

Un cierre imprescindible: la política de seguridad como instrumento (artículo 12). Los siete principios no flotan: se plasman en un documento. El artículo 12.1 define la política de seguridad de la información como «el conjunto de **directrices** que rigen la forma en que una organización **gestiona y protege** la información que trata y los servicios que presta», y fija su **contenido mínimo en seis letras** `[ENS, art. 12.1]`:

Letra	Contenido mínimo de la política de seguridad
`a)`	Los **objetivos o misión** de la organización
`b)`	El **marco regulatorio** en el que se desarrollarán las actividades
`c)`	Los **roles o funciones de seguridad**, con sus deberes y responsabilidades y el **procedimiento para su designación y renovación**
`d)`	La **estructura y composición del comité o los comités** para la gestión y coordinación de la seguridad
`e)`	Las **directrices para la estructuración de la documentación** de seguridad del sistema, su gestión y acceso
`f)`	Los **riesgos que se derivan del tratamiento de los datos personales**

DATO CLAVE

Seis letras en el artículo 12.1, no ocho. La letra que más se olvida es la `f)`: la política de seguridad del ENS tiene que hablar expresamente de los **riesgos derivados del tratamiento de datos personales**. Es otra manifestación de la concurrencia con el RGPD del artículo 3.

Los apartados 2 a 5 del artículo 12 resuelven **quién aprueba qué**, y el apartado 5 tiene interés municipal directo:

- Cada **administración pública** contará con una política formalmente aprobada por el órgano competente, y **cada órgano o entidad con personalidad jurídica propia** del ámbito del artículo 2 también, aunque el sector público institucional puede quedar comprendido en la política de la Administración de la que dependa `[ENS, art. 12.2]`.
- En la **Administración General del Estado**, **cada ministerio** contará con su política, aprobada por la persona titular del Departamento `[ENS, art. 12.3]`.
- «Los **municipios podrán disponer de una política de seguridad común** elaborada por la **entidad local comarcal o provincial** que asuma la responsabilidad de la seguridad de la información de los sistemas municipales» `[ENS, art. 12.5]`.

DATO CLAVE

El **artículo 12.5** es la respuesta a la pregunta «¿cómo cumple el ENS un ayuntamiento de mil habitantes?». Puede acogerse a una **política común elaborada por la diputación o el ente comarcal**. No es el caso de Madrid —que tiene la suya propia—, pero es relevante porque es la única mención expresa a los municipios en todo el articulado. La política de seguridad es, además, un documento **obligatorio en las tres categorías**: la medida `org.1` aparece marcada como «aplica» en BÁSICA, MEDIA y ALTA. Un sistema sin política de seguridad **no puede ser conforme al ENS ni siquiera en categoría BÁSICA**.

Bajo la política, el capítulo III despliega los **quince requisitos mínimos**, enumerados en el **artículo 12.6** con las letras `a)` a `ñ)` y desarrollados uno por artículo en los **artículos 13 a 27**: organización e implantación del proceso de seguridad (13), análisis y gestión de los riesgos (14), gestión de personal (15), profesionalidad (16), autorización y control de los accesos (17), protección de las instalaciones (18), adquisición de productos de seguridad y contratación de servicios de seguridad (19), mínimo privilegio (20), integridad y actualización del sistema (21), protección de la información almacenada y en tránsito (22), prevención ante otros sistemas de información interconectados (23), registro de la actividad y detección de código dañino (24), incidentes de seguridad (25), continuidad de la actividad (26) y mejora continua del proceso de seguridad (27) `[ENS, arts. 12.6 y 13–27]`.

DATO CLAVE

Son **quince requisitos mínimos**, letras `a)` a `ñ)` del artículo 12.6 y artículos 13 a 27, uno por requisito. El **artículo 12.7** matiza su exigibilidad con una regla de proporcionalidad: «los requisitos mínimos se exigirán **en proporción a los riesgos** identificados en cada sistema (…), alguno de los cuales **podrá obviarse en sistemas sin riesgos significativos**». Nótese la diferencia con los **principios básicos**, que **no admiten excepción alguna**: los principios se aplican siempre; los requisitos, en proporción al riesgo.

Dos de esos quince requisitos conviene retenerlos con su literal por su valor en el test. El **artículo 14.2** ordena emplear «alguna **metodología reconocida internacionalmente**» para el análisis y tratamiento de riesgos —lo que en España significa, en la práctica, **MAGERIT** y su herramienta **PILAR** `[MAGERIT]` —. Y el **artículo 16.1** exige que la seguridad esté atendida, revisada y auditada por **personal cualificado, dedicado e instruido** en **todas las fases del ciclo de vida**, que el precepto enumera: planificación, diseño, adquisición, construcción, despliegue, explotación, mantenimiento, **gestión de incidencias** y **desmantelamiento** `[ENS, art. 16.1]`.

2.3. Dimensiones de seguridad de la información

Las **dimensiones de seguridad** son las **propiedades de la información y de los servicios** cuya pérdida se valora para decidir cuánta seguridad hace falta. No son medidas ni objetivos: son **magnitudes que se puntúan**. El **apartado 2 del anexo I** las enumera y ordena que se identifiquen «por sus correspondientes **iniciales en mayúsculas**» `[ENS, anexo I, ap. 2]`:

`a)` **Confidencialidad [C]** · `b)` **Integridad [I]** · `c)` **Trazabilidad [T]** · `d)` **Autenticidad [A]** · `e)` **Disponibilidad [D]**

DATO CLAVE

El orden del anexo I vigente es **C, I, T, A, D**. El del derogado RD 3/2010 era **D, A, I, C, T** `[RD3-2010]`. Muchísimos resúmenes siguen dando el orden antiguo. Como regla mnemotécnica, el orden vigente se lee como **«CITAD»**, con las tres primeras —confidencialidad, integridad, trazabilidad— pegadas al concepto clásico de seguridad, y las dos últimas —autenticidad y disponibilidad— añadiendo lo que la Administración necesita para que un acto valga y para que un servicio se preste.

Las cinco definiciones proceden del **glosario del anexo IV** y conviene retenerlas casi literalmente `[ENS, anexo IV]`:

Dimensión	Definición del anexo IV	Pregunta que responde
Confidencialidad [C]	«Propiedad o característica consistente en que la información **ni se pone a disposición, ni se revela** a individuos, entidades o procesos **no autorizados**»	¿Quién puede ver esto?
Integridad [I]	«Propiedad o característica consistente en que el activo de información **no ha sido alterado de manera no autorizada**»	¿Es esto lo mismo que se guardó?
Trazabilidad [T]	«Propiedad o característica consistente en que **las actuaciones de una entidad** (persona o proceso) **pueden ser trazadas de forma indiscutible hasta dicha entidad**»	¿Quién hizo qué y cuándo?
Autenticidad [A]	«Propiedad o característica consistente en que **una entidad es quien dice ser** o bien que **garantiza la fuente de la que proceden los datos**»	¿Es de quien dice ser?
Disponibilidad [D]	«Propiedad o característica de los activos consistente en que las entidades o procesos autorizados **tienen acceso a los mismos cuando lo requieren**»	¿Está cuando hace falta?

El diagrama D9 presenta las cinco dimensiones con su inicial, su definición abreviada y la pregunta que responde cada una.

2.3.1. Disponibilidad, integridad y confidencialidad

Estas tres son la **tríada clásica** de la seguridad de la información —la que en la literatura anglosajona se abrevia CIA— y son también las que un opositor tiende a manejar bien. Conviene, aun así, precisar tres cosas.

La disponibilidad no es «que el servidor esté encendido». El glosario la define desde el punto de vista del **usuario autorizado**: que **tenga acceso cuando lo requiere**. Un sistema encendido pero inaccesible por saturación, por un fallo de la red o por una caída del directorio de usuarios **no está disponible** en el sentido del ENS. Por eso la disponibilidad es la dimensión que arrastra tras de sí el grupo de medidas más caro del anexo II: `op.cont.1` a `op.cont.4` (continuidad del servicio), `op.pl.4` (dimensionamiento y gestión de la capacidad), `mp.if.4` (energía eléctrica), `mp.if.5` y `mp.if.6` (incendios e inundaciones), `mp.info.6` (copias de seguridad) y `mp.s.4` (protección frente a denegación de servicio). Todas ellas llevan una **D** en la columna de dimensiones del anexo II.

DATO CLAVE

Las medidas de **continuidad** `op.cont.2` (plan de continuidad), `op.cont.3` (pruebas periódicas) y `op.cont.4` (medios alternativos) están marcadas como `n.a.` **en BÁSICA y en MEDIA**, y solo **aplican en ALTA**. La única de la familia que aparece ya en MEDIA es `op.cont.1` (análisis de impacto).

La integridad protege contra la alteración, no contra la lectura. La definición insiste en «alterado de manera **no autorizada**»: una modificación autorizada y trazada no rompe la integridad. Sus medidas naturales son `mp.info.3` (firma electrónica), `mp.si.2` (criptografía), `mp.com.3` (protección de la integridad y de la autenticidad) y `op.exp.3` (gestión de la configuración de seguridad).

La confidencialidad es la única de las cinco que, una vez perdida, no se puede recuperar. Un dato indisponible vuelve; un dato alterado se restaura desde copia; un dato **divulgado** ya no se puede volver a hacer secreto. Esta observación no está en la norma, pero explica su tratamiento: la confidencialidad concentra las medidas de cifrado (`mp.si.2` , `mp.com.2`), de marcado y destrucción de soportes (`mp.si.1` , `mp.si.5`), de calificación de la información (`mp.info.2`) y de limpieza de documentos (`mp.info.5` , la medida que obliga a eliminar los metadatos ocultos antes de publicar un fichero).

EJERCICIO RESUELTO

¿Qué dimensión se ve afectada en cada uno de estos cuatro incidentes sobre el Padrón municipal? 1. Un funcionario consulta sin motivo el domicilio de una persona conocida. → **Confidencialidad**. El dato no se ha alterado ni ha dejado de estar disponible; se ha revelado a quien no estaba autorizado a verlo para ese fin. Además, la **trazabilidad** es lo que permite descubrirlo. 2. Un error de un proceso de carga cambia el número de portal de doscientas inscripciones. → **Integridad**. 3. El servicio de consulta del Padrón queda inaccesible tres días. → **Disponibilidad**. 4. Un certificado de empadronamiento circula sin sello electrónico y no se puede demostrar que lo emitió el Ayuntamiento. → **Autenticidad**. La lección del ejercicio es que las dimensiones **no son excluyentes**: un mismo incidente puede afectar a varias, y el anexo I obliga a valorarlas **una por una**, no en conjunto.

2.3.2. Autenticidad y trazabilidad

Estas dos son las **dimensiones específicamente administrativas** y las que más se confunden. Ambas tienen que ver con «quién», pero con **quiénes distintos y en momentos distintos**.

Autenticidad: quién es el origen. Responde a la pregunta de si una entidad **es quien dice ser** o si los datos proceden **de la fuente que dicen proceder**. Es la dimensión que hace posible el acto administrativo electrónico: sin autenticidad, un documento firmado no acredita quién lo firmó y una solicitud presentada no acredita quién la presentó. Sus medidas son `op.acc.1`

(identificación, con dimensiones **T** y **A**), `op.acc.5` y `op.acc.6` (mecanismos de autenticación), `mp.com.3` (protección de la integridad **y de la autenticidad**, dimensiones **I** y **A**) y `mp.info.3` (firma electrónica, dimensiones **I** y **A**).

> DATO CLAVE
>
> Obsérvese que la autenticidad casi nunca viaja sola en la columna de dimensiones del anexo II: aparece emparejada con la integridad en `mp.com.3` (**IA**) y en `mp.info.3` (**IA**), y con la trazabilidad en `op.acc.1` (**TA**). Tiene sentido: una firma electrónica que garantiza quién firmó garantiza a la vez que el contenido no ha cambiado, porque si cambiara la firma dejaría de validar. **Autenticidad e integridad son técnicamente inseparables cuando el mecanismo es criptográfico.** La denominación literal de la medida es «Protección de la **integridad y de la autenticidad**», en ese orden.

Trazabilidad: quién hizo qué, después. Responde a una pregunta **retrospectiva**: reconstruir las actuaciones y atribuirlas «de forma **indiscutible**» a una entidad. Es la dimensión de la **rendición de cuentas**, y su medida canónica es `op.exp.8` (registro de la actividad), que en el anexo II lleva **T** como única dimensión y que en nivel **ALTO** acumula **cinco refuerzos**, R1 a R5. La acompañan `op.exp.9` (registro de la gestión de incidentes), `op.mon.3` (vigilancia) y `mp.info.4` (sellos de tiempo).

> DATO CLAVE
>
> `mp.info.4` **(sellos de tiempo)** es la medida que mejor discrimina: dimensión **T**, `n.a.` en **BÁSICA**, `n.a.` en **MEDIA** y **aplica solo en ALTA**. Es la única medida del grupo `mp.info` que no aparece hasta el nivel más alto. Su función es dar **fecha y hora oponibles frente a terceros**, cosa que el reloj del servidor no hace.

La diferencia entre las dos dimensiones se aprecia mejor sobre un mismo hecho. Cuando una persona presenta una solicitud en la sede electrónica municipal:

Momento	Dimensión en juego	Mecanismo
Se identifica con certificado o con Cl@ve	**Autenticidad**	Autenticación (`op.acc.5`)
Firma la solicitud	**Autenticidad** e **integridad**	Firma electrónica (`mp.info.3`)
El registro le asigna número y fecha	**Trazabilidad**	Asiento registral y, si el nivel lo exige, **sello de tiempo** (`mp.info.4`)
Meses después se audita quién consultó el expediente	**Trazabilidad**	Registro de la actividad (`op.exp.8`)

EJEMPLO DE APLICACIÓN EN EL AYTO

El sistema de tramitación de expedientes del Ayuntamiento almacena, para cada acceso a un expediente, el identificador del empleado, el momento y la operación. Ese registro **no protege el expediente**: no impide que se consulte indebidamente. Lo que hace es permitir **reconstruir después** quién lo hizo, que es exactamente lo que dice el glosario cuando define la trazabilidad como la propiedad de que las actuaciones «pueden ser **trazadas de forma indiscutible** hasta dicha entidad». Es también lo que convierte al registro de actividad en un dato personal sujeto al RGPD: el `op.exp.8` y el `mp.info.1` se aplican sobre el mismo fichero.

RELACIÓN CON OTROS TEMAS

Los **mecanismos criptográficos** que hacen posibles la autenticidad y la integridad —funciones resumen, firma con clave pública, certificados y sellos de tiempo— se desarrollan en el **Tema 32**. La **protección de la información en tránsito** por la red y los protocolos que la implementan, en los **Temas 35 y 36**.

El diagrama D10 contrapone autenticidad, integridad y trazabilidad sobre el recorrido de una solicitud en la sede electrónica municipal.

2.4. Categorización de los sistemas de información

2.4.1. Criterios de valoración y niveles de impacto

Para qué sirve categorizar. El artículo 40.1 lo dice con precisión: la categoría de seguridad «**modulará el equilibrio** entre la importancia de la información que maneja y los servicios que presta y el **esfuerzo de seguridad requerido**, en función de los riesgos a los que está expuesto, bajo el **principio de proporcionalidad**» `[ENS, art. 40.1]`. Categorizar es, por tanto, la operación que traduce **cuánto vale lo que hay dentro** en **cuánta seguridad hay que poner**.

Sobre qué se valora. El apartado 1 del anexo I fija tres criterios: la determinación de la categoría se basa en la valoración del impacto que tendría sobre la organización un incidente que afectase a la seguridad de la información tratada o de los servicios prestados para `a)` **alcanzar sus objetivos**, `b)` **proteger los activos a su cargo** y `c)` **garantizar la conformidad con el ordenamiento jurídico** `[ENS, anexo I, ap. 1]`.

> DATO CLAVE
>
> El mismo apartado 1 impone una obligación temporal: «**Anualmente**, o siempre que se produzcan **modificaciones significativas** en los citados criterios de determinación, deberá **re-evaluarse la categoría** de seguridad de los sistemas de información concernidos» `[ENS, anexo I, ap. 1]`. Es decir: **la categoría se revisa cada año**, mientras que la **auditoría** es al menos **cada dos años** (art. 31.1) y el **análisis de riesgos** se revisa y aprueba **anualmente** (anexo III). Tres plazos distintos que conviene no mezclar.

Los tres niveles. Cada dimensión afectada se adscribe a uno de tres niveles: **BAJO, MEDIO o ALTO**. Y el anexo I añade la regla que más se olvida: «**si una dimensión de seguridad no se ve afectada, no se adscribirá a ningún nivel**» `[ENS, anexo I, ap. 3]`. No existe un «nivel cero»: la dimensión simplemente **no se valora**.

Los tres niveles se definen por el **grado de perjuicio**, y cada definición se desglosa en **cinco supuestos** con la misma estructura:

Nivel	Perjuicio	Los cinco supuestos del anexo I
BAJO	**Limitado**	1.º Reducción **apreciable** de la capacidad de la organización, aunque las funciones **sigan desempeñándose** · 2.º Daño **menor** en los activos · 3.º Incumplimiento **formal** de una ley o regulación, con carácter **subsanable** · 4.º Perjuicio **menor** a algún individuo, molesto pero **fácilmente reparable** · 5.º Otros de naturaleza análoga
MEDIO	**Grave**	1.º Reducción **significativa** de la capacidad, aunque las funciones sigan desempeñándose · 2.º Daño **significativo** en los activos · 3.º Incumplimiento **material**, o incumplimiento formal **no subsanable** · 4.º Perjuicio **significativo** a algún individuo, de **difícil reparación** · 5.º Otros de naturaleza análoga
ALTO	**Muy grave**	1.º **Anulación efectiva** de la capacidad de la organización · 2.º Daño **muy grave, e incluso irreparable** · 3.º Incumplimiento **grave** de una ley o regulación · 4.º Perjuicio **grave** a algún individuo, de **difícil o imposible reparación** · 5.º Otros de naturaleza análoga

DATO CLAVE

Los tres adjetivos del perjuicio son **limitado (BAJO)**, **grave (MEDIO)** y **muy grave (ALTO)**. Y la escala del incumplimiento jurídico es la que mejor discrimina en un test: **formal y subsanable** en BAJO; **material, o formal no subsanable**, en MEDIO; y **grave** en ALTO. Obsérvese la diferencia de gradación en las funciones: en BAJO la capacidad se reduce «de forma **apreciable**», en MEDIO «de forma **significativa**» —y en ambos casos las funciones **siguen desempeñándose**—, mientras que en ALTO se produce la «**anulación efectiva**» de la capacidad. Ese «siguen desempeñándose» es la frontera entre MEDIO y ALTO.

La regla del máximo entre informaciones y servicios. El anexo I cierra el apartado 3 con una regla de agregación: «cuando un sistema de información trate **diferentes informaciones** y preste **diferentes servicios**, el nivel de seguridad del sistema **en cada dimensión** será **el mayor** de los establecidos para cada información y cada servicio» `[ENS, anexo I, ap. 3]`.

2.4.2. Categorías de sistemas de información

Las tres categorías. El apartado 4 del anexo I define tres —**BÁSICA, MEDIA y ALTA**— y las determina con una regla que conviene leer despacio `[ENS, anexo I, ap. 4]`:

- Un sistema será de categoría **ALTA** si **alguna** de sus dimensiones alcanza el nivel de seguridad **ALTO**.
- Un sistema será de categoría **MEDIA** si **alguna** de sus dimensiones alcanza el nivel **MEDIO**, y **ninguna alcanza un nivel superior**.
- Un sistema será de categoría **BÁSICA** si **alguna** de sus dimensiones alcanza el nivel **BAJO**, y **ninguna alcanza un nivel superior**.

DATO CLAVE

Manda **la dimensión más alta**, no la media ni la mayoría. Cuatro dimensiones en BAJO y una en ALTO dan categoría **ALTA**. Y hay que fijarse en los nombres: los **niveles** son **BAJO, MEDIO y ALTO** (masculino, referidos a dimensiones); las **categorías** son **BÁSICA, MEDIA y ALTA** (femenino, referidas al sistema). **La categoría más baja no se llama «BAJA», se llama «BÁSICA»**. Es un error frecuentísimo y una opción de test muy habitual.

El apartado 4.2 añade una precisión que suele pasar inadvertida y que tiene consecuencias prácticas: «la determinación de la categoría de seguridad de un sistema (…) **no implicará que se altere, por este hecho, el nivel de seguridad de las dimensiones** que no han influido en la determinación de la categoría» `[ENS, anexo I, ap. 4.2]`. Es decir: que un sistema sea de categoría ALTA porque su confidencialidad es ALTA **no eleva** su disponibilidad, que seguirá siendo BAJA si así se valoró. Y eso importa porque **muchas medidas del anexo II se exigen por dimensión, no por categoría**.

La secuencia de actuaciones. El apartado 5 del anexo I la fija en dos pasos, y el apartado 2 del anexo II la amplía a cinco para la selección de medidas `[ENS, anexo I, ap. 5]` `[ENS, anexo II, ap. 2.1]`:

1. **Identificar los tipos de activos** presentes.
2. **Determinar las dimensiones relevantes** para cada información y cada servicio.
3. **Determinar el nivel** de cada dimensión (BAJO, MEDIO o ALTO), aplicando la regla del máximo entre informaciones y servicios.
4. **Determinar la categoría** del sistema (BÁSICA, MEDIA o ALTA).
5. **Seleccionar las medidas de seguridad**, junto con los refuerzos apropiados, según las dimensiones y sus niveles y, para determinadas medidas, según la categoría.

Quién hace cada paso. El artículo 41 reparte las facultades: **valorar** corresponde al **responsable o responsables de la información o de los servicios** afectados (ap. 1); **determinar la categoría** a partir de esas valoraciones corresponde al **responsable o responsables de la seguridad** (ap. 2) `[ENS, art. 41]`.

La segregación de subsistemas. El anexo II ofrece una salida de eficiencia que es materia de caso práctico: «cuando en un sistema de información existan **subsistemas que requieran la aplicación de un nivel de medidas de seguridad diferente** al del sistema principal, **podrán segregarse** de este último, siendo de aplicación en cada caso el nivel de medidas con los refuerzos correspondientes, y siempre que **puedan delimitarse la información y los servicios afectados**» `[ENS, anexo II, ap. 2.2]`.

> DATO CLAVE
>
> La segregación de subsistemas del **anexo II, apartado 2.2** es la herramienta que evita que un módulo pequeño y muy sensible arrastre a categoría ALTA a un sistema entero. Su condición de validez es que **la información y los servicios se puedan delimitar**: si no se pueden separar, no hay segregación posible y manda el máximo.

EJERCICIO RESUELTO

Categorizar el sistema de tramitación de expedientes de la sede electrónica municipal. Valoraciones acordadas por los responsables de la información y del servicio: - **Confidencialidad**: los expedientes incluyen datos personales de contacto y situación económica de solicitantes de ayudas. Una divulgación causaría un perjuicio **significativo y de difícil reparación** a personas identificables → nivel **MEDIO**. - **Integridad**: la alteración de una resolución supondría un incumplimiento **material** del ordenamiento → nivel **MEDIO**. - **Trazabilidad**: hay que poder acreditar quién resolvió y quién consultó → nivel **MEDIO**. - **Autenticidad**: sin autenticidad no hay acto administrativo válido; su pérdida anularía la capacidad de resolver → nivel **ALTO**. - **Disponibilidad**: una caída de un día retrasa la tramitación pero es **subsanable** y los plazos se pueden restituir → nivel **BAJO**. **Paso 1**: los niveles son C=MEDIO, I=MEDIO, T=MEDIO, A=ALTO, D=BAJO. **Paso 2**: alguna dimensión alcanza ALTO, luego la **categoría del sistema es ALTA**. **Paso 3**, y es donde está la nota del ejercicio: la categoría ALTA **no eleva la disponibilidad**, que sigue siendo BAJA (anexo I, ap. 4.2). Consecuencia concreta: las medidas exigidas **por categoría** —como `op.exp.4` o `mp.s.3` — se aplican en su versión de ALTA, mientras que las exigidas **por dimensión D** —como `op.cont.2` , `op.cont.3` y `op.cont.4` — **no aplican**, porque la disponibilidad se quedó en BAJO. Quien conteste «al ser categoría ALTA hay que hacer plan de continuidad» **falla**: la continuidad se exige por nivel de disponibilidad, no por categoría. **Variante**: si el mismo sistema alojara además el módulo de una sola unidad que trata datos de una categoría especial con confidencialidad ALTA, y ese módulo pudiera delimitarse en información y servicios, procedería **segregarlo como subsistema** (anexo II, ap. 2.2) en lugar de elevar el conjunto.

Los diagramas D11 y D12 desarrollan, respectivamente, los tres niveles con sus cinco supuestos y la conversión de niveles a categoría con el ejercicio anterior como ejemplo.

2.5. Medidas de seguridad y evaluación de la conformidad

2.5.1. Marco organizativo, marco operacional y medidas de protección

La estructura del anexo II. Las medidas se aplican de forma **proporcional** a `a)` las dimensiones relevantes en el sistema a proteger y `b)` la categoría del sistema, y se dividen en **tres grupos** `[ENS, anexo II, ap. 1]` :

- **Marco organizativo [`org`]**: «conjunto de medidas relacionadas con la **organización global** de la seguridad».
- **Marco operacional [`op`]**: «medidas a tomar para **proteger la operación** del sistema como conjunto integral de componentes para un fin».
- **Medidas de protección [`mp`]**: «se centran en **proteger activos concretos**, según su naturaleza y la calidad exigida por el nivel de seguridad de las dimensiones afectadas».

El catálogo completo, con su recuento, es el siguiente:

Grupo	Familias	Medidas
`org` — **Marco organizativo**	`org.1` política · `org.2` normativa · `org.3` procedimientos · `org.4` proceso de autorización	**4**
`op` — **Marco operacional**	`op.pl` planificación (5) · `op.acc` control de acceso (6) · `op.exp` explotación (10) · `op.ext` recursos externos (4) · `op.nub` servicios en la nube (1) · `op.cont` continuidad del servicio (4) · `op.mon` monitorización del sistema (3)	**33**
`mp` — **Medidas de protección**	`mp.if` instalaciones e infraestructuras (7) · `mp.per` gestión del personal (4) · `mp.eq` protección de los equipos (4) · `mp.com` protección de las comunicaciones (4) · `mp.si` soportes de información (5) · `mp.sw` aplicaciones informáticas (2) · `mp.info` protección de la información (6) · `mp.s` protección de los servicios (4)	**36**
Total	**16 familias**	**73**

DATO CLAVE

73 medidas, repartidas en **3 grupos** y **16 familias**: `org` **4**, `op` **33** y `mp` **36**. Las dos familias más numerosas son `op.exp` (**10 medidas**, de `op.exp.1` a `op.exp.10`) y `mp.if` (**7**). Y hay dos familias **nuevas del RD 311/2022** que no existían en el RD 3/2010: **`op.nub` (servicios en la nube)**, con una sola medida — `op.nub.1`, protección de servicios en la nube—, y la ampliación de **`op.ext`** con `op.ext.3` (**protección de la cadena de suministro**) y `op.ext.4` (**interconexión de sistemas**). También es nueva la familia **`op.mon`** con su medida `op.mon.3` (vigilancia).

Cómo se lee la tabla del anexo II. Cada fila tiene, además del código y el nombre, una **tercera columna** que indica si la medida se exige **por categoría** o **por nivel de una o más dimensiones**, y en este segundo caso se identifican las dimensiones por sus iniciales `[ENS, anexo II, ap. 5.a)]`. Después, tres columnas con lo exigible en **BAJO/BÁSICA**, **MEDIO/MEDIA** y **ALTO/ALTA**, con cuatro posibles contenidos:

Contenido de la celda	Significado
`n.a.`	**No aplica** en ese nivel o categoría
`aplica`	Se exige la medida en su formulación base, **sin refuerzos**
`+ R1`, `+ R1 + R2` …	Se exige la medida base **más** los refuerzos indicados, **todos ellos**
`+ [R1 o R2 o R3]`	Se exige la medida base más **uno de los refuerzos entre corchetes**, a elegir

DATO CLAVE

Los **corchetes con «o»** significan **elección entre refuerzos alternativos**; el signo `+` encadenado significa **acumulación**. Confundirlos es un error caro en un caso práctico. Los ejemplos canónicos son `mp.com.4`, que en MEDIA exige `+ [R1 o R2 o R3]` y en ALTA `+ [R2 o R3] + R4`; `mp.s.2`, que exige `+ [R1 o R2]` **ya en BÁSICA**; y `op.acc.6`, la medida con más refuerzos del anexo, que en ALTA exige `+ [R1 o R2 o R3 o R4] + R5 + R6 + R7 + R8 + R9`.

Algunas filas concretas cuya tabla de aplicación conviene tener memorizada:

Medida	Se exige por	BÁSICA	MEDIA	ALTA
`org.1` Política de seguridad	Categoría	aplica	aplica	aplica
`op.pl.1` Análisis de riesgos	Categoría	aplica	+ R1	+ R2
`op.exp.4` Mantenimiento y actualizaciones de seguridad	Categoría	aplica	+ R1	+ R1 + R2
`op.exp.8` Registro de la actividad	**T**	aplica	+ R1 + R2 + R3 + R4	+ R1 + R2 + R3 + R4 + R5
`op.exp.10` Protección de claves criptográficas	Categoría	aplica	+ R1	+ R1
`op.ext.3` Protección de la cadena de suministro	Categoría	n.a.	n.a.	aplica
`op.nub.1` Protección de servicios en la nube	Categoría	aplica	+ R1	+ R1 + R2
`op.cont.2` Plan de continuidad	**D**	n.a.	n.a.	aplica
`mp.com.1` Perímetro seguro	Categoría	aplica	aplica	aplica
`mp.com.4` Separación de flujos de información en la red	Categoría	**n.a.**	+ [R1 o R2 o R3]	+ [R2 o R3] + R4
`mp.info.3` Firma electrónica	**IA**	aplica	+ R1 + R2 + R3	+ R1 + R2 + R3 + R4
`mp.info.4` Sellos de tiempo	**T**	n.a.	n.a.	aplica
`mp.info.6` Copias de seguridad	**D**	aplica	+ R1	+ R1 + R2
`mp.s.2` Protección de servicios y aplicaciones web	Categoría	+ [R1 o R2]	+ [R1 o R2]	+ R2 + R3

DATO CLAVE

Tres filas que se confunden con facilidad. `mp.com.4` **no aplica en BÁSICA**: la separación de flujos —la segmentación en VLAN— no es exigible al sistema más sencillo. `op.ext.3` **(cadena de suministro) solo aplica en ALTA.** Y `mp.s.2` **exige ya en BÁSICA un refuerzo a elegir**, `+ [R1 o R2]`, lo que la convierte en la única medida del anexo que **no tiene formulación base pura en ninguna categoría**: cualquier servicio web de una Administración, por sencillo que sea, arrastra un refuerzo desde el primer escalón.

La Declaración de Aplicabilidad. El artículo 28 cierra el círculo. Las medidas del anexo II tienen «la condición de **mínimos exigibles, siendo ampliables** a criterio del responsable de la seguridad», y «la relación de medidas de seguridad seleccionadas **se formalizará en un documento denominado Declaración de Aplicabilidad, firmado por el responsable de la seguridad**» `[ENS, art. 28.2]`.

Las medidas compensatorias. El apartado 3 permite reemplazar medidas del anexo II «por otras **compensatorias**, siempre y cuando se **justifique documentalmente** que protegen, **igual o mejor**, del riesgo sobre los activos y se satisfacen los **principios básicos y los requisitos mínimos**». La correspondencia entre medida compensatoria y medida compensada se indica «de forma detallada» **como parte integral de la Declaración de Aplicabilidad**, y el conjunto es objeto de **aprobación formal por el responsable de la seguridad** `[ENS, art. 28.3]`.

DATO CLAVE

Las medidas compensatorias tienen **tres condiciones acumulativas**: justificación **documental**, protección **igual o mejor**, y respeto a los **principios básicos y requisitos mínimos**. Y su sede documental es la **Declaración de Aplicabilidad**, no un documento aparte. La consecuencia conceptual es la que se anticipó en §2.2: **las medidas del anexo II se pueden sustituir; los principios básicos del capítulo II, no**. Los principios son el suelo del ENS.

Los perfiles de cumplimiento específicos. El artículo 30 permite, «en virtud del **principio de proporcionalidad**», implementar **perfiles de cumplimiento específicos** para entidades o sectores concretos: conjuntos de medidas que, derivadas del análisis de riesgos, resultan idóneas para una determinada categoría. Los **valida y publica el CCN** `[ENS, art. 30]`. El glosario los define como conjunto de medidas «**comprendidas o no en el anexo II**» que resulten de aplicación a una entidad o sector y «que haya sido **habilitado por el CCN**» `[ENS, anexo IV]`. Existe además, en el apartado 4 del mismo artículo, una previsión importante para el modelo de nube: las instrucciones técnicas o las guías CCN-STIC precisarán las condiciones de las **implementaciones en modo local de productos originariamente prestados en la nube** `[ENS, art. 30.4]`.

RELACIÓN CON OTROS TEMAS

El desarrollo de los **servicios en la nube** —modelos IaaS, PaaS y SaaS, nubes públicas, privadas e híbridas, y la extensión del ENS al proveedor privado por el artículo 2.3— corresponde al **Tema 31**. Aquí solo interesa que existe la familia `op.nub` y que `op.ext` cubre los recursos externos.

El diagrama D13 presenta el anexo II completo: tres grupos, dieciséis familias y el recuento de medidas de cada una.

2.5.2. Auditoría y certificación de conformidad

La auditoría de la seguridad (artículo 31). Los sistemas «serán objeto de una **auditoría regular ordinaria, al menos cada dos años**, que verifique el cumplimiento de los requerimientos del ENS». Con carácter **extraordinario**, deberá realizarse «siempre que se produzcan **modificaciones sustanciales** en los sistemas de información que puedan repercutir en las medidas de seguridad requeridas», y la realización de esa auditoría extraordinaria **reinicia el cómputo** de los dos años. El plazo «podrá extenderse durante **tres meses** cuando concurran impedimentos de **fuerza mayor no imputables** a la entidad titular» `[ENS, art. 31.1]`.

DATO CLAVE

Tres datos del artículo 31.1: la auditoría ordinaria es **al menos cada dos años** —«al menos», no «cada»: se puede hacer más a menudo—; la **extraordinaria** procede ante **modificaciones sustanciales** y **determina la nueva fecha de cómputo**; y la **prórroga** por fuerza mayor es de **tres meses**, un dato muy concreto que introdujo el RD 311/2022.

El resto del artículo 31 completa el régimen: la auditoría se realiza **en función de la categoría** y, en su caso, del perfil de cumplimiento, según los anexos I y III y la **Instrucción Técnica de Seguridad de Auditoría** (ap. 2); el informe **dictamina sobre el grado de cumplimiento** e identifica los **hallazgos de cumplimiento e incumplimiento**, con los criterios metodológicos, el alcance, el objetivo y los datos, hechos y observaciones en que se basen las conclusiones (ap. 4); los informes se presentan **al responsable del sistema y al responsable de la seguridad**, y es **este último** quien los analiza y presenta sus conclusiones al **responsable del sistema** para que adopte las medidas correctoras (ap. 5); en categoría **ALTA**, a la vista del dictamen y ante una eventual gravedad de las deficiencias, **el responsable del sistema podrá suspender temporalmente** el tratamiento de informaciones, la prestación de servicios o la total operación del sistema (ap. 6); y los informes **podrán ser requeridos por el CCN** (ap. 7) `[ENS, art. 31]`.

DATO CLAVE

El circuito del informe de auditoría se recuerda como una cadena: **el auditor informa → el responsable de la seguridad analiza → el responsable del sistema corrige**. Y la facultad de **suspender la operación** del artículo 31.6 corresponde al **responsable del sistema**, **solo en categoría ALTA** y **de forma temporal**, hasta la subsanación o mitigación.

Los dos caminos de la conformidad (artículo 38). Es el precepto que ordena la conformidad en el ENS:

- Sistemas de categoría **MEDIA o ALTA**: precisan de una **auditoría para la certificación** de su conformidad. La auditoría del artículo 31 «podrá servir asimismo para los fines de la certificación».
- Sistemas de categoría **BÁSICA**: «solo requerirán de una **autoevaluación** para su **declaración de la conformidad**, sin perjuicio de que se puedan someter igualmente a una auditoría de certificación» `[ENS, art. 38.1]`.

Y el apartado 2 añade la obligación de **publicidad**: los responsables «darán publicidad, en los correspondientes **portales de internet o sedes electrónicas**, a las declaraciones y certificaciones de conformidad», conforme a la Instrucción Técnica de Seguridad de Conformidad `[ENS, art. 38.2]`.

El **anexo III** desarrolla los niveles de auditoría con dos precisiones que completan lo anterior `[ENS, anexo III, ap. 2]`:

- **Categoría BÁSICA**: «no necesitarán realizar una auditoría. Bastará una **autoevaluación realizada por el mismo personal que administra el sistema** de información o en quien éste delegue». El resultado debe estar **documentado**, indicando si cada medida está **implantada y sujeta a revisión regular**, y con las **evidencias** que sustentan la valoración. Los informes de autoevaluación los analiza el **responsable de la seguridad**, que eleva conclusiones al **responsable del sistema**.
- **Categorías MEDIA o ALTA**: el informe dictamina sobre el grado de cumplimiento «identificando los **hallazgos de conformidad y no conformidad**», con criterios metodológicos, alcance, objetivo y base fáctica.

DATO CLAVE

La **autoevaluación de BÁSICA la puede hacer el propio personal que administra el sistema** —el anexo III lo dice expresamente—, mientras que la **certificación de MEDIA y ALTA exige auditoría por entidad certificadora**, cuyos requisitos concreta la Instrucción Técnica de Seguridad de Conformidad. Y una precisión terminológica: BÁSICA produce una **Declaración de Conformidad**; MEDIA y ALTA producen una **Certificación de Conformidad**.

Ambas se materializan en un **distintivo**, y el glosario los define por separado con una diferencia decisiva: **quién lo firma** `[ENS, anexo IV]`.

Distintivo	Formato	Quién lo firma	Dónde permanece accesible
Distintivo de Declaración de Conformidad (BÁSICA)	Documento electrónico en **PDF-A**	«La **propia entidad** bajo cuya responsabilidad se encuentre el sistema», que lo **firma o sella** electrónicamente	Sede electrónica o página web de la entidad, mientras se mantenga su vigencia
Distintivo de Certificación de Conformidad (MEDIA y ALTA)	Documento electrónico en **PDF-A**	La **Entidad de Certificación** responsable de la evaluación	Sede electrónica o página web de la entidad, mientras se mantenga su vigencia

DATO CLAVE

Los dos distintivos son **documentos electrónicos en formato PDF-A** que incluyen un **enlace** a la declaración o certificación correspondiente. La diferencia está en la firma: la **Declaración la firma o sella la propia entidad**; la **Certificación la firma la Entidad de Certificación**. Es la traducción documental de la diferencia entre autoevaluarse y ser auditado por un tercero.

El objeto de la auditoría (anexo III, apartado 1.1). La auditoría constata **seis extremos**, y los tres primeros son puro principio de diferenciación de responsabilidades `[ENS, anexo III, ap. 1.1]`:

`a)` que la política de seguridad **define los roles y funciones** de los responsables del sistema, la información, los servicios y la seguridad; `b)` que existen **procedimientos para resolución de conflictos** entre dichos responsables; `c)` que se han **designado personas** para dichos roles «a la luz del **principio de diferenciación de responsabilidades**»; `d)` que se ha realizado un **análisis de riesgos, con revisión y aprobación anual**; `e)` que se cumplen las medidas del **anexo II** según las condiciones de aplicación; y `f)` que existe un **sistema de gestión de la seguridad de la información**, documentado y con un **proceso regular de aprobación por la dirección**, tomando como base la **Declaración de Aplicabilidad** del artículo 28.

Además, la auditoría «se basará en la existencia de **evidencias**» de cuatro tipos: **documentación de los procedimientos**, **registro de incidentes**, **examen del personal afectado** —conocimiento y praxis de las medidas que le afectan— y **productos certificados**, considerándose evidencia suficiente el empleo de productos que satisfagan el artículo 19 `[ENS, anexo III, ap. 1.2]`. Y debe existir «un **programa o plan de auditorías documentado**», con las comprobaciones sobre sistemas operativos **planificadas y acordadas previamente** `[ENS, anexo III, ap. 1.3]`.

DATO CLAVE

Que el **examen del personal** figure entre las cuatro clases de evidencia de auditoría es un dato poco conocido: el auditor del ENS **puede y debe preguntar a los empleados** si conocen y practican las medidas que les afectan. Es la comprobación empírica del artículo 6.2, que declaraba la ignorancia como fuente de riesgo.

El informe del estado de la seguridad (artículo 32). La **Comisión Sectorial de Administración Electrónica** recoge la información sobre las principales variables de la seguridad para elaborar un **perfil general del estado de la seguridad**, y el **CCN** articula los procedimientos de recogida y consolidación y los aspectos metodológicos, «a través de los correspondientes **grupos de trabajo**». Los resultados los usan las autoridades competentes para impulsar la mejora continua, «utilizando en su caso **cuadros de mando e indicadores**» con las herramientas que el CCN provea `[ENS, art. 32]`. La herramienta con la que esto se materializa es **INES** `[CCNSTIC]`.

EJEMPLO DE APLICACIÓN EN EL AYTO

El Ayuntamiento de Madrid, como entidad del sector público, reporta anualmente a través de **INES** el grado de implantación de las medidas de sus sistemas, y publica en su **sede electrónica** las declaraciones y certificaciones de conformidad obtenidas, conforme al artículo 38.2. Dado el volumen y la heterogeneidad de sus sistemas —Padrón, tributos, licencias, sede, movilidad, emergencias— la organización habitual no es un único sistema categorizado en bloque, sino **varios sistemas categorizados por separado**, con la posibilidad de **segregar subsistemas** cuando un módulo requiere un nivel distinto (anexo II, ap. 2.2). Esa arquitectura de conformidad es, en la práctica, la decisión de diseño más importante que toma el responsable de seguridad de una organización grande.

El diagrama D14 representa los dos caminos de la conformidad y el circuito completo del informe de auditoría.

---

3. El Esquema Nacional de Interoperabilidad

3.1. Marco conceptual y ámbito de aplicación

3.1.1. Objeto y normativa vigente del Esquema Nacional de Interoperabilidad

Qué es la interoperabilidad. El preámbulo del propio real decreto ofrece la definición canónica, y es la que hay que reproducir en un examen: la interoperabilidad es «la **capacidad de los sistemas de información y de los procedimientos a los que éstos dan soporte, de compartir datos y posibilitar el intercambio de información y conocimiento entre ellos**» `[ENI, preámbulo]`.

Conviene fijarse en que la definición no habla solo de sistemas: habla también de **los procedimientos a los que esos sistemas dan soporte**. Esa es la razón de que la interoperabilidad tenga una dimensión **organizativa** y no solo técnica.

La norma. El ENI vigente es el **Real Decreto 4/2010, de 8 de enero**, publicado en el **BOE núm. 25, de 29 de enero de 2010** `[ENI]`. Su estructura es la siguiente:

Parte	Contenido
Capítulo I (arts. 1-3)	Disposiciones generales: objeto, definiciones y ámbito
Capítulo II (arts. 4-7)	**Principios básicos**
Capítulo III (arts. 8-9)	Interoperabilidad **organizativa**
Capítulo IV (art. 10)	Interoperabilidad **semántica**
Capítulo V (art. 11)	Interoperabilidad **técnica**
Capítulo VI (art. 12)	Infraestructuras y servicios comunes
Capítulo VII (arts. 13-15)	Comunicaciones de las Administraciones públicas
Capítulo VIII (arts. 16-17)	Reutilización y transferencia de tecnología
Capítulo IX (arts. 18-20)	Firma electrónica y certificados
Capítulo X (arts. 21-24)	Recuperación y **conservación** del documento electrónico
Capítulo XI (arts. 25-28)	Normas de conformidad
Capítulo XII (art. 29)	Actualización permanente
Disp. adic. 1.ª	**Normas técnicas de interoperabilidad** e instrumentos
Anexo	Glosario de términos

Son **29 artículos en 12 capítulos**, 5 disposiciones adicionales, 2 transitorias, 1 derogatoria, 3 finales y 1 anexo.

DATO CLAVE

El paralelismo estructural con el ENS es deliberado y ayuda a memorizar los dos a la vez: ambos tienen su **capítulo II dedicado a los principios básicos**, ambos tienen un **capítulo de normas de conformidad** y ambos terminan con un capítulo de **actualización permanente** (art. 39 del ENS, art. 29 del ENI). Lo que el ENI **no tiene** es capítulo de categorización ni anexo de medidas: **el ENI no categoriza ni mide**. Esa es su diferencia estructural de fondo con el ENS.

El objeto. El artículo 1.2 define el contenido del ENI: «comprenderá los **criterios y recomendaciones de seguridad, normalización y conservación** de la información, de los formatos y de las aplicaciones que deberán ser tenidos en cuenta por las Administraciones públicas para asegurar un adecuado nivel de interoperabilidad **organizativa, semántica y técnica** de los datos, informaciones y servicios que gestionen en el ejercicio de sus competencias y para **evitar la discriminación a los ciudadanos por razón de su elección tecnológica**» `[ENI, art. 1.2]`.

Esa última frase —evitar la discriminación por razón de la elección tecnológica— es la **finalidad última** del ENI y aparece repetida en el artículo 11.1 al justificar el uso de estándares abiertos. Es lo que explica que el ENI sea, en el fondo, una norma de **garantía de derechos**: si la Administración solo admitiera un formato propietario, estaría obligando a la ciudadanía a comprar un producto concreto para poder ejercer un derecho.

DATO CLAVE

Compárense los dos objetos. El **artículo 1.2 del ENI** habla de «criterios y recomendaciones de **seguridad, normalización y conservación**», mientras que el **artículo 156.1 de la Ley 40/2015** lo enuncia como «criterios y recomendaciones en materia de **seguridad, conservación y normalización**». El contenido es el mismo, el orden difiere. Ambos coinciden en algo que sorprende: **el ENI menciona la seguridad en su propia definición de objeto**.

El detalle normativo que distingue un temario bueno. El artículo 1.1 del ENI dice, todavía hoy: «El presente real decreto tiene por objeto regular el Esquema Nacional de Interoperabilidad **establecido en el artículo 42 de la Ley 11/2007, de 22 de junio**» `[ENI, art. 1.1]`. Y el artículo 3.1 remite el ámbito de aplicación «al establecido en el **artículo 2 de la Ley 11/2007**» `[ENI, art. 3.1]`. **La Ley 11/2007 fue derogada en 2015.** El ENI **no ha actualizado esas remisiones**, cosa que el ENS sí hizo al rehacerse en 2022 (su artículo 1.1 remite al vigente artículo 156.2 de la Ley 40/2015).

DATO CLAVE

El **ENI sigue remitiéndose a la derogada Ley 11/2007** en sus artículos 1.1 y 3.1. No es un error de este material: es lo que dice el texto consolidado del BOE. La interpretación correcta es que esas remisiones han de entenderse hechas a los preceptos equivalentes de las leyes 39/2015 y 40/2015 —**artículo 156.1** para el objeto y **artículo 2 de la Ley 40/2015** para el ámbito subjetivo—. Ese desfase es el mejor síntoma de la asimetría entre los dos esquemas que se anunció en las «Convenciones»: uno se ha rehecho, el otro se ha remendado.

Ese desfase se aprecia también en el **léxico** del articulado, que arrastra denominaciones institucionales de tres épocas distintas: el artículo 8.1 menciona todavía el «**Comité** Sectorial de Administración electrónica» —hoy **Comisión** Sectorial, por la disposición adicional novena de la Ley 40/2015— y la derogada **Ley Orgánica 15/1999** de protección de datos; el artículo 9 cita ministerios que han cambiado de nombre; y la disposición adicional primera, reformada en 2024, ya nombra correctamente al **Ministerio para la Transformación Digital y de la Función Pública** `[ENI, art. 8.1]` `[RD1125]`.

La regla de prevalencia. El artículo 3.2 contiene una cláusula de fuerza: «el Esquema Nacional de Interoperabilidad y sus normas de desarrollo **prevalecerán sobre cualquier otro criterio** en materia de política de interoperabilidad en la utilización de medios electrónicos para el acceso de los ciudadanos a los servicios públicos» `[ENI, art. 3.2]`.

DATO CLAVE

El artículo 3.2 es el precepto que impide que una Administración adopte «su propio criterio» de interoperabilidad. **El ENI y sus normas técnicas prevalecen sobre cualquier otro criterio.** Nótese la diferencia de técnica normativa con el ENS: el ENS asegura su cumplimiento por la vía de la **conformidad auditable**; el ENI, por la vía de la **prevalencia normativa** y de la **validez de los actos** (arts. 27 y 70 de la Ley 39/2015).

El diagrama D15 presenta la estructura del RD 4/2010 junto con sus tres principios específicos.

3.2. Principios específicos del Esquema Nacional de Interoperabilidad

El **artículo 4** enuncia los principios con una fórmula de dos pisos que hay que reproducir con cuidado: «la aplicación del Esquema Nacional de Interoperabilidad se desarrollará de acuerdo con **los principios generales establecidos en el artículo 4 de la Ley 11/2007** y con **los siguientes principios específicos de la interoperabilidad**» `[ENI, art. 4]`:

`a)` **La interoperabilidad como cualidad integral.** `b)` **Carácter multidimensional de la interoperabilidad.** `c)` **Enfoque de soluciones multilaterales.**

DATO CLAVE

Son **tres principios específicos**, en el **artículo 4**, desarrollados en **tres artículos**: el **5** (cualidad integral), el **6** (carácter multidimensional) y el **7** (enfoque de soluciones multilaterales). Aquí sí hay correspondencia de uno a uno, a diferencia del ENS. Y hay que reparar en el adjetivo: el ENI habla de principios **específicos** de la interoperabilidad —porque los generales los pone la ley—, mientras que el ENS habla de principios **básicos**. Un enunciado que pregunte por «los principios básicos del ENI» está usando el término del ENS; la rúbrica del capítulo II del ENI sí es «Principios básicos», pero el artículo 4 los llama **específicos**. Y son **tres frente a siete**: una asimetría numérica que conviene retener.

3.2.1. La interoperabilidad como cualidad integral y el criterio multidisciplinar

Principio `a)` : la interoperabilidad como cualidad integral (artículo 5). El texto es breve y hay que memorizar su enumeración: «La interoperabilidad se tendrá presente **de forma integral desde la concepción** de los servicios y sistemas y **a lo largo de su ciclo de vida**: **planificación, diseño, adquisición, construcción, despliegue, explotación, publicación, conservación y acceso o interconexión** con los mismos» `[ENI, art. 5]`.

DATO CLAVE

Nueve momentos del ciclo de vida en el artículo 5 del ENI: planificación, diseño, adquisición, construcción, despliegue, explotación, **publicación**, **conservación** y **acceso o interconexión**. Los tres últimos son los que distinguen esta lista de cualquier ciclo de vida informático genérico, y no es casual: **publicación**, **conservación** y **acceso** son los tres momentos en los que la interoperabilidad se pone a prueba de verdad. Compárese con el ciclo de vida del **artículo 16.1 del ENS**, que enumera **nueve fases distintas**: planificación, diseño, adquisición, construcción, despliegue, explotación, **mantenimiento**, **gestión de incidencias** y **desmantelamiento**. Las seis primeras coinciden; **las tres últimas no**, y ahí está la diferencia.

La idea de fondo es idéntica a la del principio de seguridad integral del ENS, y por eso las dos se estudian juntas: **ni la seguridad ni la interoperabilidad se pueden añadir al final**. Un sistema que se construye sin pensar en el intercambio acaba exportando ficheros hechos a medida para cada destinatario; un sistema que se construye sin pensar en la conservación acaba con documentos que dentro de quince años no se podrán abrir.

Principio `b)` : el carácter multidimensional (artículo 6). El precepto merece transcribirse casi entero porque contiene, además del principio, la lista de los **cinco planos donde la interoperabilidad se manifiesta** y el enunciado de la **dimensión temporal** `[ENI, art. 6]`:

> «La interoperabilidad se entenderá contemplando sus **dimensiones organizativa, semántica y técnica**. La **cadena de interoperabilidad** se manifiesta en la práctica en los **acuerdos**

> **interadministrativos**, en el **despliegue de los sistemas y servicios**, en la **determinación y uso de estándares**, en las **infraestructuras y servicios básicos** de las Administraciones públicas y en la **publicación y reutilización de las aplicaciones** de las Administraciones públicas, de la documentación asociada y de otros objetos de información. Todo ello **sin olvidar la dimensión temporal que ha de garantizar el acceso a la información a lo largo del tiempo**.»

DATO CLAVE

El artículo 6 contiene **tres listas** distintas. Primera: las **tres dimensiones** —organizativa, semántica y técnica—. Segunda: los **cinco eslabones de la cadena de interoperabilidad** —acuerdos interadministrativos, despliegue de sistemas y servicios, determinación y uso de estándares, infraestructuras y servicios básicos, y publicación y reutilización de aplicaciones—. Y tercera, la más olvidada: la **dimensión temporal**, que el precepto añade al final «sin olvidar». **La dimensión temporal no es una cuarta dimensión numerada: es un añadido transversal.** Quien conteste «el ENI tiene cuatro dimensiones» se equivoca; quien conteste «tres, más la temporal», acierta.

El principio `c)` : el enfoque de soluciones multilaterales (artículo 7). «Se favorecerá la aproximación multilateral a la interoperabilidad de forma que se puedan obtener las ventajas derivadas **del escalado**, de la aplicación de las **arquitecturas modulares y multiplataforma**, de **compartir**, de **reutilizar** y de **colaborar**» `[ENI, art. 7]`.

DATO CLAVE

El artículo 7 enumera **cinco ventajas** de la aproximación multilateral: **escalado**, **arquitecturas modulares y multiplataforma**, **compartir**, **reutilizar** y **colaborar**. La oposición conceptual que hay detrás es **multilateral frente a bilateral**: si cada par de Administraciones resuelve su intercambio con un convenio y un formato propios, con `n` Administraciones hacen falta del orden de n^2 acuerdos; con una solución multilateral basta uno. Es exactamente el problema que resuelven la **plataforma de intermediación de datos** y los **nodos de interoperabilidad** del artículo 8.3.

Los **nodos de interoperabilidad**, definidos en el artículo 8.3 como «entidades a las cuales se les encomienda la **gestión de apartados globales o parciales** de la interoperabilidad organizativa, semántica o técnica», son la materialización institucional del principio `c)` `[ENI, art. 8.3]`. Y el artículo 8.1 refuerza la misma idea al potenciar «el establecimiento de **convenios** entre las Administraciones públicas emisoras y receptoras y, en particular, con los nodos de interoperabilidad (…), con el objetivo de **simplificar la complejidad organizativa sin menoscabo de las garantías jurídicas**» `[ENI, art. 8.1]`.

El diagrama D16 compara las tres dimensiones del ENI con las cuatro capas del marco europeo.

3.2.2. Reutilización, transferencia tecnológica y estándares abiertos

Este epígrafe recoge los tres mecanismos con los que el ENI hace operativos sus principios: **reutilizar** lo que ya existe, **transferir** la tecnología entre Administraciones y **usar estándares abiertos** para que nada de lo anterior quede cautivo de un proveedor.

Los estándares abiertos (artículo 11). El apartado 1 impone la regla general: las Administraciones «usarán **estándares abiertos**, así como, en su caso y de forma **complementaria**, estándares que sean de **uso generalizado por los ciudadanos**», con dos consecuencias: `a)` los documentos y servicios puestos a disposición de la ciudadanía o de otras Administraciones estarán «**como mínimo, disponibles mediante estándares abiertos**»; y `b)` serán «**visualizables, accesibles y funcionalmente operables**» en condiciones que satisfagan el **principio de neutralidad tecnológica** `[ENI, art. 11.1]`.

El apartado 2 regula la excepción con una redacción muy estricta: el uso **en exclusiva** de un estándar **no abierto**, sin ofrecer alternativa basada en estándar abierto, «se limitará a aquellas circunstancias en las que **no se disponga de un estándar abierto que satisfaga la funcionalidad**» requerida «y **sólo mientras dicha disponibilidad no se produzca**». Y añade un deber activo: las Administraciones «promoverán las **actividades de normalización**» para facilitar la disponibilidad de los estándares abiertos que necesiten `[ENI, art. 11.2]`.

> **DATO CLAVE**
>
> La excepción del artículo 11.2 tiene **dos condiciones acumulativas**: que **no exista** estándar abierto que dé la funcionalidad, y que la excepción dure **solo mientras** esa indisponibilidad se mantenga. Es decir, la excepción es **subsidiaria y temporal**, nunca definitiva. Y el apartado 5 cierra con el derecho correlativo: «en cualquier caso **los ciudadanos podrán elegir las aplicaciones o sistemas** para relacionarse con las Administraciones públicas (…) siempre y cuando utilicen **estándares abiertos** o, en su caso, aquellos otros que sean de **uso generalizado**».

El apartado 3 fija **cinco criterios** para seleccionar estándares y establecer el catálogo `[ENI, art. 11.3]`:

Criterio	Contenido
`a)`	Uso de las **especificaciones técnicas de las TIC en la contratación pública**, con las definiciones de norma y especificación técnica del **Reglamento (UE) 1025/2012** sobre normalización europea
`b)`	La **definición de estándar abierto** de la Ley 11/2007, anexo, letra `k)`
`c)`	**Carácter de especificación formalizada**
`d)`	La definición de «**coste que no suponga una dificultad de acceso**» del anexo del propio real decreto
`e)`	Consideraciones adicionales: **adecuación** a la funcionalidad; condiciones de **desarrollo, uso e implementación**, documentación, publicación y **gobernanza** del estándar; **madurez, apoyo y adopción** por el mercado; **potencial de reutilización**; **aplicabilidad multiplataforma y multicanal**; e implementación bajo **diversos modelos de desarrollo**

La reutilización y el licenciamiento (artículo 16). El apartado 1 enumera **seis aspectos** que han de tener en cuenta las condiciones de licenciamiento de las aplicaciones cuya propiedad intelectual sea de una Administración: `a)` el fin perseguido es el **aprovechamiento y la reutilización de recursos públicos**; `b)` la **protección completa contra la apropiación exclusiva o parcial** por terceros; `c)` la **exención de responsabilidad del cedente** por el mal uso del cesionario; `d)` la **no obligación de asistencia técnica o mantenimiento** por el cedente; `e)` la **ausencia total de responsabilidad** del cedente ante errores o mal funcionamiento; y `f)` que «el licenciamiento se realizará **por defecto sin contraprestación y sin necesidad de establecer convenio alguno**», con una excepción tasada de repercusión parcial de costes `[ENI, art. 16.1]`.

El apartado 2 fija las **cuatro libertades** que debe garantizar la licencia de una aplicación declarada **de fuentes abiertas** `[ENI, art. 16.2]`:

`a)` **Pueden ejecutarse para cualquier propósito.** `b)` **Permiten conocer su código fuente.** `c)` **Pueden modificarse o mejorarse.** `d)` **Pueden redistribuirse a otros usuarios con o sin cambios**, siempre que la obra derivada **mantenga estas cuatro garantías**.

Y el apartado 3 añade la preferencia de licencia: «se procurará la aplicación de la **Licencia Pública de la Unión Europea**», sin perjuicio de otras que garanticen los mismos derechos `[ENI, art. 16.3]`.

DATO CLAVE

Cuatro datos del artículo 16: el licenciamiento entre Administraciones es **por defecto gratuito y sin convenio** (ap. 1.f); las libertades del software de fuentes abiertas son **cuatro** y la cuarta incluye la **cláusula de herencia** —la obra derivada mantiene las cuatro garantías— (ap. 2); la licencia preferente es la **EUPL**, *European Union Public Licence* (ap. 3); y el apartado 4 obliga a incluir en los **pliegos de cláusulas técnicas** que la Administración contratante **adquiera los derechos completos de propiedad intelectual** de las aplicaciones desarrolladas.

Los directorios de aplicaciones (artículo 17). La Administración General del Estado mantiene el **Directorio general de aplicaciones para su libre reutilización**, «de acuerdo al **artículo 158 de la Ley 40/2015**, a través del **Centro de Transferencia de Tecnología**». Quien disponga de directorio propio debe garantizar que sus aplicaciones se puedan consultar **también** a través del CTT, y los directorios han de conectarse entre sí «y con instrumentos equivalentes del ámbito de la Unión Europea» `[ENI, art. 17.1 y 17.2]`. La publicación debe incluir, al menos: **código fuente** de las aplicaciones finalizadas —si son reutilizables en modo producto y se han declarado de fuentes abiertas—, **documentación asociada**, **condiciones de licenciamiento** o **nivel de servicio** según el modo, y **costes asociados** a la reutilización, si existieran `[ENI, art. 17.3]`.

DATO CLAVE

La reutilización no es una recomendación: el **artículo 157.3 de la Ley 40/2015** obliga a **consultar el directorio general antes de adquirir, desarrollar o mantener** una aplicación, y «en el caso de existir una solución disponible para su reutilización total o parcial, las Administraciones Públicas **estarán obligadas a su uso**», salvo que la decisión de no reutilizar «se justifique en términos de **eficiencia**» conforme al artículo 7 de la Ley Orgánica 2/2012 de Estabilidad Presupuestaria `[L40, art. 157.3]`. Es una **obligación de consulta previa** con inversión de la carga de la justificación.

Obsérvese la distinción, introducida por la reforma de 2021, entre reutilización **en modo producto** —se cede el código y el cesionario lo despliega— y **en modo servicio** —el cedente sigue operando la aplicación y el cesionario la consume—. En el primer caso lo que se publica son licencias; en el segundo, **niveles de servicio** `[ENI, art. 17.3.c)]` `[RD203]`.

EJEMPLO DE APLICACIÓN EN EL AYTO

Antes de licitar una nueva aplicación de gestión de subvenciones, el Ayuntamiento está obligado por el artículo 157.3 de la Ley 40/2015 a consultar el **Centro de Transferencia de Tecnología**. Si allí existe una solución reutilizable que cubra total o parcialmente la necesidad, la reutilización es **obligatoria**, y apartarse de ella exige una **justificación motivada en términos de eficiencia** que debe constar en el expediente de contratación. En sentido inverso, cuando el Ayuntamiento desarrolla una aplicación con derechos propios y decide publicarla, el artículo 16 le impone licenciarla **sin contraprestación y sin convenio**, y si la declara de fuentes abiertas, con una licencia que garantice las cuatro libertades, preferentemente la **EUPL**.

3.3. Dimensiones de la interoperabilidad

Las tres dimensiones del artículo 6 son el eje de los capítulos III, IV y V del ENI. Conviene entenderlas como **tres condiciones que se acumulan**: sin las tres, el intercambio no funciona. Un intercambio técnicamente perfecto entre dos sistemas que no tienen acuerdo para intercambiar es ilegal; un intercambio acordado y técnicamente resuelto en el que cada parte entiende una cosa distinta por «domicilio» es inútil.

3.3.1. Interoperabilidad organizativa e interoperabilidad semántica

Interoperabilidad organizativa (capítulo III, arts. 8 y 9). Responde a la pregunta **quién intercambia con quién, para qué y con qué garantías**. El artículo 8.1 obliga a las Administraciones a «**establecer y publicar las condiciones de acceso y utilización** de los servicios, datos y documentos en formato electrónico que pongan a disposición del resto», especificando `[ENI, art. 8.1]`:

- Las **finalidades**.
- Las **modalidades de consumo, consulta o interacción**.
- Los **requisitos** que deben satisfacer los posibles usuarios.
- Los **perfiles** de los participantes implicados.
- Los **protocolos y criterios funcionales o técnicos** necesarios para acceder.
- Los **mecanismos de gobierno** de los sistemas interoperables.
- Las **condiciones de seguridad** aplicables.

Y añade que esas condiciones «deberán en todo caso resultar **conformes** a los principios, derechos y obligaciones» de la normativa de protección de datos «así como a lo dispuesto en el **Esquema Nacional de Seguridad**» `[ENI, art. 8.1]`.

DATO CLAVE

El **artículo 8.1 del ENI remite expresamente al ENS** al fijar las condiciones de publicación de un servicio interoperable. Es el primero de los puentes normativos entre los dos esquemas y conviene tenerlo localizado, porque el segundo —el artículo 22— y el tercero —el artículo 35.2 del ENS— se ven en §4.2.1.

El artículo 8.2 exige publicar esos servicios «a través de la **Red de comunicaciones de las Administraciones públicas españolas**, o de cualquier otra red equivalente o conectada a la misma que garantice el acceso seguro», y el 8.3 introduce los ya citados **nodos de interoperabilidad** `[ENI, art. 8]`.

El **artículo 9** impone a cada Administración mantener actualizado el conjunto de sus **inventarios de información administrativa**, que incluirá **al menos dos** `[ENI, art. 9.1]`:

Inventario	Contenido	Se conecta con
`a)` **De procedimientos y servicios**	La relación de los **procedimientos administrativos y servicios prestados**, de forma clasificada y estructurada	El **Sistema de Información Administrativa (SIA)**
`b)` **De órganos y oficinas**	La relación de sus **órganos administrativos y oficinas orientadas al público** y sus relaciones entre ellos	El **Directorio Común de Unidades Orgánicas y Oficinas (DIR3)**, que «proveerá una **codificación unívoca**»

DATO CLAVE

Son **dos inventarios como mínimo**: procedimientos y servicios (conectado al **SIA**) y órganos y oficinas (conectado al **DIR3**). La palabra clave del DIR3 es **codificación unívoca**: es lo que permite que un asiento registral dirigido a un órgano llegue a ese órgano y no a otro con nombre parecido. Sin DIR3 no hay registro electrónico común, y sin registro común no hay ventanilla única.

Interoperabilidad semántica (capítulo IV, art. 10). Responde a la pregunta **qué significa lo que se intercambia**. Su instrumento son los **modelos de datos de intercambio**, y el artículo 10 los organiza en dos niveles `[ENI, art. 10]`:

1. Una **Relación de modelos de datos de intercambio que tengan el carácter de comunes**, «de **preferente aplicación**» para los intercambios entre Administraciones, establecida por el procedimiento de la disposición adicional primera (ap. 1).

2. Los modelos **sectoriales** que establecen y publican los órganos titulares de competencias en materias sujetas a intercambio, que son de «**obligatoria aplicación**» (ap. 2).

Ambos se ajustan a lo previsto sobre estándares en el artículo 11 y se publican, junto con sus **definiciones y codificaciones**, a través del **Centro de Interoperabilidad Semántica de la Administración (CISE)**, con las condiciones de licenciamiento del artículo 16 (ap. 3). Y el apartado 4 añade una remisión que sorprende: las definiciones y codificaciones «tendrán en cuenta lo dispuesto en la **Ley 12/1989, de 9 de mayo, de la Función Estadística Pública**» `[ENI, art. 10.4]`.

> DATO CLAVE
>
> Diferencia de intensidad entre los dos apartados del artículo 10: los modelos **comunes** son de «**preferente** aplicación»; los **sectoriales**, de «**obligatoria** aplicación». Es contraintuitivo. Y el instrumento donde viven es el **CISE**, no el CTT: el **CTT** es de **aplicaciones**, el **CISE** es de **modelos de datos**, el **SIA** es de **procedimientos** y el **DIR3** es de **órganos**. Confundir los cuatro instrumentos de la disposición adicional primera es uno de los fallos más habituales.

Por qué la semántica es la dimensión difícil. La interoperabilidad técnica se resuelve con protocolos; la organizativa, con convenios; la semántica exige **acuerdo sobre el significado**, que es lo único que no se puede automatizar. Dos Administraciones pueden intercambiar sin problema técnico un campo «fecha de baja» y equivocarse por completo si para una significa la fecha en que se solicitó la baja y para otra la fecha en que surtió efecto.

> EJEMPLO DE APLICACIÓN EN EL AYTO
>
> Cuando la sede electrónica municipal consulta, con consentimiento o habilitación legal, si una persona solicitante de una ayuda está al corriente de sus obligaciones tributarias, la consulta viaja por la **plataforma de intermediación de datos** sobre la **Red SARA**. Las tres dimensiones actúan a la vez: la **organizativa**, porque el Ayuntamiento ha tenido que adherirse al servicio, aceptar sus condiciones de uso y acreditar la base jurídica de la consulta; la **semántica**, porque el certificado devuelto se ajusta a un **modelo de datos común** publicado en el CISE, de modo que «estar al corriente» significa lo mismo para el emisor y para el receptor; y la **técnica**, porque el mensaje se transporta con los **protocolos de intermediación** de la norma técnica correspondiente. Y hay un efecto jurídico añadido: gracias a esa consulta, el Ayuntamiento **no puede exigir a la persona interesada** que aporte el certificado, por aplicación del artículo 28 de la Ley 39/2015.

3.3.2. Interoperabilidad técnica y la dimensión temporal de la conservación

Interoperabilidad técnica (capítulo V, art. 11, y capítulos VI y VII). Responde a la pregunta **cómo viaja**. Sus piezas son los **estándares abiertos** ya vistos, las **infraestructuras y servicios comunes**

y las **comunicaciones**.

El **artículo 12** obliga a las Administraciones a «**enlazar** aquellas infraestructuras y servicios que puedan implantar en su ámbito de actuación con las **infraestructuras y servicios comunes que proporcione la Administración General del Estado**» `[ENI, art. 12]`. El **artículo 13** dispone que las Administraciones utilizarán **preferentemente** la Red de comunicaciones de las Administraciones públicas españolas para comunicarse entre sí, conectando a ella «bien sus respectivas redes, bien sus **nodos de interoperabilidad**», y facilitando también «la interconexión con las redes de las **Instituciones de la Unión Europea y de otros Estados miembros**». Y añade la identificación clave: «**La Red SARA prestará la citada Red** de comunicaciones de las Administraciones públicas españolas» `[ENI, art. 13.1]`.

El **artículo 14** manda aplicar el **Plan de direccionamiento e interconexión de redes en la Administración**, y el **artículo 15** regula la **hora oficial**: los sistemas implicados en la provisión de un servicio público por vía electrónica «se **sincronizarán con la hora oficial**, con una **precisión y desfase que garanticen la certidumbre de los plazos**», y esa sincronización «se realizará con el **Real Instituto y Observatorio de la Armada**» conforme al Real Decreto 1308/1992 y, «cuando sea posible, con la **hora oficial a nivel europeo**» `[ENI, art. 15]`.

> DATO CLAVE
>
> El **artículo 15 del ENI** encierra un dato contraintuitivo: la fuente de la hora legal española es el **Real Instituto y Observatorio de la Armada (ROA)**, en San Fernando (Cádiz), laboratorio depositario del **patrón nacional de Tiempo**. Y la razón por la que esto está en una norma de interoperabilidad y no en una de metrología la da el propio precepto: **la certidumbre de los plazos administrativos**. Un registro electrónico desfasado unos minutos puede convertir una solicitud presentada en plazo en una presentada fuera de plazo.

> RELACIÓN CON OTROS TEMAS
>
> El **Plan de direccionamiento** y los **requisitos de conexión a la red SARA** —área de conexión con zona desmilitarizada, servicios básicos y cifrado por túnel— se desarrollan en el **Tema 34**, al hilo de la pila TCP/IP. La **arquitectura de la red corporativa** y su segmentación, en los **Temas 30 y 37**.

La dimensión temporal: recuperación y conservación (capítulo X, arts. 21 a 24). Es la parte del ENI que más se olvida y la que más peso tiene en un caso práctico. El **artículo 21.1** obliga a adoptar las medidas organizativas y técnicas necesarias para garantizar la interoperabilidad en la recuperación y conservación de los documentos electrónicos **a lo largo de su ciclo de vida**, y enumera **trece medidas**, de la letra `a)` a la `m)` `[ENI, art. 21.1]`:

Letra	Medida
`a)`	Definición de una **política de gestión de documentos**
`b)`	Inclusión en los expedientes de un **índice electrónico firmado** por el órgano o entidad actuante, que garantice la **integridad del expediente** y permita su recuperación
`c)`	**Identificación única e inequívoca** de cada documento mediante convenciones adecuadas
`d)`	Asociación de los **metadatos mínimos obligatorios** y, en su caso, complementarios, a lo largo del ciclo de vida, e incorporación al **esquema de metadatos**
`e)`	**Clasificación** conforme a un plan de clasificación adaptado a las funciones
`f)`	**Período de conservación**, establecido por las **comisiones calificadoras** que correspondan
`g)`	**Acceso completo e inmediato** mediante consulta en línea, con visualización, recuperación, descarga en formatos originales e impresión, y consulta durante todo el período de conservación **de la firma electrónica, del sello de tiempo y de los metadatos**
`h)`	Medidas para **asegurar la conservación** a lo largo del ciclo de vida, conforme al artículo 22, garantizando el **valor probatorio** y la **fiabilidad como evidencia electrónica**
`i)`	**Coordinación horizontal** entre el responsable de gestión de documentos y los servicios de archivos
`j)`	**Transferencia** de los expedientes entre repositorios electrónicos a efectos de conservación
`k)`	**Borrado o destrucción** si el procedimiento de evaluación documental así lo establece, **dejando registro de su eliminación**
`l)`	**Formación tecnológica** del personal responsable de la gestión y conservación
`m)`	**Documentación de los procedimientos** que garanticen la interoperabilidad a medio y largo plazo

El apartado 2 añade la obligación de crear **repositorios electrónicos**, «complementarios y equivalentes en cuanto a su función a los **archivos convencionales**», destinados a cubrir el conjunto del ciclo de vida `[ENI, art. 21.2]`.

DATO CLAVE

Tres letras del artículo 21.1 son clave. La `b)`, el **índice electrónico firmado** que «garantice la integridad del expediente y permita su recuperación», que es la misma exigencia que impone el artículo 70.3 de la Ley 39/2015. La `f)`, que atribuye la fijación de los **períodos de conservación** a las **comisiones calificadoras** —no al informático, no al responsable del sistema: a un órgano archivístico—. Y la `k)`, que permite la **eliminación** cuando lo determine la evaluación documental, pero obliga a **dejar registro de ella**: en la Administración, destruir sin dejar rastro de la destrucción no es conservar bien, es perder información dos veces.

Formatos (artículo 23). «Con el fin de garantizar la conservación, el documento **se conservará en el formato en que haya sido elaborado, enviado o recibido**, y **preferentemente en un formato correspondiente a un estándar abierto** que preserve a lo largo del tiempo la integridad del contenido del documento, de la firma electrónica y de los metadatos que lo acompañan» `[ENI, art. 23.1]`. Y cuando exista **riesgo de obsolescencia** del formato, o este deje de figurar entre los admitidos, «se aplicarán procedimientos normalizados de **copiado auténtico** de los documentos con **cambio de formato**, de **etiquetado con información del formato utilizado** y, en su caso, de las **migraciones o conversiones**» `[ENI, art. 23.3]`.

DATO CLAVE

La regla del artículo 23.1 tiene dos escalones y el orden importa: **primero**, el documento se conserva **en el formato en que fue elaborado, enviado o recibido**; **preferentemente**, ese formato será un **estándar abierto**. No dice que haya que convertirlo todo a un formato canónico: dice que se conserve tal como es, y que se procure que ese «tal como es» sea abierto. La conversión solo entra en juego por **riesgo de obsolescencia** (ap. 3), y entonces se hace mediante **copiado auténtico con cambio de formato**, que es una figura jurídica, no una simple exportación.

Digitalización (artículo 24). La digitalización de documentos en papel se realizará conforme a la norma técnica correspondiente en cuanto a **formatos estándares y técnica de compresión**, **nivel de resolución**, **garantía de imagen fiel e íntegra** y **metadatos mínimos obligatorios y complementarios** asociados al proceso `[ENI, art. 24.1]`. Y el apartado 2 recuerda que la gestión del documento digitalizado «atenderá a la **posible existencia del mismo en otro soporte**».

RELACIÓN CON OTROS TEMAS

Los **equipos y parámetros de digitalización** —escáneres, resoluciones, profundidad de color y compresión— corresponden al **Tema 12**. Los **formatos de fichero** y sus características de preservación, al **Tema 13**.

3.4. Normas técnicas de interoperabilidad

3.4.1. Estructura y ámbito de las normas técnicas

Qué son y quién las aprueba. La **disposición adicional primera** del ENI es el precepto que da al esquema su capacidad de desarrollo. Su apartado 1 anuncia que «se desarrollarán las siguientes normas técnicas de interoperabilidad que serán de **obligado cumplimiento** por parte de las Administraciones Públicas», y enumera una lista que la reforma de 2021 amplió hasta la letra `v)` `[ENI, disp. adic. 1.ª]` `[RD203]`.

El apartado 2, en su redacción vigente tras el **RD 1125/2024**, atribuye la competencia: «el **Ministerio para la Transformación Digital y de la Función Pública**, a propuesta de la **Comisión Sectorial de Administración Electrónica** prevista en la disposición adicional novena de la Ley 40/2015, **aprobará** las normas técnicas de interoperabilidad y las **publicará mediante Resolución de la persona titular de la Secretaría de Estado de Función Pública**» `[ENI, disp. adic. 1.ª.2]` `[RD1125]`.

> DATO CLAVE
>
> El circuito de aprobación de una NTI tiene **tres escalones**: **propone** la Comisión Sectorial de Administración Electrónica → **aprueba** el Ministerio para la Transformación Digital y de la Función Pública → **se publica** por Resolución de la Secretaría de Estado de Función Pública. Compárese con el del ENS (disposición adicional segunda): allí las instrucciones técnicas de seguridad las aprueba el mismo Ministerio, **a propuesta de la Comisión Sectorial y a iniciativa del Centro Criptológico Nacional**. **El CCN aparece en el circuito del ENS y no en el general del ENI.** Ahora bien, hay una excepción que casi ningún resumen recoge: el propio apartado 3 de la disposición adicional primera del ENI dispone que, «para garantizar la debida interoperabilidad en materia de **ciberseguridad y criptografía**», el **órgano competente será el Centro Criptológico Nacional**.

Las 23 previstas frente a las 12 publicadas. Este es el dato más diferenciador de toda la segunda mitad del tema. La disposición adicional primera prevé **veintitrés** normas técnicas, de la letra `a)` a la `v)`. Solo hay **doce publicadas** en el BOE, y **todas ellas corresponden a las doce primeras letras**, de la `a)` a la `l)`. Las once restantes, incorporadas por el RD 203/2021, **siguen sin aprobarse** `[NTI]`.

Letra	Norma técnica prevista	Estado
a)	**Catálogo de estándares**	Publicada — Resolución de 3-10-2012
b)	**Documento electrónico**	Publicada — Resolución de 19-7-2011
c)	**Digitalización de documentos**	Publicada — Resolución de 19-7-2011
d)	**Expediente electrónico**	Publicada — Resolución de 19-7-2011
e)	**Política de firma electrónica y de certificados de la Administración**	Publicada — Resolución de 19-7-2011
f)	**Protocolos de intermediación de datos**	Publicada — Resolución de 28-6-2012
g)	**Relación de modelos de datos**	Publicada — Resolución de 28-6-2012
h)	**Política de gestión de documentos electrónicos**	Publicada — Resolución de 28-6-2012
i)	**Requisitos de conexión a la Red de comunicaciones de las AA. PP.**	Publicada — Resolución de 19-7-2011
j)	**Procedimientos de copiado auténtico y conversión**	Publicada — Resolución de 19-7-2011
k)	**Modelo de datos para el intercambio de asientos entre entidades registrales**	Publicada — Resolución de 19-7-2011
l)	**Reutilización de recursos de la información**	Publicada — Resolución de 19-2-2013
m)	Inventario y codificación de objetos administrativos	**Pendiente**
n)	Transferencia e ingreso de documentos y expedientes electrónicos	**Pendiente**

Letra	Norma técnica prevista	Estado
`ñ)`	Valoración y eliminación de documentos y expedientes electrónicos	**Pendiente**
`o)`	Preservación de documentación electrónica	**Pendiente**
`p)`	Tratamiento y preservación de bases de datos	**Pendiente**
`q)`	Plan de direccionamiento	**Pendiente**
`r)`	Reutilización de activos en modo producto y en modo servicio	**Pendiente**
`s)`	Registros de funcionarios habilitados	**Pendiente**
`t)`	Registros electrónicos de apoderamientos	**Pendiente**
`u)`	Sistema de referencia de documentos y repositorios de confianza	**Pendiente**
`v)`	Política de firma electrónica y de certificados en el ámbito estatal	**Pendiente**

DATO CLAVE

Doce normas técnicas publicadas —las letras `a)` a `l)`—, aprobadas en **cuatro resoluciones**: **siete** el 19 de julio de 2011, **tres** el 28 de junio de 2012, **una** el 3 de octubre de 2012 y **una** el 19 de febrero de 2013. **No hay ninguna posterior a 2013.** Y la disposición adicional primera vigente prevé **veintitrés**: hay **once pendientes**, incorporadas por el RD 203/2021 y todavía sin aprobar. Cualquier opción de examen que hable de «las doce normas técnicas previstas» confunde lo publicado con lo previsto; y si el enunciado pregunta cuántas hay **aprobadas**, la respuesta es **doce**.

El apartado 4: los cuatro instrumentos. La misma disposición adicional primera ordena desarrollar **cuatro instrumentos para la interoperabilidad**, que son las cuatro plataformas que en la práctica sostienen el ENI `[ENI, disp. adic. 1.ª.4]`:

Instrumento	Qué inventaría o almacena
SIA — Sistema de Información Administrativa	Inventario de **procedimientos administrativos**, servicios prestados y otras actuaciones que generen documentación pública, con su **nivel de informatización** e información sobre interfaces
CISE — Centro de Interoperabilidad Semántica de la Administración	**Modelos de datos** comunes y sectoriales, especificaciones semánticas y codificaciones. Se conecta con instrumentos equivalentes de la UE
CTT — Centro de Transferencia de Tecnología	Directorio de **aplicaciones para su libre reutilización**, con nombre, descripción, uso, **licencia**, estándares abiertos aplicados y estado de desarrollo
DIR3 — Directorio Común de Unidades Orgánicas y Oficinas	Sincronización de la información de **inventariado, codificación y evolución de unidades orgánicas y oficinas**

> DATO CLAVE
> Regla mnemotécnica para no confundirlos: **SIA = procedimientos · CISE = datos · CTT = aplicaciones · DIR3 = órganos**. Los cuatro están en el **apartado 4** de la disposición adicional primera del ENI, y los cuatro son citados por los artículos 9, 10 y 17 del articulado.

El diagrama D17 contrapone las veintitrés normas técnicas previstas con las doce publicadas y su reparto por resoluciones.

3.4.2. Documento electrónico y expediente electrónico

Estas dos normas técnicas —las letras `b)` y `d)`, ambas de la Resolución de 19 de julio de 2011— son las que más directamente afectan al trabajo diario de un técnico de una Administración.

El documento electrónico. La norma técnica de la letra `b)` trata «los **metadatos mínimos obligatorios**, la asociación de los datos y metadatos de firma o de sellado de tiempo, así como otros metadatos complementarios asociados; y los **formatos de documento**» `[ENI, disp. adic. 1.ª.b)]`. Se apoya en el **artículo 26.2 de la Ley 39/2015**, que exige que el documento electrónico administrativo contenga información archivada en soporte electrónico en formato identificable, disponga de datos de identificación que permitan su **individualización**, incorpore una **referencia temporal**, incorpore los **metadatos mínimos exigidos** e incorpore las **firmas electrónicas** que correspondan `[L39, art. 26.2]`.

La estructura resultante de un documento electrónico administrativo tiene, por tanto, **tres componentes**:

Componente	Qué es	Ejemplo
Contenido	El conjunto de datos que constituye el documento propiamente dicho	El PDF de la resolución
Metadatos	Datos que describen el contexto, el contenido y la estructura del documento y su gestión a lo largo del tiempo	Identificador, órgano, fecha de captura, origen —ciudadano o Administración—, estado de elaboración, tipo documental
Firmas	La firma o firmas electrónicas asociadas, y en su caso el **sello de tiempo**	Firma del titular del órgano; sello de órgano en actuación automatizada

DATO CLAVE

Los **metadatos no son opcionales ni accesorios**: son un **requisito de validez** del documento por el artículo 26.2.d) de la Ley 39/2015. Un PDF firmado pero sin los metadatos mínimos de la norma técnica **no es un documento electrónico administrativo válido**. Y un metadato concreto merece especial atención: el de **estado de elaboración**, que distingue el **original**, la **copia electrónica auténtica** y la **copia electrónica parcial auténtica**, y que es lo que permite saber, mirando el documento, qué grado de autenticidad tiene lo que se está manejando.

El expediente electrónico. La norma técnica de la letra `d)` trata «de su **estructura y formato**, así como de las **especificaciones de los servicios de remisión y puesta a disposición**» `[ENI, disp. adic. 1.ª.d)]`. Su base legal es el **artículo 70 de la Ley 39/2015**, ya visto: los expedientes «tendrán formato electrónico» y se forman «mediante la **agregación ordenada**» de los documentos que deban integrarlos «así como un **índice numerado**» de todos ellos cuando se remita, debiendo constar además «**copia electrónica certificada de la resolución adoptada**» `[L39, art. 70.2]`.

Los **cuatro componentes** del expediente electrónico son:

1. **Índice electrónico**, firmado por la Administración, órgano o entidad actuante. Es la pieza que «**garantizará la integridad e inmutabilidad del expediente electrónico** generado desde el momento de su firma y permitirá su **recuperación** siempre que sea preciso» `[L39, art. 70.3]`.
2. **Documentos electrónicos** que forman el expediente, cada uno con sus propios metadatos y firmas.
3. **Metadatos del expediente**, distintos de los de los documentos.
4. **Firma del índice**, que es lo que ata todo el conjunto.

DATO CLAVE

El **índice electrónico firmado** es la clave de bóveda del expediente. La Ley 39/2015 le atribuye **tres funciones** en un solo inciso: garantizar la **integridad**, garantizar la **inmutabilidad** «desde el momento de su firma» y permitir la **recuperación**. Y añade una consecuencia práctica: «siendo **admisible que un mismo documento forme parte de distintos expedientes electrónicos**» `[L39, art. 70.3]`. Un documento no «pertenece» a un expediente: es referenciado por el índice de cuantos expedientes lo necesiten. Esa es la razón de ser de la norma técnica pendiente de la letra `u)`, sobre **sistema de referencia de documentos y repositorios de confianza**, cuyo objeto declarado es «**evitar trasladar documentación de forma innecesaria**».

Y una regla negativa que conviene retener: el **artículo 70.4** excluye del expediente administrativo «la información que tenga carácter **auxiliar o de apoyo**», como la contenida en aplicaciones, ficheros y bases de datos informáticas, notas, borradores, opiniones, resúmenes, comunicaciones e informes internos, así como los juicios de valor, **salvo** que se trate de informes preceptivos y facultativos solicitados antes de la resolución `[L39, art. 70.4]`.

EJEMPLO DE APLICACIÓN EN EL AYTO

El Ayuntamiento debe remitir a un juzgado el expediente completo de una licencia. La operación no consiste en comprimir una carpeta: hay que generar el **índice electrónico**, firmarlo con sello de órgano, incorporar cada documento con sus **metadatos** y sus firmas, incluir la **copia electrónica certificada de la resolución**, excluir los borradores y las notas internas que no sean informes preceptivos o facultativos previos a la resolución, y remitirlo por el servicio previsto en la **norma técnica de expediente electrónico**. Si el sistema de tramitación no está preparado para producir ese objeto, el problema no es informático: es **jurídico**, porque el requerimiento judicial no queda atendido.

El diagrama D18 desglosa el expediente electrónico en sus cuatro componentes y muestra el papel del índice firmado.

3.4.3. Catálogo de estándares y reutilización de soluciones

El Catálogo de estándares. Es la norma técnica de la letra `a)`, aprobada por **Resolución de 3 de octubre de 2012**, y su función la define la propia disposición adicional primera: «establecerá un conjunto de estándares que satisfagan lo previsto en el **artículo 11** de forma **estructurada** y con indicación de los **criterios de selección y ciclo de vida** aplicados» `[ENI, disp. adic. 1.ª.a)]`.

El Catálogo organiza los estándares por **áreas de aplicación** —documento, imagen, sonido, vídeo, datos, mensajería, seguridad, web, geográfica— y les asigna un **estado dentro de un ciclo de vida** que suele resumirse en tres situaciones: **admitido** para uso general, **en observación** cuando su futuro es incierto y **en desuso** cuando se está retirando. El artículo 11.5 añade que el catálogo

«contendrá una relación de **estándares abiertos y en su caso complementarios** aplicables» `[ENI, art. 11.5]`.

> DATO CLAVE
>
> Dos definiciones del anexo del ENI que el artículo 11 usa. **Estándar abierto**: la definición aplicable es la de la Ley 11/2007, anexo, letra `k)`, que exige **dos condiciones acumulativas**, literalmente: «que **sea público y su utilización sea disponible de manera gratuita o a un coste que no suponga una dificultad de acceso**» y que «su **uso y aplicación no esté condicionado al pago de un derecho de propiedad intelectual o industrial**». Nótese la paradoja normativa: el ENI se remite, para su definición más importante, al **anexo de una ley derogada**, igual que en sus artículos 1.1 y 3.1. La segunda definición es «**uso generalizado por los ciudadanos**», que es la puerta por la que entran los formatos no abiertos que la gente usa de hecho, siempre **de forma complementaria** y nunca **en exclusiva**.

El vínculo con la conservación. El artículo 23 obliga a conservar el documento en su formato original y **preferentemente** en un estándar abierto, y a actuar cuando haya **riesgo de obsolescencia** o cuando el formato «**deje de figurar entre los admitidos** en el presente Esquema Nacional de Interoperabilidad» `[ENI, art. 23.3]`. Esa última expresión es la que conecta el Catálogo con la conservación: cuando el Catálogo degrada un formato, los documentos guardados en él **entran en el supuesto de conversión** mediante copiado auténtico con cambio de formato.

> DATO CLAVE
>
> El Catálogo de estándares **no es una lista estática**: tiene un **ciclo de vida**, y la degradación de un formato dentro de él **dispara la obligación** del artículo 23.3. Es el mecanismo por el que el ENI evita que una decisión técnica tomada en 2012 condene a la Administración a conservar durante décadas ficheros que ya nadie puede abrir.

Las normas de conformidad del ENI (capítulo XI). Cierran la estructura y son deliberadamente ligeras en comparación con las del ENS `[ENI, arts. 25–28]`:

- **Artículo 25**: la interoperabilidad de las **sedes y registros electrónicos**, así como la del acceso electrónico de los ciudadanos a los servicios públicos, «se regirán por lo establecido en el Esquema Nacional de Interoperabilidad».
- **Artículo 26**: la conformidad con el ENI «**se incluirá en el ciclo de vida** de los servicios y sistemas, acompañada de los correspondientes procedimientos de control».
- **Artículo 27**: «Cada órgano o Entidad de Derecho Público establecerá **sus mecanismos de control** para garantizar, de forma efectiva, el cumplimiento del Esquema Nacional de Interoperabilidad.»

- **Artículo 28**: los órganos y entidades «darán **publicidad, en las correspondientes sedes electrónicas**, a las **declaraciones de conformidad** y a otros posibles **distintivos de interoperabilidad** de los que sean acreedores».

DATO CLAVE

Comparación de los dos regímenes de conformidad. El **ENI** solo prevé **declaraciones de conformidad** y distintivos publicados en sede, con **mecanismos de control internos** definidos por cada entidad: **no hay auditoría obligatoria, ni plazo, ni entidad certificadora, ni categorías**. El **ENS** prevé **auditoría al menos cada dos años**, **autoevaluación en BÁSICA** y **certificación por entidad certificadora en MEDIA y ALTA**, con instrucción técnica que fija los requisitos exigibles a esas entidades. **La conformidad con el ENS es verificable por un tercero; la conformidad con el ENI es autodeclarada.** Esa es, junto con la ausencia de categorías y de anexo de medidas, la mayor diferencia estructural entre los dos esquemas.

Los artículos 26 y 27 del ENI tienen, además, un **gemelo casi literal** en el ENS: los artículos 36 y 37, que dicen prácticamente lo mismo sobre el ciclo de vida y los mecanismos de control. El paralelismo no es casual: los dos reales decretos de 2010 se redactaron a la vez y con la misma plantilla, y el ENS de 2022 conservó esa parte.

RELACIÓN CON OTROS TEMAS

El **derecho de acceso a la información pública** y la **transparencia**, que se apoyan en la publicidad de las declaraciones de conformidad del artículo 28 del ENI, se desarrollan en el **Tema 6**. Las **fases del procedimiento administrativo** en las que se producen los documentos y expedientes aquí descritos, en el **Tema 7**.

---

4. Gobernanza y sinergias entre el ENS y el ENI

4.1. Órganos de gobernanza y coordinación

4.1.1. El Centro Criptológico Nacional y los comités de cooperación

Los dos esquemas no se sostienen solos: dependen de un conjunto de órganos que los desarrollan, los interpretan, recogen información sobre su cumplimiento y responden cuando algo falla. Conviene tener localizado **qué hace cada uno y en qué precepto está**.

El Centro Criptológico Nacional (CCN). Es el órgano central del ENS. Está **adscrito al Centro Nacional de Inteligencia** y sus funciones en este ámbito proceden de varios preceptos:

Función	Precepto
Iniciativa en la elaboración de las instrucciones técnicas de seguridad	`[ENS, disp. adic. 2.ª]`
Elaborar y difundir las **guías CCN-STIC**, «particularmente de la **serie 800**», que se incorporan al conjunto documental de las auditorías	`[ENS, disp. adic. 2.ª]`
Validar y publicar los perfiles de cumplimiento específicos y los esquemas de acreditación	`[ENS, art. 30.3]`
Articular los procedimientos de **recogida y consolidación** de la información del informe del estado de la seguridad	`[ENS, art. 32.2]`
Articular la **respuesta a incidentes** en torno al **CCN-CERT**	`[ENS, art. 33.1]`
Ejercer la **coordinación nacional de la respuesta técnica de los CSIRT** en el sector público	`[ENS, art. 33.5]`
Determinar técnicamente el **riesgo de reconexión** de un sistema tras un incidente	`[ENS, art. 33.6]`
Requerir los informes de auditoría	`[ENS, art. 31.7]`
Ser el **órgano competente para garantizar la interoperabilidad en materia de ciberseguridad y criptografía** en relación con el ENI	`[ENS, art. 35.2]` y `[ENI, disp. adic. 1.ª.3]`
Desarrollar, con el **INAP**, los programas de sensibilización, concienciación y formación	`[ENS, disp. adic. 1.ª]`

DATO CLAVE

El **CCN está adscrito al CNI**, no al Ministerio para la Transformación Digital. Y la función del **artículo 35.2 del ENS** es la que hay que retener por encima de las demás, porque es literalmente un puente entre los dos esquemas: «El CCN es el **órgano competente para garantizar la debida interoperabilidad en materia de ciberseguridad y criptografía, en relación con la aplicación del Real Decreto 4/2010**». La misma regla la repite, desde el otro lado, el apartado 3 de la disposición adicional primera del **ENI**. Es la única materia del ENI cuya competencia técnica no está en el circuito ordinario de las normas técnicas.

Los tres equipos de respuesta a incidentes. Los artículos 33 y 34 reparten la respuesta entre tres CSIRT de referencia, y la clave es a cuál corresponde cada ámbito `[ENS, arts. 33 y 34]`:

Equipo	Ámbito de referencia	Depende de
CCN-CERT	**Sector público**. Recibe la notificación de los incidentes con **impacto significativo** en los sistemas del ámbito del ENS	**CCN**, adscrito al **CNI**
INCIBE-CERT	**Ciudadanos y entidades de derecho privado**. Recibe las notificaciones de las organizaciones privadas que prestan servicios a entidades públicas, y las pone **inmediatamente** en conocimiento del CCN-CERT	**INCIBE**
ESPDEF-CERT	**Defensa nacional**. Interviene cuando un incidente puede afectar al funcionamiento del Ministerio de Defensa o a la operatividad de las Fuerzas Armadas	**Mandato Conjunto del Ciberespacio (MCCE)**

A ellos se añade, para los **operadores críticos**, la coordinación con el **Ministerio del Interior a través de su Oficina de Coordinación de Ciberseguridad**, conforme al Real Decreto-ley 12/2018 `[ENS, art. 33.3]` `[RDL12-2018]`.

> **DATO CLAVE**
> Regla para no equivocarse: **público → CCN-CERT · privado → INCIBE-CERT · defensa → ESPDEF-CERT**. Y un matiz: cuando una empresa privada que presta servicios a una Administración sufre un incidente, **notifica al INCIBE-CERT**, y es este quien lo traslada **inmediatamente** al CCN-CERT `[ENS, art. 33.7]`. No notifica directamente al CCN-CERT.

Los servicios del CCN-CERT. El artículo 34.1 los enumera en **cuatro letras** `[ENS, art. 34.1]`: `a)` **soporte y coordinación** para el tratamiento de vulnerabilidades y la resolución de incidentes, con la facultad de recabar informes, registros de auditoría, configuraciones y soportes informáticos; `b)` **investigación y divulgación de las mejores prácticas**, materializada en las **series CCN-STIC**; `c)` **formación** del personal especialista del sector público; y `d)` **información sobre vulnerabilidades, alertas y avisos** de nuevas amenazas.

La Comisión Sectorial de Administración Electrónica. Es el órgano de **cooperación entre Administraciones**, y su papel en este tema es doble: propone tanto las **normas técnicas de interoperabilidad** como las **instrucciones técnicas de seguridad**. La **disposición adicional novena de la Ley 40/2015** la define como «órgano **técnico** de cooperación de la Administración General del Estado, de las Administraciones de las Comunidades Autónomas y de las **Entidades Locales** en materia de administración electrónica», **dependiente de la Conferencia Sectorial de Administración Pública**, y le atribuye **tres funciones** `[L40, disp. adic. 9.ª]`:

`a)` **Asegurar la compatibilidad e interoperabilidad** de los sistemas y aplicaciones empleados por las Administraciones Públicas. `b)` **Impulsar el desarrollo de la administración electrónica**

en España. `c)` **Asegurar la cooperación** entre las Administraciones Públicas para proporcionar **información administrativa clara, actualizada e inequívoca**.

> DATO CLAVE
>
> Cuatro precisiones sobre la Comisión Sectorial. Primera: es un órgano **técnico**, y **depende de la Conferencia Sectorial de Administración Pública**. Segunda: incluye a las **Entidades Locales**, lo que la convierte en el cauce por el que un ayuntamiento participa en la elaboración de las normas que le obligan. Tercera: sus funciones son **tres**, letras `a)` a `c)`. Y cuarta, la que más se falla: el **ENI todavía la llama «Comité Sectorial»** en su artículo 8.1, denominación de la derogada Ley 11/2007, mientras que su propia disposición adicional primera, reformada, ya dice «**Comisión** Sectorial». **En el mismo real decreto conviven las dos denominaciones.**

El resto del mapa institucional. Completan el cuadro, sin ser órganos del ENS ni del ENI pero apareciendo en su articulado o siendo imprescindibles para entenderlos:

- La **Secretaría General de Administración Digital (SGAD)**, que dispone de su propia política de seguridad (art. 12.4 del ENS), autoriza la **reconexión a los medios y servicios comunes** tras un incidente (art. 33.6) y opera las infraestructuras y servicios comunes del artículo 12 del ENI.
- El **Ministerio para la Transformación Digital y de la Función Pública**, que **aprueba** tanto las NTI como las ITS desde la reforma del RD 1125/2024, publicándolas por Resolución de la **Secretaría de Estado de Función Pública** `[RD1125]`.
- El **Instituto Nacional de Administración Pública (INAP)**, coautor con el CCN de los programas formativos de la disposición adicional primera del ENS.
- La **Agencia Española de Protección de Datos** y las autoridades autonómicas, cuyos criterios menciona expresamente el artículo 3.1 del ENS `[ENS, art. 3.1]`.
- La **Intervención General de la Administración del Estado**, que participa en la autorización de reconexión cuando el incidente afecta a un medio o servicio común bajo su responsabilidad `[ENS, art. 33.6]`.

El diagrama D19 reúne el mapa de gobernanza y los puentes entre los dos esquemas.

4.2. Integración operativa de seguridad e interoperabilidad

4.2.1. Intercambio seguro de información y auditoría conjunta

Este apartado responde a la pregunta que da sentido a que el temario oficial junte los dos esquemas en un solo tema: **por dónde se tocan**.

Los cuatro puentes normativos. No son una construcción doctrinal: están escritos, uno por uno, en los dos reales decretos y en la Ley 39/2015.

Puente	Precepto	Qué dice
1. La conservación se asegura con el ENS	`[ENI, art. 22.1]`	«Para asegurar la conservación de los documentos electrónicos **se aplicará lo previsto en el Esquema Nacional de Seguridad** en cuanto al cumplimiento de los **principios básicos** y de los **requisitos mínimos** de seguridad mediante la aplicación de las **medidas de seguridad adecuadas** a los medios y soportes en los que se almacenen los documentos, **de acuerdo con la categorización de los sistemas**»
2. Publicar un servicio interoperable exige cumplir el ENS	`[ENI, art. 8.1]`	Las condiciones de acceso y utilización de los servicios que una Administración pone a disposición de las demás «deberán en todo caso resultar conformes (…) **a lo dispuesto en el Esquema Nacional de Seguridad**»
3. La criptografía del ENI la gobierna el CCN	`[ENS, art. 35.2]` y `[ENI, disp. adic. 1.ª.3]`	El CCN «es el **órgano competente para garantizar la debida interoperabilidad en materia de ciberseguridad y criptografía**, en relación con la aplicación del Real Decreto 4/2010»
4. La copia auténtica exige los dos a la vez	`[L39, art. 27.3]`	Para garantizar la identidad y contenido de las copias, «las Administraciones Públicas deberán ajustarse a lo previsto en el **Esquema Nacional de Interoperabilidad, el Esquema Nacional de Seguridad y sus normas técnicas de desarrollo**»

DATO CLAVE

El **artículo 22 del ENI** es el puente más citable, y conviene fijarse en su detalle: no remite al ENS en bloque, remite a sus **principios básicos**, a sus **requisitos mínimos** y a las medidas «**de acuerdo con la categorización de los sistemas**». Es decir, **el ENI importa el aparato completo del ENS**, incluida la categorización que él mismo no tiene. Su apartado 3 completa la lista de propiedades a garantizar y merece leerse porque **mezcla las dimensiones del ENS con conceptos archivísticos**: «integridad, autenticidad, confidencialidad, disponibilidad, trazabilidad, **calidad, protección, recuperación y conservación física y lógica**» de los documentos, sus soportes y medios, «atendiendo a los **riesgos** a los que puedan estar expuestos y a los **plazos** durante los cuales deban conservarse» `[ENI, art. 22.3]`.

Cómo se completan, y por qué hacen falta los dos. La forma más clara de entenderlo es comprobar qué pasa si falta uno de los dos:

Si hay…	pero falta…	Resultado
Seguridad (ENS)	Interoperabilidad (ENI)	Información **bien protegida pero incomunicada**: cada Administración vuelve a pedir al ciudadano lo que otra ya tiene. Se incumple el artículo 28 de la Ley 39/2015
Interoperabilidad (ENI)	Seguridad (ENS)	Información **que circula sin garantías**: se comparte con quien no debe, se altera en tránsito o no se puede acreditar quién la envió
Ambos, pero sin conservación	—	Información **correcta hoy e ilegible mañana**: la dimensión temporal del artículo 6 del ENI

La tensión real entre ambos, que conviene saber formular. Interoperar es **abrir**; asegurar es **restringir**. Un opositor que entienda esto puede razonar cualquier caso práctico. La norma no resuelve la tensión eliminándola, sino **ordenándola**: la apertura se produce **por cauces predefinidos** —la Red SARA, la plataforma de intermediación, los nodos de interoperabilidad, los modelos de datos comunes— y esos cauces llevan incorporadas las medidas del ENS. La interoperabilidad no consiste en que todo esté abierto para todos, sino en que **lo que tiene que fluir fluya por un canal conocido, acordado y medido**.

Esto se ve muy bien en la medida `op.ext.4` **(interconexión de sistemas)** del anexo II del ENS, que **no aplica en BÁSICA**, **aplica en MEDIA** y en **ALTA** exige `+ R1` : interconectar sistemas es una operación que el ENS trata como un riesgo que hay que gestionar, exactamente la operación que el ENI promueve. Y se ve también en `mp.com.1` (perímetro seguro), exigible en **las tres categorías**, y en `op.ext.1` y `op.ext.2` (contratación, acuerdos de nivel de servicio y gestión diaria de recursos externos), que **no aplican en BÁSICA** y sí en MEDIA y ALTA.

EJERCICIO RESUELTO

El Ayuntamiento quiere que su sistema de ayudas consulte automáticamente el nivel de renta de las personas solicitantes a la Agencia Tributaria. Enumérense las obligaciones que se activan por cada esquema. **Por el ENI**: adherirse al servicio de la **plataforma de intermediación de datos** y aceptar sus condiciones (interoperabilidad **organizativa**, art. 8.1); consumir el **modelo de datos común** publicado en el CISE, sin inventar campos propios (interoperabilidad **semántica**, art. 10); usar los **protocolos de intermediación** de la norma técnica de la letra `f)` sobre la **Red SARA** (interoperabilidad **técnica**, arts. 11 a 13); **inventariar** el procedimiento en el SIA y las oficinas en el DIR3 (art. 9); y conservar el resultado de la consulta incorporado al expediente con sus **metadatos** y su índice firmado (arts. 21 y 23). **Por el ENS**: valorar las dimensiones de la nueva información —una consulta de renta eleva casi con seguridad la **confidencialidad**— y **re-categorizar** el sistema si procede (anexo I, ap. 1, que obliga a reevaluar ante modificaciones significativas); aplicar `op.ext.4` (interconexión de sistemas) si la categoría lo exige; aplicar `mp.com.2` y `mp.com.3` a la comunicación; registrar cada consulta en `op.exp.8` para poder acreditar **quién consultó qué y por qué** (trazabilidad); y actualizar la **Declaración de Aplicabilidad** firmada por el responsable de la seguridad (art. 28.2). **Por los dos a la vez**: la modificación es **sustancial**, de modo que procede **auditoría extraordinaria** del artículo 31.1 del ENS —que además reinicia el cómputo de los dos años—, y la conservación del resultado obliga a aplicar el ENS por la vía del artículo 22 del ENI. **Y por una tercera norma**: al tratarse de datos personales de categoría sensible por su alcance, el artículo 3.2 del ENS remite al RGPD, que obliga a analizar riesgos y, si procede, a realizar una **evaluación de impacto**, con la regla de prevalencia del artículo 3.3 si de ella resultan medidas agravadas. Y el beneficio para la ciudadanía es el del **artículo 28 de la Ley 39/2015**: no se le puede exigir que aporte el dato.

La auditoría conjunta. No existe en la norma una «auditoría ENS-ENI» con ese nombre, y conviene saberlo para no caer en una opción de examen que la invente. Lo que existe es una **auditoría del ENS** —regulada, periódica y con entidad certificadora en MEDIA y ALTA— cuyo objeto, definido en el apartado 1.1 del anexo III, **alcanza materia del ENI por la vía del artículo 22**: al comprobar «que se cumplen las recomendaciones de protección descritas en el anexo II», el auditor comprueba también las medidas que protegen la conservación, los soportes y los formatos, que son las que el ENI le encomienda al ENS. Del lado del ENI, lo que hay son los **mecanismos de control** que cada entidad establece por sí misma (art. 27) y la **publicidad** de las declaraciones de conformidad (art. 28).

DATO CLAVE

No hay auditoría de conformidad con el ENI equivalente a la del ENS. Si un enunciado ofrece como opción «auditoría de conformidad con el ENI cada dos años» o «entidad certificadora del ENI», es falso. El ENI se controla con **mecanismos internos** (art. 27) y se acredita con **declaraciones publicadas en sede** (art. 28); el ENS se audita (art. 31) y se certifica (art. 38).

EJEMPLO DE APLICACIÓN EN EL AYTO

El Organismo Autónomo **Informática del Ayuntamiento de Madrid (IAM)** ejerce en la práctica el papel de **responsable del sistema** sobre la infraestructura municipal, mientras que las áreas de gobierno titulares de cada materia actúan como **responsables de la información y del servicio**, y la función de **responsable de la seguridad** se articula a través de la estructura prevista en la **Política de Seguridad de la Información de 2022**, con sus **responsables de seguridad delegados** `[PSI-MAD]`. La **auditoría** que se realiza es la del ENS. La conformidad con el **ENI** se manifiesta de otra manera: en que el registro municipal intercambia asientos por **SIR** con el modelo de datos de la norma técnica de la letra `k)`, en que las oficinas de atención a la ciudadanía están codificadas en **DIR3**, en que los procedimientos figuran en el **SIA**, y en que los expedientes que salen del Ayuntamiento llevan **índice electrónico firmado**. Nadie certifica eso con un sello; lo acredita el hecho de que **funcione con el resto de Administraciones**, que es la prueba de conformidad más exigente que existe.

RELACIÓN CON OTROS TEMAS

La **arquitectura de la seguridad perimetral** que protege esos intercambios se desarrolla en el **Tema 36**; los **protocolos seguros** que los transportan, en el **Tema 35**; y los **mecanismos criptográficos** que sostienen la firma del índice y de los documentos, en el **Tema 32**.

Los diez datos que no se pueden fallar

Bloque de repaso final. Si el día del examen solo hubiera tiempo para una hoja, sería esta.

1. **La norma de cabecera es el artículo 156 de la Ley 40/2015**: apartado **1 = ENI**, apartado **2 = ENS**. El **ENS** vigente es el **RD 311/2022, de 3 de mayo**, que **derogó** el RD 3/2010. El **ENI** vigente sigue siendo el **RD 4/2010, de 8 de enero**, que todavía **remite a la derogada Ley 11/2007** en sus artículos 1.1 y 3.1. Ambos fueron modificados por última vez por el **RD 1125/2024, de 5 de noviembre**.
2. **Siete principios básicos del ENS**, artículo **5**, desarrollados en los artículos **6 a 11** —seis artículos, porque el **10 agrupa dos**—: seguridad como **proceso integral** (6) · gestión basada en los **riesgos** (7) · **prevención, detección, respuesta y conservación** (8) · **líneas de defensa** (9) · **vigilancia continua** y **reevaluación periódica** (10) · **diferenciación de responsabilidades** (11). Las líneas de defensa son de naturaleza **organizativa, física y lógica**.
3. **Tres principios específicos del ENI**, artículo **4**, uno por artículo: **cualidad integral** (5, con **nueve momentos** del ciclo de vida que terminan en publicación, conservación y acceso o interconexión) · **carácter multidimensional** (6) · **enfoque de soluciones multilaterales** (7).

4. **Cinco dimensiones de seguridad, en el orden C-I-T-A-D** del anexo I: **C**onfidencialidad, **I**ntegridad, **T**razabilidad, **A**utenticidad y **D**isponibilidad. El RD 3/2010 las ordenaba **D-A-I-C-T**. **Tres dimensiones de la interoperabilidad** —**organizativa, semántica y técnica**— **más la dimensión temporal**, que no es una cuarta numerada. El marco europeo maneja **cuatro capas**, porque añade la **jurídica**.
5. **Niveles BAJO, MEDIO y ALTO** para las dimensiones; **categorías BÁSICA, MEDIA y ALTA** para el sistema. **Manda la dimensión más alta.** La categoría baja **se llama BÁSICA, no BAJA**. Perjuicio **limitado / grave / muy grave**; incumplimiento **formal subsanable / material o formal no subsanable / grave**. La categoría **se reevalúa anualmente**, y determinarla corresponde al **responsable de la seguridad**, mientras que **valorar** las dimensiones corresponde al de la **información** o del **servicio** (art. 41).
6. **73 medidas** en el anexo II, en **3 grupos** y **16 familias**: `org` **4**, `op` **33**, `mp` **36**. Se formalizan en la **Declaración de Aplicabilidad**, firmada por el **responsable de la seguridad** (art. 28.2), que también recoge las **medidas compensatorias** —justificadas documentalmente y que protejan **igual o mejor**—. **Los principios básicos no se pueden compensar; las medidas sí.**
7. **Conformidad del ENS**: **BÁSICA → autoevaluación** por el propio personal que administra el sistema, con **Declaración de Conformidad** firmada o sellada por la propia entidad; **MEDIA y ALTA → auditoría de certificación**, con **Certificación** firmada por la **Entidad de Certificación**. Ambos distintivos son documentos electrónicos en **PDF-A** publicados en sede. **Auditoría ordinaria al menos cada dos años**, extraordinaria por **modificaciones sustanciales** —que reinicia el cómputo— y prórroga de **tres meses** por fuerza mayor.
8. **El ENI no categoriza, no mide y no audita.** Sus normas de conformidad son **mecanismos de control internos** (art. 27) y **publicidad de las declaraciones en sede** (art. 28). Lo que sí tiene es **prevalencia** sobre cualquier otro criterio (art. 3.2) y una sanción indirecta demoledora: sin él, la copia **no es auténtica** (art. 27.3 de la Ley 39/2015) y el expediente **no está válidamente remitido** (art. 70.3).
9. **Doce normas técnicas de interoperabilidad publicadas** —letras `a)` a `l)` — en cuatro resoluciones: **siete** de 19-7-2011, **tres** de 28-6-2012, **una** de 3-10-2012 y **una** de 19-2-2013. **Ninguna posterior a 2013**, frente a las **veintitrés previstas** en la disposición adicional primera. Y **cuatro instrucciones técnicas de seguridad**, ninguna posterior a **2018**. Circuito: **propone la Comisión Sectorial → aprueba el Ministerio para la Transformación Digital y de la Función Pública → publica la Secretaría de Estado de Función Pública**; en el ENS, además, **a iniciativa del CCN**. Los cuatro instrumentos: **SIA = procedimientos · CISE = datos · CTT = aplicaciones · DIR3 = órganos**.
10. **Los cuatro puentes entre los dos esquemas**: el **artículo 22 del ENI** manda aplicar el ENS para conservar; el **artículo 8.1 del ENI** exige conformidad con el ENS para publicar un servicio interoperable; el **artículo 35.2 del ENS** hace al **CCN** competente en la criptografía del ENI; y el **artículo 27.3 de la Ley 39/2015** exige los dos a la vez para que una copia sea auténtica. **La Red**

SARA presta la Red de comunicaciones de las AA. PP. españolas (art. 13 del ENI) y la hora se sincroniza con el **Real Instituto y Observatorio de la Armada** (art. 15).

Diagramas

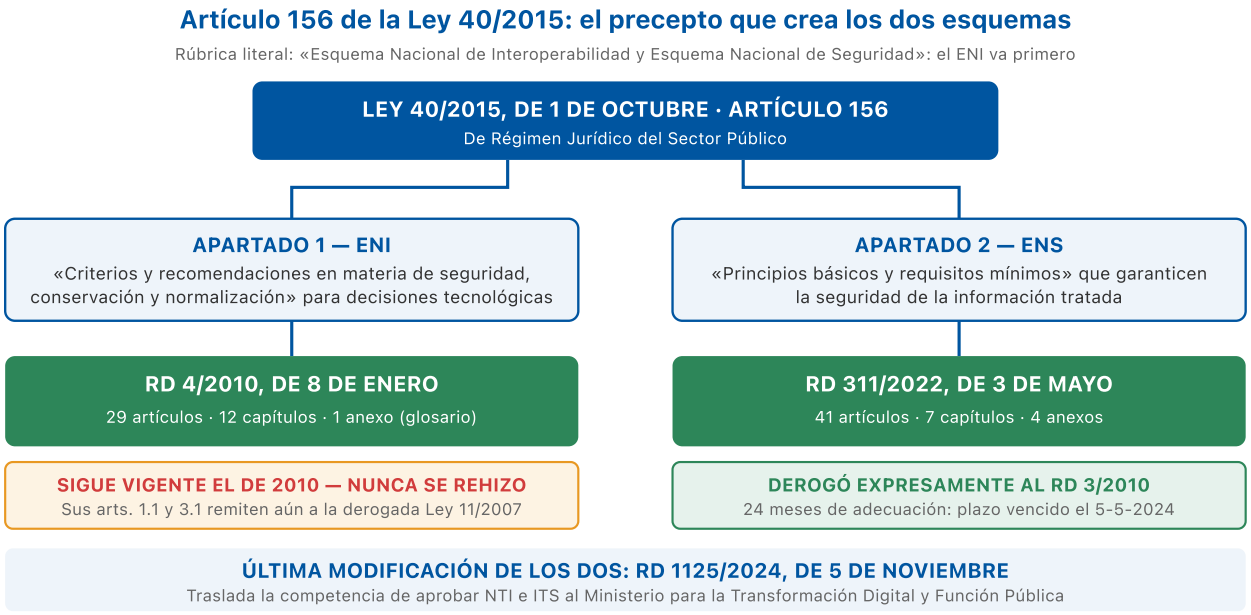
Índice de diagramas

ID	Título	Sección	Tipo
D1	El artículo 156 de la Ley 40/2015: dos esquemas, dos reales decretos	§1.1	Árbol normativo
D2	La cadena normativa: de la Constitución a la instrucción municipal	§1.1.1	Pirámide de cinco niveles
D3	Estructura del RD 311/2022: dónde está cada cosa	§2.1.1	Mapa de capítulos y anexos
D4	Los siete principios básicos del ENS y sus artículos	§2.2	Lista razonada
D5	La cadena del riesgo: activo, amenaza, impacto y salvaguarda	§2.2.1	Cadena causal
D6	Prevención, detección, respuesta y conservación	§2.2.2	Línea temporal del incidente
D7	Líneas de defensa: las tres naturalezas del artículo 9	§2.2.3	Capas concéntricas
D8	Los cuatro responsables del ENS y la regla de separación	§2.2.3	Cuadro de roles
D9	Las cinco dimensiones de seguridad: C-I-T-A-D	§2.3	Tabla-esquema
D10	Autenticidad, integridad y trazabilidad sobre una solicitud	§2.3.2	Recorrido temporal
D11	Los tres niveles de impacto y sus supuestos	§2.4.1	Escala comparativa
D12	De los niveles a la categoría: la regla del máximo	§2.4.2	Caso resuelto
D13	El anexo II: 73 medidas, 3 grupos, 16 familias	§2.5.1	Mapa del catálogo
D14	Los dos caminos de la conformidad y el circuito de auditoría	§2.5.2	Bifurcación + flujo
D15	Estructura del RD 4/2010 y sus tres principios específicos	§3.1.1 · §3.2	Mapa de capítulos

ID	Título	Sección	Tipo
D16	Tres dimensiones del ENI frente a cuatro capas europeas	§3.3	Comparativa de pilas
D17	23 normas técnicas previstas, 12 publicadas	§3.4.1	Rejilla de estado
D18	El expediente electrónico y su índice firmado	§3.4.2	Anatomía del objeto
D19	Gobernanza y los cuatro puentes entre ENS y ENI	§4.1.1 · §4.2.1	Mapa institucional

D1 · El artículo 156 de la Ley 40/2015: dos esquemas, dos reales decretos

Sección: §1.1 — Fundamentos normativos de la administración electrónica **Propósito**: Fijar de entrada el precepto de cabecera y la asimetría entre los dos esquemas: mismo origen legal, distinta suerte reglamentaria. El ENS se rehízo en 2022; el ENI sigue siendo el de 2010.



[Fuente: L40, art. 156 · ENS · ENI · RD1125 — textos consolidados del BOE]

D2 · La cadena normativa: de la Constitución a la instrucción municipal

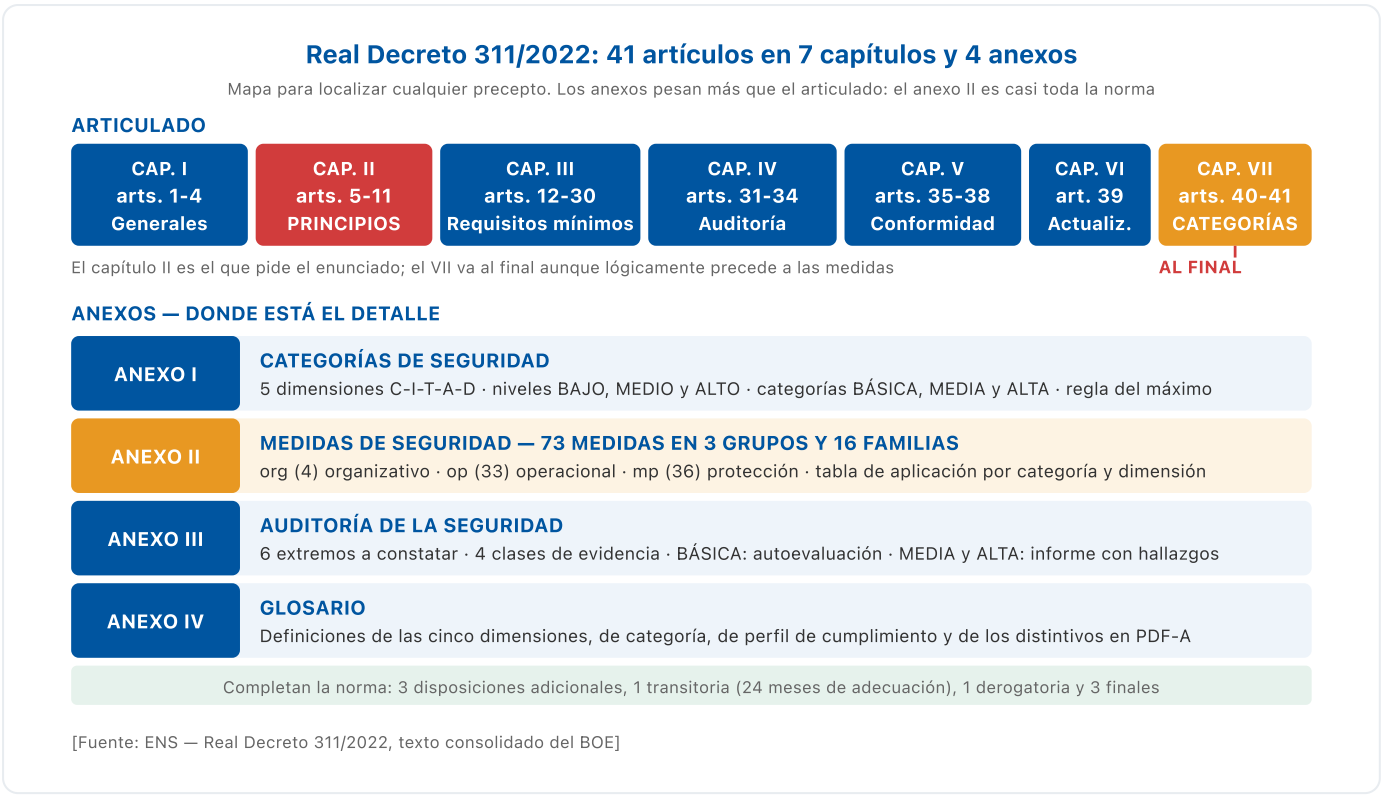
Sección: §1.1.1 — El principio de seguridad y la dimensión de la interoperabilidad **Propósito**: Situar los dos esquemas en la pirámide normativa completa y mostrar que por debajo de ellos hay dos escalones más —normas técnicas estatales y normativa municipal— que son los que aterrizan la obligación en el puesto de trabajo.



[Fuente: CE · L40 · L39 · ENS · ENI · NTI · ITS · PSI-MAD — verificado en BOE y BOAM]

D3 · Estructura del RD 311/2022: dónde está cada cosa

Sección: §2.1.1 — Objeto y normativa vigente del Esquema Nacional de Seguridad **Propósito**: Dar un mapa para localizar cualquier pregunta del ENS, subrayando la colocación contraintuitiva del capítulo VII (categorización) al final del articulado y el peso real de los anexos.



[Fuente: ENS — Real Decreto 311/2022, texto consolidado del BOE]

D4 · Los siete principios básicos del ENS y sus artículos

Sección: §2.2 — Principios básicos del Esquema Nacional de Seguridad **Propósito**: Es el diagrama nuclear del tema. Fija los siete principios con su artículo, su idea y la conducta que cada uno excluye, y señala la asimetría siete principios / seis artículos.

Los siete principios básicos del ENS — artículo 5, desarrollados en los artículos 6 a 11

Siete principios y solo seis artículos: el art. 10 lleva dos, porque su rúbrica es «Vigilancia continua y reevaluación periódica»

a) art. 6	**SEGURIDAD COMO PROCESO INTEGRAL**	Elementos humanos, materiales, técnicos, jurídicos y organizativos. Máxima atención a la concienciación del personal **EXCLUYE: cualquier actuación puntual o tratamiento coyuntural (art. 6.1, literal)**
b) art. 7	**GESTIÓN DE LA SEGURIDAD BASADA EN LOS RIESGOS**	Actividad continua y permanentemente actualizada. Entorno controlado, riesgos en niveles aceptables **EXCLUYE: pretender eliminar todo riesgo. Las medidas han de ser equilibradas y proporcionadas**
c) art. 8	**PREVENCIÓN, DETECCIÓN, RESPUESTA Y CONSERVACIÓN**	Prevención con disuasión y reducción de la exposición · detección del ciberincidente · respuesta en tiempo oportuno **NOVEDAD 2022: en el RD 3/2010 era «prevención, reacción y recuperación». Entran DETECCIÓN y CONSERVACIÓN**
d) art. 9	**EXISTENCIA DE LÍNEAS DE DEFENSA**	Múltiples capas de naturaleza ORGANIZATIVA, FÍSICA y LÓGICA. Minimizar el impacto final cuando una capa caiga **El artículo dice «CUANDO una de las capas sea comprometida», no «si»: da por supuesto el fallo**
e) f) art. 10 DOS	**e) VIGILANCIA CONTINUA — detección de actividades o comportamientos anómalos y su oportuna respuesta** **f) REEVALUACIÓN PERIÓDICA — las medidas se reevalúan y actualizan, pudiendo llegar a un replanteamiento**	Apartado 2: evaluación permanente del estado de los activos, para medir su evolución y detectar vulnerabilidades **DIFERENCIA: la vigilancia mira el TRÁFICO y es permanente · la reevaluación mira las MEDIDAS y es periódica**
g) art. 11	**DIFERENCIACIÓN DE RESPONSABILIDADES**	Cuatro responsables: de la INFORMACIÓN, del SERVICIO, de la SEGURIDAD y del SISTEMA. La política detalla sus atribuciones **EXCLUYE: que seguridad y explotación recaigan en la misma persona, o con dependencia jerárquica entre ellas (art. 13.3)**

Los principios NO admiten excepción ni compensación. Los requisitos mínimos sí: el art. 12.7 permite obviar alguno

[Fuente: ENS, arts. 5 a 11, 12.7 y 13.3 — texto consolidado del BOE]

D5 · La cadena del riesgo: activo, amenaza, impacto y salvaguarda

Sección: §2.2.1 — Seguridad integral y gestión del riesgo **Propósito**: Fijar el vocabulario del análisis de riesgos sobre el caso de referencia municipal y distinguir las salvaguardas que reducen probabilidad de las que reducen impacto.

La cadena del riesgo, sobre el sistema de expedientes de la sede municipal

Vocabulario del art. 7 del ENS, del glosario del anexo IV y de MAGERIT. El objetivo no es eliminar el riesgo, sino dejarlo aceptable



LAS SALVAGUARDAS ACTÚAN SOBRE UNO DE LOS DOS FACTORES

REDUCEN LA PROBABILIDAD

- op.exp.4 · Mantenimiento y actualizaciones
- op.exp.6 · Protección frente a código dañino
- op.acc.6 · Autenticación de la organización
- mp.com.4 · Separación de flujos en la red

REDUCEN EL IMPACTO

- mp.info.6 · Copias de seguridad
- op.cont.2 · Plan de continuidad (solo si D es ALTO)
- op.cont.4 · Medios alternativos (solo si D es ALTO)
- op.exp.7 · Gestión de incidentes

TRAMPA CLÁSICA: la copia de seguridad solo reduce el impacto SI ESTÁ FUERA DEL ALCANCE DEL ATACANTE. Una copia accesible desde la misma red se cifra con el resto. De ahí que mp.info.6 tenga refuerzos: + R1 en MEDIA y + R1 + R2 en ALTA.

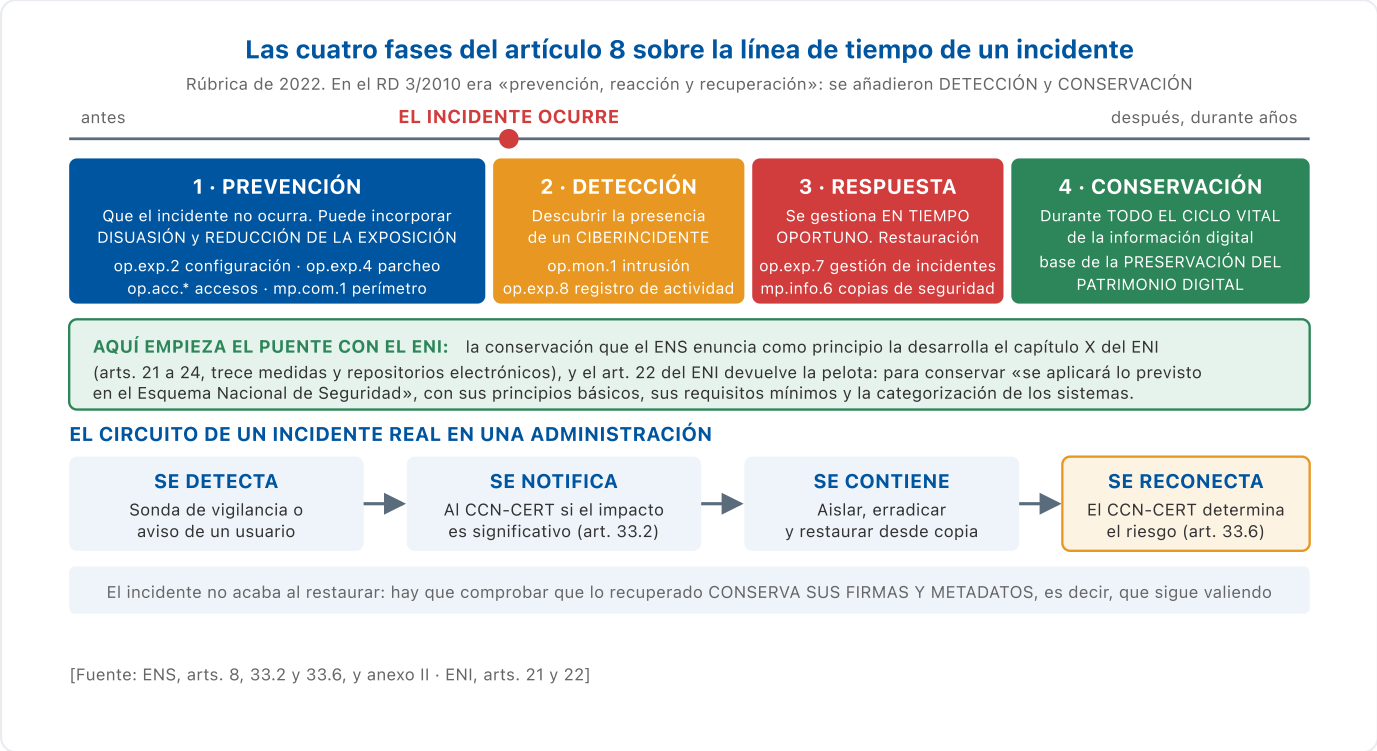
RIESGO RESIDUAL — EL QUE QUEDA DESPUÉS DE APLICAR LAS SALVAGUARDAS

Nadie lo elimina: alguien lo ACEPTA formalmente. Concluye el responsable de la seguridad; decide el del sistema

[Fuente: ENS, arts. 7, 14 y 31.5, anexo II y glosario del anexo IV · MAGERIT v3]

D6 · Prevención, detección, respuesta y conservación

Sección: §2.2.2 — Prevención, detección, respuesta y conservación **Propósito**: Situar las cuatro fases del artículo 8 sobre la línea temporal de un incidente real y asociar a cada una sus medidas del anexo II, mostrando dónde empieza el puente con el ENI.



[Fuente: ENS, arts. 8, 33.2 y 33.6, y anexo II · ENI, arts. 21 y 22]

D7 · Líneas de defensa: las tres naturalezas del artículo 9

Sección: §2.2.3 — Líneas de defensa, vigilancia continua, reevaluación y diferenciación de responsabilidades **Propósito**: Mostrar la defensa en profundidad como capas concéntricas y hacer visible la correspondencia entre las tres naturalezas del artículo 9 y los tres grupos de medidas del anexo II.

Líneas de defensa: múltiples capas de naturaleza organizativa, física y lógica

El artículo 9.1 dice «CUANDO una de las capas sea comprometida», no «si». Se diseña asumiendo que alguna fallará



1 · ORGANIZATIVA — la más externa

Política de seguridad, normativa, procedimientos, autorización, formación y concienciación del personal

Grupos del anexo II: org.1 a org.4 · mp.per.1 a mp.per.4

2 · FÍSICA — la intermedia

Áreas separadas con control de acceso, identificación, acondicionamiento, energía, incendios

Grupo del anexo II: mp.if.1 a mp.if.7 (siete medidas)

3 · LÓGICA — la más interna

Control de acceso, cifrado, firma, perímetro seguro, flujos, protección de aplicaciones y de servicios

Grupos: op.acc · op.exp · mp.com · mp.si · mp.sw · mp.s

LO QUE PIDE EL ARTÍCULO 9.1 A LAS CAPAS: a) desarrollar una reacción adecuada frente a los incidentes que no han podido evitarse, reduciendo la probabilidad de que el sistema sea comprometido EN SU CONJUNTO · b) MINIMIZAR EL IMPACTO FINAL.

[Fuente: ENS, art. 9 y anexo II — texto consolidado del BOE]

D8 · Los cuatro responsables del ENS y la regla de separación

Sección: §2.2.3 — Líneas de defensa, vigilancia continua, reevaluación y diferenciación de responsabilidades **Propósito**: Repartir las facultades de los artículos 11, 13, 28, 31 y 41 entre los cuatro papeles, y destacar la regla de separación reforzada del artículo 13.3.

Los cuatro responsables del artículo 11 y el reparto de facultades

Regla de oro: VALORAR las dimensiones lo hacen información y servicio (art. 41.1) · DETERMINAR LA CATEGORÍA, la seguridad (art. 41.2)

RESPONSABLE DE LA INFORMACIÓN

Responde del CONTENIDO: qué es esa información y cuánto vale.

Art. 13.2.a): «determinará los requisitos de la información tratada».

FACULTAD PROPIA (art. 41.1): valorar los niveles de las cinco dimensiones de la información, y modificarlos después.

RESPONSABLE DEL SERVICIO

Responde de la PRESTACIÓN: para qué sirve y qué pasa si se cae.

Art. 13.2.b): «determinará los requisitos de los servicios prestados».

FACULTAD PROPIA (art. 41.1): valorar los niveles de las cinco dimensiones del servicio, y modificarlos después.

las dos valoraciones alimentan la categorización

RESPONSABLE DE LA SEGURIDAD

Responde de que las MEDIDAS sean las adecuadas y funcionen.

Art. 41.2: DETERMINA LA CATEGORÍA del sistema.

Art. 28.2: FIRMA LA DECLARACIÓN DE APLICABILIDAD.

Art. 28.3: aprueba formalmente las medidas compensatorias.

Art. 31.5: ANALIZA los informes de auditoría y concluye.

RESPONSABLE DEL SISTEMA

Responde de la EXPLOTACIÓN: que funcione el día a día.

Art. 13.2.d): desarrolla la forma concreta de implementar la seguridad; puede delegar en administradores u operadores.

Art. 31.5: ADOPTA LAS MEDIDAS CORRECTORAS.

Art. 31.6: en categoría ALTA, puede SUSPENDER la operación.

REGLA DE SEPARACIÓN — ART. 11.2 Y ART. 13.3

«El responsable de la seguridad será DISTINTO del responsable del sistema, NO DEBIENDO EXISTIR DEPENDENCIA JERÁRQUICA.» No basta con que sean dos personas. Excepción tasada: ausencia justificada de recursos, y entonces MEDIDAS COMPENSATORIAS.

SERVICIOS EXTERNALIZADOS (art. 13.5): el proveedor designa un POC, «sin perjuicio de que LA RESPONSABILIDAD ÚLTIMA RESIDA EN LA ENTIDAD DEL SECTOR PÚBLICO»

[Fuente: ENS, arts. 11, 13, 28, 31 y 41 — texto consolidado del BOE]

D9 · Las cinco dimensiones de seguridad: C-I-T-A-D

Sección: §2.3 — Dimensiones de seguridad de la información **Propósito**: Fijar las cinco dimensiones en el orden del anexo I vigente, con su definición del glosario, la pregunta que responde cada una y sus medidas características, advirtiendo del orden antiguo D-A-I-C-T.

Las cinco dimensiones de seguridad — anexo I, apartado 2, en su orden vigente

Se identifican «por sus correspondientes iniciales en mayúsculas». Regla mnemotécnica: se leen como CITAD

C	**CONFIDENCIALIDAD**	«Ni se pone a disposición, ni se revela a individuos o procesos NO AUTORIZADOS» **¿QUIÉN PUEDE VER ESTO? — mp.si.1 marcado · mp.si.2 criptografía · mp.si.5 borrado · mp.info.2 y mp.info.5 · mp.com.2**
I	**INTEGRIDAD**	«El activo de información NO HA SIDO ALTERADO de manera no autorizada» **¿ES ESTO LO MISMO QUE SE GUARDÓ? — mp.info.3 firma · mp.com.3 integridad y autenticidad · mp.si.2 · op.exp.3**
T	**TRAZABILIDAD**	«Las actuaciones de una entidad pueden ser TRAZADAS DE FORMA INDISCUTIBLE hasta ella» **¿QUIÉN HIZO QUÉ Y CUÁNDO? — op.exp.8 registro de actividad · op.exp.9 incidentes · mp.info.4 sellos de tiempo · op.mon.3**
A	**AUTENTICIDAD**	«Una entidad ES QUIEN DICE SER, o bien garantiza LA FUENTE de la que proceden los datos» **¿ES DE QUIEN DICE SER? — op.acc.1 identificación · op.acc.5 y op.acc.6 autenticación · mp.info.3 · mp.com.3 · mp.eq.2**
D	**DISPONIBILIDAD**	«Las entidades o procesos autorizados TIENEN ACCESO CUANDO LO REQUIEREN» **¿ESTÁ CUANDO HACE FALTA? — op.cont.1 a 4 continuidad · op.pl.4 capacidad · mp.if.4 a mp.if.6 · mp.info.6 copias · mp.s.4**

AVISO — DOS LISTAS QUE SE CONFUNDEN: el RD 3/2010 las ordenaba D-A-I-C-T. Y las SIETE propiedades del art. 1.2 del ENS añaden ACCESO y CONSERVACIÓN, que NO son dimensiones y no se valoran: las del anexo I son solo cinco.

[Fuente: ENS, anexo I ap. 2, anexo II y glosario del anexo IV · RD3-2010, anexo I ap. 2]

D10 · Autenticidad, integridad y trazabilidad sobre una solicitud

Sección: §2.3.2 — Autenticidad y trazabilidad **Propósito**: Separar las tres dimensiones que se confunden mostrando en qué momento actúa cada una a lo largo de una solicitud presentada en la sede electrónica municipal.

Autenticidad, integridad y trazabilidad sobre una solicitud de la sede municipal

Las tres responden a un «quién», pero a quiénes distintos y en momentos distintos

tiempo

1 · SE IDENTIFICA	2 · FIRMA	3 · SE REGISTRA	4 · SE AUDITA
Certificado electrónico o Cl@ve	La firma acredita a la vez quién y que nada cambió	Número y fecha del asiento; sello de tiempo si D es ALTO	Meses después: quién consultó el expediente
A	A + I	T	T
op.acc.5 · op.acc.6	mp.info.3 · mp.com.3	mp.info.4 (solo ALTA)	op.exp.8 · op.mon.3

A — AUTENTICIDAD — MIRA HACIA EL ORIGEN

¿Es quien dice ser? ¿Vienen los datos de donde dicen? Actúa EN EL MOMENTO. Es lo que hace válido el acto.

I — INTEGRIDAD — MIRA HACIA EL CONTENIDO

¿Ha cambiado algo sin autorización? Inseparable de la autenticidad cuando el mecanismo es criptográfico.

T — TRAZABILIDAD — MIRA HACIA ATRÁS

¿Quién hizo qué y cuándo? Actúa DESPUÉS. No protege: permite reconstruir y rendir cuentas.

POR QUÉ VIAJAN EMPAREJADAS EN EL ANEXO II mp.com.3 lleva I y A · mp.info.3 lleva I y A · op.acc.1 lleva T y A. La denominación literal de mp.com.3 es «Protección de la INTEGRIDAD y de la AUTENTICIDAD», en ese orden.

[Fuente: ENS, anexo I ap. 2, anexo II y glosario del anexo IV · L39, arts. 16 y 26]

D11 · Los tres niveles de impacto y sus supuestos

Sección: §2.4.1 — Criterios de valoración y niveles de impacto **Propósito**: Poner en paralelo los tres niveles del anexo I para que se vean las gradaciones exactas de cada supuesto, que es donde están los matices.

Los tres niveles de impacto — anexo I, apartado 3

Cada nivel se define por cinco supuestos con la misma estructura. Las diferencias están en los adjetivos

SUPUESTO	NIVEL BAJO perjuicio LIMITADO	NIVEL MEDIO perjuicio GRAVE	NIVEL ALTO perjuicio MUY GRAVE
1.º CAPACIDAD DE LA ORGANIZACIÓN	Reducción APRECIABLE, pero las funciones siguen desempeñándose	Reducción SIGNIFICATIVA, pero las funciones siguen desempeñándose	ANULACIÓN EFECTIVA de la capacidad de desarrollar sus funciones
2.º DAÑO EN LOS ACTIVOS	Daño MENOR	Daño SIGNIFICATIVO	Daño MUY GRAVE, e incluso IRREPARABLE
3.º INCUMPLIMIENTO JURÍDICO	Incumplimiento FORMAL, de carácter SUBSANABLE	Incumplimiento MATERIAL, o formal NO SUBSANABLE	Incumplimiento GRAVE de alguna ley o regulación
4.º PERJUICIO A ALGÚN INDIVIDUO	MENOR: molesto, pero FÁCILMENTE REPARABLE	SIGNIFICATIVO, de DIFÍCIL REPARACIÓN	GRAVE, de DIFÍCIL O IMPOSIBLE reparación
5.º OTROS DE NATURALEZA ANÁLOGA — cláusula de cierre idéntica en los tres			

DOS REGLAS QUE ACOMPAÑAN A LA TABLA:

si una dimensión NO SE VE AFECTADA no se adscribe a ningún nivel: no existe el «nivel cero» · y si hay varias informaciones y servicios, el nivel en cada dimensión es EL MAYOR de los de cada información y cada servicio. La categoría se reevalúa ANUALMENTE.

[Fuente: ENS, anexo I, apartados 1 y 3 — texto consolidado del BOE]

D12 · De los niveles a la categoría: la regla del máximo

Sección: §2.4.2 — Categorías de sistemas de información **Propósito**: Resolver gráficamente el ejercicio del sistema de expedientes municipal y hacer visible la consecuencia que más se falla: que la categoría ALTA no eleva las dimensiones que no influyeron.



[Fuente: ENS, anexo I apartados 3 a 5, anexo II y art. 41 — texto consolidado del BOE]

D13 · El anexo II: 73 medidas, 3 grupos, 16 familias

Sección: §2.5.1 — Marco organizativo, marco operacional y medidas de protección **Propósito**: Dar el mapa completo del catálogo de medidas con su recuento exacto por familia, marcando las familias nuevas del RD 311/2022 y explicando cómo se lee la tabla de aplicación.

El anexo II del ENS: 73 medidas · 3 grupos · 16 familias

Proporcionales a las dimensiones relevantes y a la categoría. Son mínimos exigibles, siempre ampliables

org · 4 — MARCO ORGANIZATIVO

Medidas de la ORGANIZACIÓN GLOBAL de la seguridad. Las cuatro se exigen POR CATEGORÍA y APLICAN EN LAS TRES: org.1 política · org.2 normativa · org.3 procedimientos · org.4 proceso de autorización

op · 33 — MARCO OPERACIONAL

Protegen LA OPERACIÓN del sistema como conjunto integral de componentes para un fin

op.pl · Planificación 5 — riesgos y arquitectura	op.acc · Accesos 6 — identificación y acceso	op.exp · Explotación 10 — la familia más numerosa	op.ext · Rec. externos 4 — contratación y ANS
op.nub · Nube 1 — FAMILIA NUEVA EN 2022	op.cont · Continuidad 4 — solo op.cont.1 en MEDIA	op.mon · Monitoriz. 3 — FAMILIA NUEVA EN 2022	TAMBIÉN NUEVAS: op.ext.3 cadena suministro; op.ext.4 interconexión

Códigos clave: op.exp.4 mantenimiento · op.exp.8 registro de actividad, con 5 refuerzos en ALTA
op.exp.10 protección de CLAVES CRIPTOGRÁFICAS, no de registros: es la denominación que muchas fuentes dan mal

mp · 36 — MEDIDAS DE PROTECCIÓN

Protegen ACTIVOS CONCRETOS, según su naturaleza y la calidad exigida por el nivel de las dimensiones

mp.if · Instalaciones 7 — áreas, energía, incendios	mp.per · Personal 4 — concienciación, formación	mp.eq · Equipos 4 — puesto, portátiles, IoT	mp.com · Comunic. 4 — perímetro, cifrado, flujos
mp.si · Soportes 5 — marcado, custodia, borrado	mp.sw · Aplicaciones 2 — desarrollo y aceptación	mp.info · Información 6 — firma, sellos, copias	mp.s · Servicios 4 — correo, web, navegación

Trampas: mp.com.4 NO APLICA EN BÁSICA · mp.info.4 sellos SOLO EN ALTA · mp.s.2 ya exige un refuerzo en BÁSICA

CÓMO SE LEE UNA CELDA: «n.a.» = no aplica · «aplica» = base sin refuerzos · «+ R1 + R2» = base MÁS TODOS · «+ [R1 o R2]» = UNO A ELEGIR

[Fuente: ENS, anexo II, apartados 1, 2 y 5, y tabla de medidas — texto consolidado del BOE]

D14 · Los dos caminos de la conformidad y el circuito de auditoría

Sección: §2.5.2 — Auditoría y certificación de conformidad **Propósito**: Resolver de un vistazo el precepto que ordena la conformidad en el ENS —el artículo 38— y encadenar el circuito del informe de auditoría con la facultad de suspensión del artículo 31.6.

Los dos caminos de la conformidad — artículo 38 y anexo III

Es el precepto clave del ENS. Sea cual sea el camino, la auditoría del art. 31 sigue siendo obligatoria cada dos años

CATEGORÍA DEL SISTEMA

BÁSICA

AUTOEVALUACIÓN

La realiza «EL MISMO PERSONAL QUE ADMINISTRA EL SISTEMA o en quien éste delegue» (anexo III)

Debe estar DOCUMENTADA: si cada medida está implantada, revisada y con qué EVIDENCIAS

RESULTADO: DECLARACIÓN DE CONFORMIDAD

MEDIA Y ALTA

AUDITORÍA DE CERTIFICACIÓN

La realiza una ENTIDAD DE CERTIFICACIÓN, cuyos requisitos concreta la ITS de Conformidad

El informe identifica los HALLAZGOS DE CONFORMIDAD Y NO CONFORMIDAD, con su alcance

RESULTADO: CERTIFICACIÓN DE CONFORMIDAD

AMBOS SE MATERIALIZAN EN UN DISTINTIVO EN FORMATO PDF-A, PUBLICADO EN SEDE (art. 38.2)
La diferencia está en la firma: la DECLARACIÓN la firma LA PROPIA ENTIDAD · la CERTIFICACIÓN, LA ENTIDAD DE CERTIFICACIÓN

EL CIRCUITO DEL INFORME DE AUDITORÍA — ARTÍCULO 31.5 Y 31.6

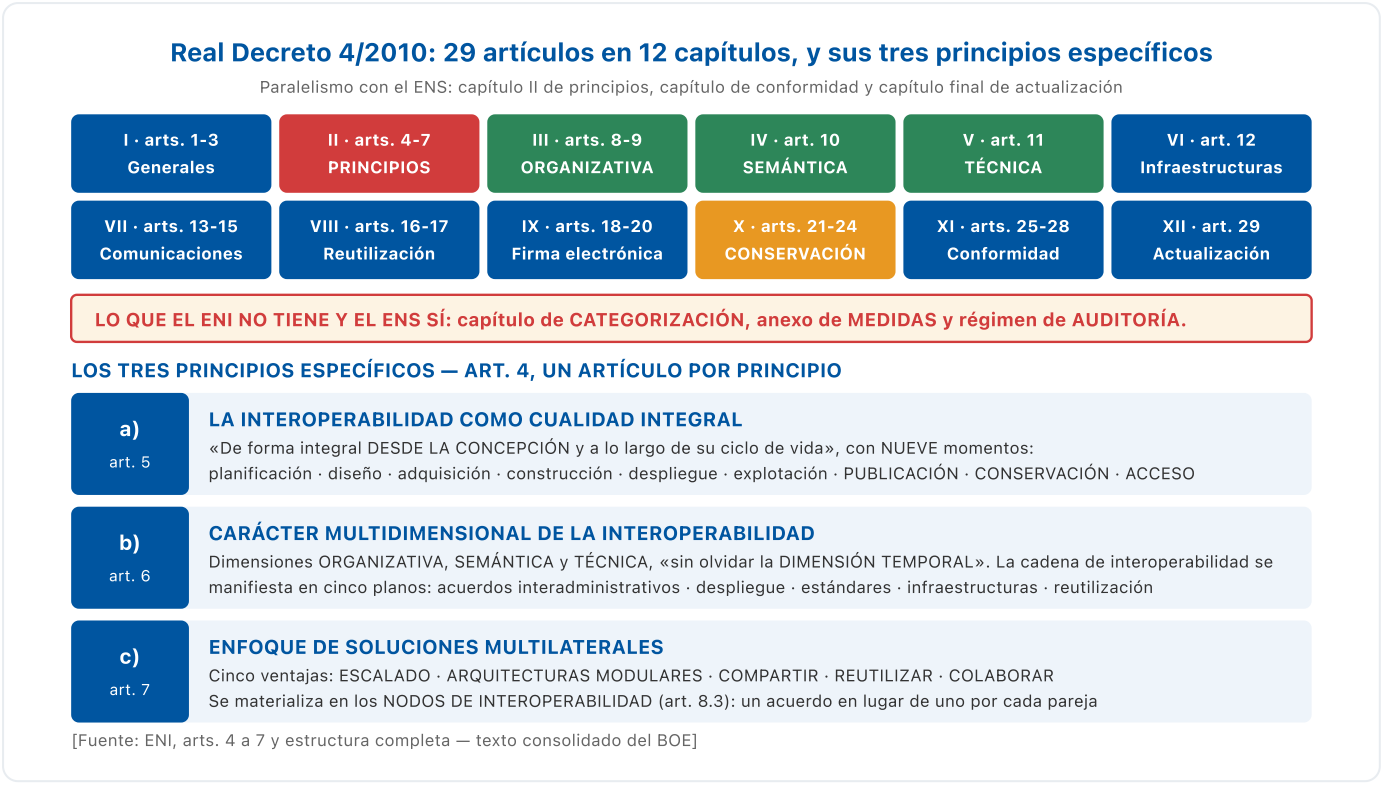
EL AUDITOR (informa y dictamina) → RESPONSABLE DE SEGURIDAD (ANALIZA el informe y presenta conclusiones) → RESPONSABLE DEL SISTEMA (ADOPTA las medidas correctoras) → ALTA (art. 31.6)

SOLO EN CATEGORÍA ALTA el responsable del sistema puede SUSPENDER TEMPORALMENTE el tratamiento o la operación, hasta subsanar

[Fuente: ENS, arts. 31 y 38, anexo III y glosario del anexo IV · ITS de Conformidad]

D15 · Estructura del RD 4/2010 y sus tres principios específicos

Sección: §3.1.1 · §3.2 — Objeto y normativa vigente del ENI · Principios específicos **Propósito**: Dar el mapa del ENI y, en el mismo diagrama, sus tres principios, subrayando el paralelismo estructural con el ENS y las dos piezas que el ENI no tiene.



[Fuente: ENI, arts. 4 a 7 y estructura completa — texto consolidado del BOE]

D16 · Tres dimensiones del ENI frente a cuatro capas europeas

Sección: §3.3 — Dimensiones de la interoperabilidad **Propósito**: Fijar las tres dimensiones del artículo 6 con su capítulo, su pregunta y su instrumento, y contraponerlas a las cuatro capas del marco europeo para que no se confunda «tres más la temporal» con «cuatro».

Las dimensiones de la interoperabilidad: tres en el ENI, cuatro en el marco europeo

El ENI dice «organizativa, semántica y técnica» y añade «sin olvidar la dimensión temporal»: no son cuatro, son tres más un añadido

ENI — ART. 6 · CADA DIMENSIÓN, SU CAPÍTULO, SU PREGUNTA Y SU INSTRUMENTO

ORGANIZATIVA Cap. III · arts. 8-9	¿QUIÉN INTERCAMBIA CON QUIÉN Y CON QUÉ GARANTÍAS? Publicar condiciones de acceso (finalidades, modalidades, requisitos, perfiles, protocolos y SEGURIDAD) · nodos de interoperabilidad · inventarios: procedimientos → SIA · órganos y oficinas → DIR3, codificación unívoca
SEMÁNTICA Cap. IV · art. 10	¿QUÉ SIGNIFICA LO QUE SE INTERCAMBIA? Modelos de datos COMUNES, de preferente aplicación · SECTORIALES, de OBLIGATORIA aplicación · en el CISE Es la dimensión difícil: los protocolos se pactan, el significado hay que acordarlo, y eso no se automatiza
TÉCNICA Cap. V · art. 11	¿CÓMO VIAJA? ESTÁNDARES ABIERTOS como regla; los no abiertos solo si no hay alternativa y mientras no la haya Infraestructuras y servicios comunes (12) · Red SARA (13) · plan de direccionamiento (14) · hora del ROA (15)
+ TEMPORAL Cap. X · arts. 21-24	**¿SEGUIRÁ SIENDO LEGIBLE Y VÁLIDO DENTRO DE 20 AÑOS?** Trece medidas de conservación · repositorios electrónicos · copiado auténtico con cambio de formato

MARCO EUROPEO — REGLAMENTO (UE) 2024/903 Y EIF · CUATRO CAPAS

JURÍDICA	ORGANIZATIVA	SEMÁNTICA	TÉCNICA
LA QUE EL ENI NO TIENE	coincide con el ENI	coincide con el ENI	coincide con el ENI

[Fuente: ENI, arts. 6 a 24 · Reglamento (UE) 2024/903, aplicable desde el 12-7-2024 · EIF]

D17 · 23 normas técnicas previstas, 12 publicadas

Sección: §3.4.1 — Estructura y ámbito de las normas técnicas **Propósito**: Hacer visible de un golpe el dato más diferenciador del bloque del ENI: la disposición adicional primera prevé veintitrés normas técnicas y solo están publicadas las doce primeras letras, ninguna posterior a 2013.

Normas Técnicas de Interoperabilidad: 23 previstas, 12 publicadas

Las publicadas coinciden con las doce primeras letras de la disposición adicional primera. Ninguna es posterior a 2013

PUBLICADAS EN EL BOE — LETRAS a) A l)

a — Catálogo de estándares Res. 3-10-2012	b — Documento electrónico Res. 19-7-2011	c — Digitalización de documentos Res. 19-7-2011	d — Expediente electrónico Res. 19-7-2011
e — Política de firma electrónica Res. 19-7-2011	f — Protocolos de intermediación Res. 28-6-2012	g — Relación de modelos de datos Res. 28-6-2012	h — Gestión de documentos Res. 28-6-2012
i — Conexión a la red AA. PP. Res. 19-7-2011	j — Copiado auténtico Res. 19-7-2011	k — Asientos registrales Res. 19-7-2011	l — Reutilización de recursos Res. 19-2-2013

PENDIENTES — LETRAS m) A v), INCORPORADAS POR EL RD 203/2021

m) Inventario y codificación	n) Transferencia e ingreso	ñ) Valoración y eliminación	o) Preservación de documentación
p) Preservación de bases de datos	q) Plan de direccionamiento	r) Reutilización de activos	s) Funcionarios habilitados
t) Registros de apoderamientos	u) Repositorios de confianza	v) Política de firma y certificados en el ámbito estatal	

CIRCUITO DE APROBACIÓN DE UNA NTI

PROPONE la Comisión Sectorial de Admón. Electrónica → APRUEBA el Ministerio → PUBLICA la Secretaría de Estado

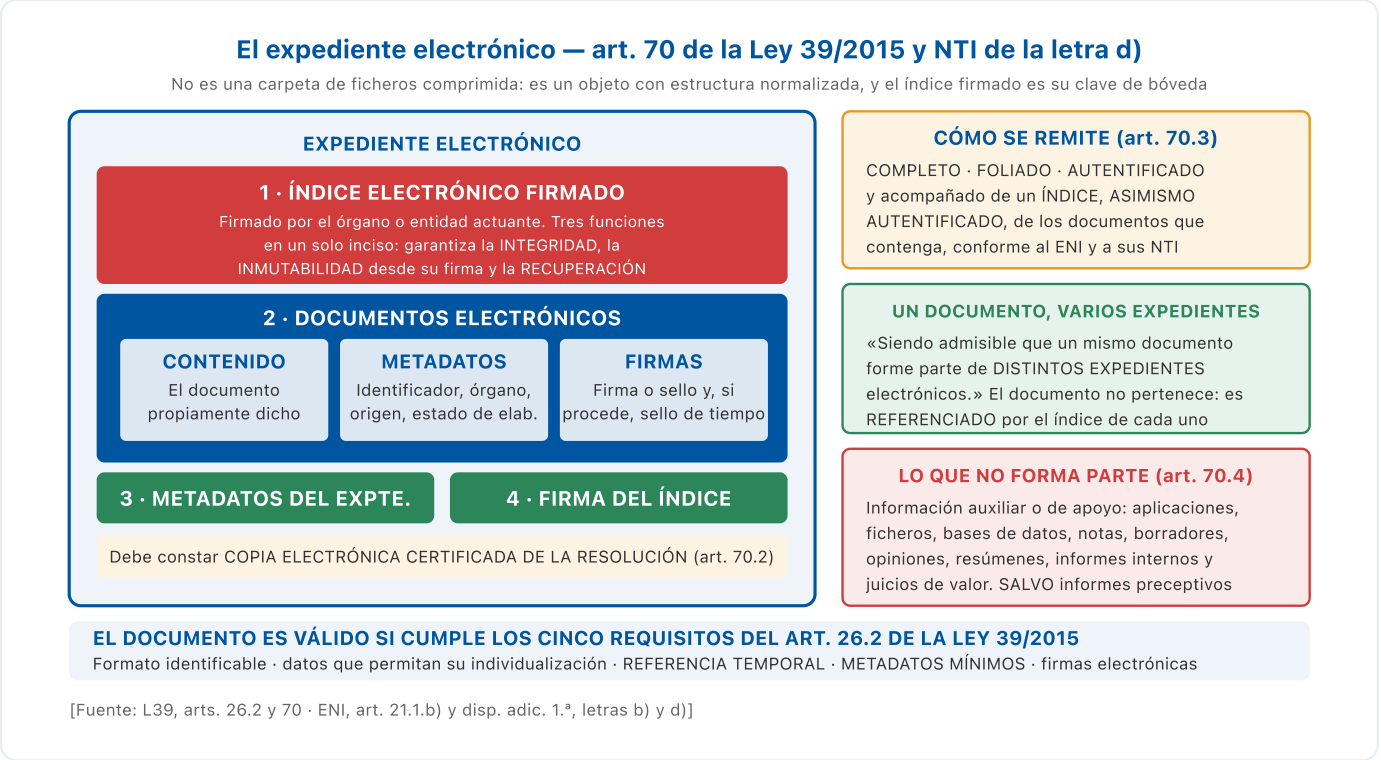
COMPARACIÓN CON EL ENS

En el ENS el circuito es el mismo PERO «a iniciativa del CCN». Solo hay 4 ITS, ninguna posterior a 2018.

[Fuente: ENI, disp. adic. 1.ª · sumarios del BOE verificados uno a uno · ENS, disp. adic. 2.ª · portal del CCN]

D18 · El expediente electrónico y su índice firmado

Sección: §3.4.2 — Documento electrónico y expediente electrónico **Propósito**: Desmontar el objeto «expediente electrónico» en sus cuatro componentes y hacer explícito el papel del índice firmado, que es lo que distingue un expediente de una carpeta de ficheros.



[Fuente: L39, arts. 26.2 y 70 · ENI, art. 21.1.b) y disp. adic. 1.ª, letras b) y d)]

D19 · Gobernanza y los cuatro puentes entre ENS y ENI

Sección: §4.1.1 · §4.2.1 — Órganos de gobernanza · Intercambio seguro de información **Propósito**: Cerrar el tema con el mapa institucional completo y los cuatro preceptos que atan los dos esquemas.

Gobernanza de los dos esquemas y los cuatro puentes que los unen

Los puentes no son doctrina: están escritos en el ENI, en el ENS y en la Ley 39/2015

COMISIÓN SECTORIAL DE ADMINISTRACIÓN ELECTRÓNICA	MINISTERIO PARA LA TRANSFORMACIÓN DIGITAL Y FP	CENTRO CRIPTOLÓGICO NACIONAL — adscrito al CNI
L40 disp. adic. 9.ª · PROPONE NTI e ITS	APRUEBA · publica la SE de Función Pública	INICIATIVA de las ITS · guías CCN-STIC 800

LOS TRES EQUIPOS DE RESPUESTA A INCIDENTES — ARTS. 33 Y 34

CCN-CERT → SECTOR PÚBLICO, recibe los incidentes con impacto significativo y coordina a los CSIRT · INCIBE-CERT → CIUDADANOS Y ENTIDADES PRIVADAS, incluidos los proveedores del sector público, y traslada INMEDIATAMENTE al CCN-CERT · ESPDEF-CERT → DEFENSA

LOS CUATRO PUENTES ENTRE LOS DOS ESQUEMAS

1	**ENI art. 22.1 — LA CONSERVACIÓN SE ASEGURA APLICANDO EL ENS** «Para asegurar la conservación de los documentos SE APLICARÁ LO PREVISTO EN EL ESQUEMA NACIONAL DE SEGURIDAD en cuanto al cumplimiento de los principios básicos y los requisitos mínimos», «DE ACUERDO CON LA CATEGORIZACIÓN DE LOS SISTEMAS»
2	**ENI art. 8.1 — PUBLICAR UN SERVICIO INTEROPERABLE EXIGE CUMPLIR EL ENS** Las condiciones de acceso a los servicios que una Administración pone a disposición de las demás «deberán resultar conformes a los principios y obligaciones» de protección de datos «ASÍ COMO A LO DISPUESTO EN EL ESQUEMA NACIONAL DE SEGURIDAD»
3	**ENS art. 35.2 y ENI disp. adic. 1.ª.3 — LA CRIPTOGRAFÍA DEL ENI LA RIGE EL CCN** «El CCN es el ÓRGANO COMPETENTE PARA GARANTIZAR LA INTEROPERABILIDAD EN CIBERSEGURIDAD Y CRIPTOGRAFÍA, en relación con el Real Decreto 4/2010.» Es la única materia del ENI fuera del circuito ordinario de las normas técnicas
4	**L39 art. 27.3 — LA COPIA AUTÉNTICA EXIGE LOS DOS A LA VEZ** Para garantizar la identidad y el contenido de las copias, «deberán ajustarse a lo previsto en el ESQUEMA NACIONAL DE INTEROPERABILIDAD, EL ESQUEMA NACIONAL DE SEGURIDAD Y SUS NORMAS TÉCNICAS». Sin los dos no hay copia auténtica

[Fuente: ENI, arts. 8.1 y 22 y disp. adic. 1.ª · ENS, arts. 30 a 35 y disp. adic. 2.ª · L40, disp. adic. 9.ª · L39, art. 27.3]

Casos prácticos

Los tres casos recorren el supuesto de referencia del tema (ver la pestaña Contenido, «Convenciones»): el **sistema de tramitación de expedientes de la sede electrónica municipal**, operado por el IAM. El **Caso 1** trabaja la **categorización y la selección de medidas** del ENS (§2.3, §2.4 y §2.5). El **Caso 2**, la **interoperabilidad** de un nuevo intercambio de datos y la conservación de lo intercambiado (§3.2, §3.3 y §3.4). Y el **Caso 3**, la **gobernanza, la conformidad y la respuesta a un incidente**, donde los dos esquemas actúan a la vez (§2.2, §2.5.2, §4.1 y §4.2).

Caso 1 — Categorización y adecuación al ENS del sistema de expedientes

Enunciado

El **Organismo Autónomo Informática del Ayuntamiento de Madrid (IAM)** va a poner en explotación una nueva versión del **sistema de tramitación de expedientes** que da soporte a la sede electrónica municipal. Datos del supuesto:

- El sistema **recibe solicitudes** de la ciudadanía, **forma expedientes electrónicos**, **resuelve** y **notifica**.
- Trata **datos personales de contacto y de situación económica** de las personas solicitantes de ayudas sociales.
- Sus resoluciones son **actos administrativos** que producen efectos jurídicos frente a terceros.
- Debe poder acreditarse **quién resolvió cada expediente y quién lo consultó**, incluso años después.
- Una interrupción del servicio **retrasa la tramitación**, pero los plazos son restituibles por la vía del artículo 32 de la Ley 39/2015 y no se pierde información.
- Un **módulo específico**, delimitable en información y en servicios, trata expedientes de **violencia de género** con requisitos de confidencialidad muy superiores al resto.
- El mantenimiento evolutivo lo prestará una **empresa adjudicataria** de un contrato de servicios, que a su vez subcontratará el soporte de la base de datos.

Se pide un informe técnico previo a la puesta en explotación.

Cuestiones

Cuestión 1 — Valoración de dimensiones y categoría (3 puntos). Valore razonadamente el **nivel** de cada una de las cinco dimensiones de seguridad y determine la **categoría** del sistema. Indique

quién realiza cada una de esas dos operaciones y con qué fundamento normativo.

Cuestión 2 — Consecuencias de la categoría sobre las medidas (3 puntos). Explique qué medidas del anexo II resultan exigibles y cuáles no como consecuencia de las valoraciones anteriores, con especial atención a la diferencia entre medidas exigidas **por categoría** y medidas exigidas **por dimensión**. Cite al menos cinco códigos de medida.

Cuestión 3 — El módulo de violencia de género (2 puntos). Determine si procede elevar la categoría del sistema completo o existe una alternativa prevista en la norma. Cite el precepto y sus condiciones de aplicación.

Cuestión 4 — La empresa adjudicataria y su subcontratista (2 puntos). Determine qué obligaciones del ENS alcanzan al contratista y a su cadena de suministro, cómo se instrumentan y quién conserva la responsabilidad última.

▾ Ver solución orientativa

Solución orientativa

- **C1**: (§2.3, §2.4 y §2.4.2)

Dimensión	Nivel	Razonamiento sobre los supuestos del anexo I
Confidencialidad [C]	**MEDIO**	La divulgación de datos económicos de solicitantes de ayudas causaría un **perjuicio significativo a algún individuo, de difícil reparación** (supuesto 4.º del nivel MEDIO)
Integridad [I]	**MEDIO**	La alteración de una resolución supondría un **incumplimiento material** del ordenamiento jurídico (supuesto 3.º del nivel MEDIO)
Trazabilidad [T]	**MEDIO**	Sin poder acreditar quién resolvió y quién consultó, el incumplimiento sería **material**, y el perjuicio a la organización, **significativo**
Autenticidad [A]	**ALTO**	Sin autenticidad no hay acto administrativo válido: se produciría la **anulación efectiva de la capacidad** del Ayuntamiento de resolver (supuesto 1.º del nivel ALTO)
Disponibilidad [D]	**BAJO**	La interrupción retrasa pero no impide: las funciones **siguen desempeñándose**, el incumplimiento es **formal y subsanable** y el perjuicio es **fácilmente reparable**

Categoría: ALTA, porque alguna dimensión alcanza el nivel ALTO (anexo I, ap. 4.1.a). **Quién hace qué** (art. 41): **valorar** los niveles corresponde al **responsable de la información** y al **responsable del servicio** (ap. 1); **determinar la categoría** a partir de esas valoraciones corresponde al **responsable de la seguridad** (ap. 2). Y hay que añadir la obligación temporal del apartado 1 del anexo I: la categoría se **reevalúa anualmente** o ante modificaciones significativas de los criterios.

- **C2**: (§2.4.2 y §2.5.1) La clave es el **apartado 4.2 del anexo I**: la categoría ALTA **no altera** el nivel de las dimensiones que no influyeron en su determinación. La disponibilidad **sigue siendo BAJA**, con dos consecuencias opuestas:

Se exigen en su versión de ALTA (por categoría)	No se exigen (por dimensión D, que es BAJA)
`org.1` a `org.4` marco organizativo, en las tres categorías	`op.cont.1` análisis de impacto (`n.a.` en BÁSICA)
`op.pl.1` análisis de riesgos, `+ R2`	`op.cont.2` plan de continuidad (solo ALTA)
`op.exp.4` mantenimiento y actualizaciones, `+ R1 + R2`	`op.cont.3` pruebas periódicas (solo ALTA)
`op.exp.10` protección de claves criptográficas, `+ R1`	`op.cont.4` medios alternativos (solo ALTA)
`mp.com.4` separación de flujos, `+ [R2 o R3] + R4`	`mp.if.4` energía eléctrica en su refuerzo por D
`mp.s.2` protección de servicios web, `+ R2 + R3`	`mp.s.4` protección frente a denegación de servicio
`op.ext.3` protección de la cadena de suministro	

Por **dimensión A** y **dimensión I**, que sí son altas o medias, se exigen `mp.info.3` firma electrónica con sus refuerzos y `mp.com.3` protección de la integridad y de la autenticidad. Por **dimensión T**, `op.exp.8` registro de la actividad con **cinco refuerzos** en nivel ALTO y `mp.info.4` sellos de tiempo, que solo aplica en ALTA. Y por tratarse de datos personales, `mp.info.1`, con la regla de prevalencia del artículo 3.3 del ENS si la evaluación de impacto del RGPD arroja medidas agravadas.

El error que se penaliza es contestar «al ser categoría ALTA hay que hacer plan de continuidad»: la continuidad se exige por **nivel de disponibilidad**, no por categoría.

- **C3**: (§2.4.2) **No procede elevar el conjunto**: el **anexo II, apartado 2.2**, permite **segregar el módulo como subsistema**, aplicándole el nivel de medidas y los refuerzos que le correspondan por sí mismo. Su condición de validez es expresa: que **puedan delimitarse la información y los servicios afectados**, lo que el enunciado confirma. Si no fueran delimitables, no habría segregación posible y mandaría el máximo. Es la herramienta que evita que un módulo pequeño y muy sensible arrastre a un sistema entero, y es una decisión de arquitectura de conformidad, no un ajuste técnico.

- **C4**: (§2.1.1 y §2.2.3) El **artículo 2.3** extiende el ENS a las entidades privadas que, en virtud de relación contractual, presten servicios al sector público, **incluida la obligación de contar con política de seguridad**, aprobada por «el órgano que ostente las máximas competencias ejecutivas». La cautela «se extenderá también a la **cadena de suministro** de dichos contratistas, en la medida que sea necesario y de acuerdo con los resultados del correspondiente **análisis de riesgos**», lo que alcanza al subcontratista de la base de datos. **Cómo se instrumenta**: por la vía de los **pliegos**, que «contemplarán todos aquellos requisitos necesarios para asegurar la conformidad con el ENS», con presentación de **Declaraciones o Certificaciones de Conformidad**. Y hay dos piezas más: la medida `op.ext.1` (contratación y acuerdos de nivel de servicio) y `op.ext.2` (gestión diaria), y el **POC de seguridad** del artículo 13.5, que designa la organización prestataria. La responsabilidad, en cambio, no se traslada: el mismo artículo 13.5 dispone que todo ello opera «sin perjuicio de que **la responsabilidad última resida en la entidad del sector público** destinataria de los citados servicios».

Criterios de evaluación

Criterio	Puntos
Valoración razonada de las cinco dimensiones contra los supuestos del anexo I	1,5
Determinación correcta de la categoría y del reparto de facultades del artículo 41	1,5
Distinción entre medidas por categoría y por dimensión, con la trampa de la continuidad	2,0
Cita de al menos cinco códigos de medida con su tabla de aplicación	1,0
Identificación de la segregación de subsistemas y de su condición de validez	2,0
Alcance del artículo 2.3 al contratista y a su cadena de suministro, e instrumentación por pliegos	1,0
Responsabilidad última no externalizable y figura del POC	1,0

Caso 2 — Un nuevo intercambio de datos y la conservación de lo intercambiado

Enunciado

El Ayuntamiento quiere que el sistema de expedientes **consulte automáticamente**, en la tramitación de las ayudas al alquiler, dos datos que hoy pide en papel a la ciudadanía:

1. El **nivel de renta**, que obra en poder de la Agencia Estatal de Administración Tributaria.
2. La **situación de desempleo**, que obra en poder del Servicio Público de Empleo Estatal.

Además, el Área de Gobierno responsable quiere que:

- Los expedientes resueltos puedan **remitirse a los juzgados** de lo contencioso-administrativo cuando sean requeridos.
- Los expedientes se **conserven durante treinta años**, plazo fijado por la comisión calificadora competente.
- Las solicitudes presentadas **en papel** en las Oficinas de Atención a la Ciudadanía se **digitalicen** e incorporen al expediente electrónico con el mismo valor.

- Se **publique** en el Centro de Transferencia de Tecnología el módulo de gestión de ayudas, desarrollado con medios propios.

Se pide un informe sobre las obligaciones que el Esquema Nacional de Interoperabilidad impone en cada uno de esos cuatro frentes.

Cuestiones

Cuestión 1 — Las tres dimensiones sobre la consulta de datos (3 puntos). Identifique qué obligación concreta se activa en cada una de las tres dimensiones de la interoperabilidad para poder consultar la renta y el desempleo, e indique el beneficio jurídico que ello produce para la persona interesada.

Cuestión 2 — La remisión del expediente al juzgado (2,5 puntos). Describa el objeto que hay que producir y sus componentes, la norma técnica aplicable y qué información queda excluida. Cite el precepto de la Ley 39/2015 y la consecuencia de no cumplirlo.

Cuestión 3 — La conservación a treinta años y la digitalización (2,5 puntos). Enumere al menos seis de las medidas del artículo 21 del ENI que resultan aplicables, resuelva qué hacer si el formato en que se guardaron los documentos queda obsoleto y señale qué norma gobierna la digitalización del papel.

Cuestión 4 — La publicación del módulo en el CTT (2 puntos). Indique las condiciones de licenciamiento aplicables, qué debe publicarse junto al software y qué licencia procura la norma. Distinga reutilización en modo producto y en modo servicio.

▾ Ver solución orientativa

Solución orientativa

- **C1**: (§3.3.1 y §3.3.2)

Dimensión	Obligación concreta
Organizativa (arts. 8 y 9)	Adherirse al servicio de la **plataforma de intermediación de datos**, aceptar y publicar las **condiciones de acceso y utilización** —finalidades, modalidades de consumo, requisitos de los usuarios, perfiles, protocolos, mecanismos de gobierno y condiciones de seguridad—, acreditar la **base jurídica** de la consulta y mantener actualizados los **inventarios**: el procedimiento en el **SIA** y las oficinas en el **DIR3**
Semántica (art. 10)	Consumir el **modelo de datos común** publicado en el **CISE**, sin inventar campos propios, de modo que «estar en situación de desempleo» signifique lo mismo para el emisor y para el receptor
Técnica (arts. 11 a 13)	Usar los **protocolos de intermediación de datos** de la norma técnica de la letra `f)`, sobre **estándares abiertos** conforme al artículo 11, transportados por la **Red SARA**, que es quien presta la Red de comunicaciones de las AA. PP. españolas

Beneficio jurídico: por el **artículo 28 de la Ley 39/2015**, el Ayuntamiento **no puede exigir** a la persona interesada que aporte esos documentos, porque puede consultarlos. Y hay una obligación que se olvida y conviene señalar: el **artículo 8.1 del ENI** exige que esas condiciones sean conformes a la normativa de protección de datos **y al Esquema Nacional de Seguridad**, de modo que el nuevo intercambio obliga además a **reevaluar la categoría** del sistema, por tratarse de una modificación significativa (anexo I, ap. 1), y a aplicar `op.ext.4` (interconexión de sistemas) si la categoría del sistema lo exige: no aplica en BÁSICA, aplica en MEDIA y en ALTA con `+ R1` (§4.2.1).

- **C2**: (§3.4.2) Hay que producir un **expediente electrónico** conforme a la **norma técnica de la letra `d)`** —Resolución de 19 de julio de 2011—, con **cuatro componentes**: un **índice electrónico firmado** por el órgano actuante, los **documentos electrónicos** con sus metadatos y firmas, los **metadatos del expediente** y la **firma del índice**. Debe constar además **copia electrónica certificada de la resolución** adoptada. Se remite **completo, foliado, autentificado y acompañado de un índice, asimismo autentificado** (**artículo 70.3 de la Ley 39/2015**). Queda **excluida** la información auxiliar o de apoyo del artículo 70.4: aplicaciones, ficheros y bases de datos, notas, borradores, opiniones, resúmenes, comunicaciones e informes internos y juicios de valor, **salvo** los informes preceptivos y facultativos solicitados antes de la resolución. La **consecuencia de no cumplirlo** no es una sanción: es que **el requerimiento judicial no queda atendido**, porque lo remitido no es «el expediente» en el sentido del artículo 70.3. Conviene añadir el matiz del mismo precepto: es admisible que **un mismo documento forme parte de distintos expedientes**, porque el índice lo **referencia** en lugar de contenerlo.

- **C3**: (§3.3.2 y §3.4.3) Del **artículo 21.1 del ENI** son directamente aplicables, entre otras: `a)` **política de gestión de documentos**; `b)` **índice electrónico firmado** que garantice la integridad del expediente; `c)` **identificación única e inequívoca** de cada documento; `d)` asociación de los **metadatos mínimos obligatorios** a lo largo del ciclo de vida; `e)` **clasificación** conforme a un plan adaptado a las funciones; `f)` **período de conservación** establecido por las **comisiones calificadoras** —que es exactamente lo que ha ocurrido con los treinta años del enunciado, y conviene subrayar que **no lo fija el informático**—; `g)` **acceso completo e inmediato** en línea, con consulta durante todo el período de conservación de la firma, el sello de tiempo y los metadatos; `h)` medidas de conservación que aseguren el **valor probatorio**; `j)` **transferencia** entre repositorios; y `m)` **documentación de los procedimientos**. El apartado 2 obliga además a crear **repositorios electrónicos**, «complementarios y equivalentes en cuanto a su función a los archivos convencionales».

Si el formato queda obsoleto: se aplica el **artículo 23.3**, que ordena, ante riesgo de obsolescencia o si el formato «deja de figurar entre los admitidos» en el ENI, aplicar **procedimientos normalizados de copiado auténtico con cambio de formato**, **etiquetado con información del formato utilizado** y, en su caso, migraciones o conversiones. Es la conexión entre el **Catálogo de estándares** —que tiene ciclo de vida y puede degradar un formato— y la conservación. El **copiado auténtico es una figura jurídica**, no una exportación: se rige por la norma técnica de la letra `j)`.

Digitalización del papel: **artículo 24 del ENI** y **norma técnica de la letra** `c)`, que fija formatos y técnica de compresión, **nivel de resolución**, **garantía de imagen fiel e íntegra** y **metadatos** del proceso. El apartado 2 recuerda atender a la **posible existencia del documento en otro soporte**. Y para que la imagen digitalizada tenga valor de copia auténtica hay que estar además al **artículo 27.3 de la Ley 39/2015**, que exige ajustarse al **ENI, al ENS y a sus normas técnicas de desarrollo**.

- **C4**: (§3.2.2) El **artículo 16.1 del ENI** fija los seis aspectos del licenciamiento, entre ellos que el fin es el **aprovechamiento y la reutilización de recursos públicos**, la **protección contra la apropiación exclusiva** por terceros, la **exención de responsabilidad del cedente** y, sobre todo, que «el licenciamiento se realizará **por defecto sin contraprestación y sin necesidad de establecer convenio alguno**». Si el módulo se declara **de fuentes abiertas**, la licencia debe garantizar las **cuatro libertades** del apartado 2 —ejecutar para cualquier propósito, conocer el código fuente, modificar o mejorar y redistribuir con o sin cambios manteniendo la obra derivada esas cuatro garantías—, y se procurará la **Licencia Pública de la Unión Europea (EUPL)** (ap. 3). Al publicarlo en el **CTT** hay que incluir, al menos (art. 17.3): **código fuente** si es reutilizable en modo producto y se ha declarado de fuentes abiertas, **documentación asociada**,

condiciones de licenciamiento o **nivel de servicio** según el modo, y **costes asociados** si existieran.

Modo producto frente a modo servicio: en modo **producto** se cede el código y el cesionario lo despliega, y lo que se publica son **licencias**; en modo **servicio** el cedente sigue operando la aplicación y el cesionario la consume, y lo que se publica son **niveles de servicio**. Conviene cerrar señalando la obligación inversa: antes de desarrollar el módulo, el **artículo 157.3 de la Ley 40/2015** obligaba a **consultar el CTT** y, de existir solución reutilizable, a usarla salvo justificación en términos de **eficiencia**.

Criterios de evaluación

Criterio	Puntos
Identificación de las tres dimensiones con obligación concreta y su instrumento (SIA, DIR3, CISE, SARA)	2,0
Beneficio del artículo 28 de la Ley 39/2015 y remisión del artículo 8.1 al ENS	1,0
Componentes del expediente electrónico y régimen de remisión del artículo 70.3	1,5
Exclusiones del artículo 70.4 y consecuencia jurídica del incumplimiento	1,0
Seis o más medidas del artículo 21, con las comisiones calificadoras	1,5
Solución de obsolescencia por copiado auténtico con cambio de formato, y norma de digitalización	1,0
Condiciones de licenciamiento, cuatro libertades y EUPL	1,0
Distinción modo producto / modo servicio y obligación previa de consulta al CTT	1,0

Caso 3 — Conformidad, gobernanza y respuesta a un incidente

Enunciado

El sistema de expedientes, ya en explotación y **categorizado como ALTA**, atraviesa la siguiente secuencia de hechos a lo largo de un año:

1. En **enero**, el IAM debe acreditar la conformidad del sistema con el ENS y publicarla.

2. En **marzo** se detecta que el **responsable de la seguridad** designado depende jerárquicamente del director del Departamento de Sistemas, que es el **responsable del sistema**. La entidad alega falta de recursos para separar ambas funciones.
3. En **junio**, una sonda de vigilancia detecta **cifrado masivo de ficheros** en un servidor del sistema. El incidente tiene impacto significativo. El servidor lo opera la **empresa adjudicataria** del mantenimiento.
4. En **septiembre**, restaurado el servicio, se comprueba que **doscientos expedientes** recuperados desde copia han perdido los **sellos de tiempo** asociados a sus asientos registrales.
5. En **noviembre**, tras una modificación sustancial del sistema, el Área quiere saber si hay que auditar de nuevo o basta con esperar a la siguiente auditoría ordinaria.

Se pide un informe.

Cuestiones

Cuestión 1 — Acreditación y publicidad de la conformidad (2 puntos). Determine qué procedimiento corresponde en enero, quién lo realiza, qué documento produce, cómo se materializa y dónde debe publicarse.

Cuestión 2 — El conflicto de responsabilidades (2 puntos). Valore la situación de marzo a la luz de los principios básicos, indique si es admisible y en qué condiciones, y qué habría que hacer.

Cuestión 3 — La gestión del incidente de junio (3 puntos). Describa la actuación exigible en las cuatro fases del artículo 8, identifique a qué equipo de respuesta debe notificar cada uno de los dos sujetos implicados y señale qué órgano interviene antes de reconectar el sistema.

Cuestión 4 — La pérdida de los sellos de tiempo (1,5 puntos). Analice qué dimensión de seguridad se ha visto afectada, qué medida del anexo II ha fallado y por qué el problema no se resuelve con una restauración técnica.

Cuestión 5 — La modificación sustancial de noviembre (1,5 puntos). Resuelva si procede auditoría, de qué tipo, y qué efecto tiene sobre el cómputo del plazo.

▾ **Ver solución orientativa**

Solución orientativa

- **C1**: (§2.5.2) Al tratarse de un sistema de categoría **ALTA**, el **artículo 38.1** exige una **auditoría para la certificación** de su conformidad, realizada por una **Entidad de Certificación** cuyos requisitos concreta la **Instrucción Técnica de Seguridad de Conformidad**. La auditoría regular del artículo 31 «podrá servir asimismo para los fines de

la certificación». El documento producido es una **Certificación de Conformidad**, que se materializa en un **Distintivo de Certificación de Conformidad**: documento electrónico en formato **PDF-A**, **firmado electrónicamente por la Entidad de Certificación**, que incluye un **enlace** a la certificación. El **artículo 38.2** obliga a darle publicidad «en los correspondientes **portales de internet o sedes electrónicas**», donde permanecerá accesible mientras mantenga su vigencia. Conviene contrastar con el otro camino: si el sistema fuera de categoría **BÁSICA** bastaría una **autoevaluación**, que el anexo III permite realizar «al mismo personal que administra el sistema o en quien éste delegue», y produciría una **Declaración de Conformidad** cuyo distintivo firma o sella **la propia entidad**.

- **C2**: (§2.2.3) La situación **infringe el principio básico de diferenciación de responsabilidades** (art. 5.g y art. 11) y, en particular, dos reglas: el **artículo 11.2**, que exige que la responsabilidad de la seguridad esté **diferenciada de la responsabilidad sobre la explotación**, y el **artículo 13.3**, que dispone que el responsable de la seguridad «será distinto del responsable del sistema, **no debiendo existir dependencia jerárquica entre ambos**». **No basta con que sean dos personas**: la jerarquía es precisamente lo que la norma prohíbe, porque quien explota tiene incentivos para minimizar los avisos que le obligarían a parar. Ahora bien, el mismo artículo 13.3 **admite la situación excepcional**: cuando «la **ausencia justificada de recursos**» lo haga necesario, «deberán aplicarse **medidas compensatorias** para garantizar la finalidad del principio». Qué habría que hacer: **justificar y documentar** la ausencia de recursos, **definir y aprobar formalmente las medidas compensatorias** —por ejemplo, atribuir la validación de las decisiones de seguridad a un órgano colegiado como el **Comité Municipal de Seguridad de la Información**, o reportar directamente al órgano que aprueba la política—, y **recoger todo ello en la política de seguridad**, que conforme al artículo 11.3 debe detallar las atribuciones de cada responsable y los **mecanismos de coordinación y resolución de conflictos**. Es además un punto que el auditor **comprobará expresamente**: el anexo III, apartado 1.1.c), obliga a constatar que se han designado personas para dichos roles «a la luz del principio de diferenciación de responsabilidades».

- **C3**: (§2.2.2 y §4.1.1) Las cuatro fases del **artículo 8**:

Fase	Actuación exigible
Prevención	Ha fallado. Procede revisar `op.exp.2` configuración de seguridad, `op.exp.4` mantenimiento y actualizaciones —con sus refuerzos R1 pruebas en preproducción y R2 mecanismo para revertir— y `mp.com.4` separación de flujos
Detección	Ha funcionado: `op.mon.1` detección de intrusión y `op.exp.8` registro de la actividad. Debe abrirse el incidente en `op.exp.7` y registrarse en `op.exp.9`
Respuesta	Aislar el segmento, erradicar, **restaurar desde copia** (`mp.info.6`) y gestionar «en **tiempo oportuno**». Al ser categoría ALTA, el **responsable del sistema** puede, si las deficiencias son graves, **suspender temporalmente** la operación (art. 31.6)
Conservación	Comprobar que lo restaurado **sigue valiendo**: firmas, sellos y metadatos intactos. Es lo que falla en la cuestión 4

Notificaciones, y aquí está el matiz que se evalúa: son **dos sujetos y dos destinatarios distintos**. El **Ayuntamiento**, como entidad del sector público, notifica al **CCN-CERT** los incidentes con **impacto significativo**, conforme al artículo 33.2 y a la **Instrucción Técnica de Seguridad de Notificación de Incidentes**. La **empresa adjudicataria**, como organización del sector privado que presta servicios a una entidad pública, notifica al **INCIBE-CERT** (art. 33.7), y es este quien lo pone **inmediatamente** en conocimiento del CCN-CERT. Quien conteste que el proveedor notifica directamente al CCN-CERT falla.

Antes de reconectar: el **artículo 33.6** dispone que, tras un incidente de seguridad, «el **CCN-CERT determinará técnicamente el riesgo de reconexión** del sistema o sistemas afectados, indicando los procedimientos a seguir y las salvaguardas a implementar». Si estuvieran implicados medios y servicios comunes, la **Secretaría General de Administración Digital** autoriza la reconexión a la vista de un **informe de superficie de exposición** del CCN-CERT.

- **C4**: (§2.3.2 y §4.2.1) La dimensión afectada es la **trazabilidad [T]**: sin sello de tiempo no se puede acreditar **de forma indiscutible y oponible frente a terceros** el momento del asiento. La medida que ha fallado es **`mp.info.4` (sellos de tiempo)**, que en un sistema de categoría ALTA **aplica** y que precisamente existe porque el reloj del servidor **no da fecha oponible**. Puede haber fallado también el refuerzo correspondiente de `mp.info.6` (copias de seguridad), si la copia no incluía los objetos de sellado.

Por qué no basta con restaurar: porque el problema no es de disponibilidad sino de **valor probatorio**. Un sello de tiempo **no se puede regenerar retroactivamente**: sellar hoy un documento acredita que existía hoy, no que existía en la fecha del asiento. Aquí es donde los

dos esquemas se tocan: el **artículo 21.1.g) del ENI** exige que el sistema permita la consulta, durante todo el período de conservación, «al menos de la firma electrónica, **incluido, en su caso, el sello de tiempo**, y de los metadatos asociados»; y el **artículo 22.1 del ENI** remite al **ENS** para asegurar esa conservación. La actuación correcta es documentar la pérdida como **incidencia de conservación**, valorar si los asientos registrales permiten reconstruir la fecha por otra vía probatoria y revisar el procedimiento de copia para que incluya los objetos de sellado. Y conviene señalar la lección general: **un incidente no termina cuando el servicio vuelve**, sino cuando se ha comprobado que la información recuperada **sigue siendo válida como documento administrativo**.

- **C5**: (§2.5.2) **Sí procede auditoría, y es extraordinaria.** El **artículo 31.1** dispone que «con carácter extraordinario, deberá realizarse dicha auditoría **siempre que se produzcan modificaciones sustanciales** en los sistemas de información, que puedan repercutir en las medidas de seguridad requeridas». No cabe esperar a la ordinaria. **Efecto sobre el plazo**: «la realización de la auditoría extraordinaria **determinará la fecha de cómputo** para el cálculo de los dos años establecidos para la realización de la siguiente auditoría regular ordinaria». Es decir, **reinicia el contador**. Procede además **reevaluar la categoría**, porque el anexo I, apartado 1, obliga a hacerlo «siempre que se produzcan modificaciones significativas en los criterios de determinación», y **actualizar la Declaración de Aplicabilidad** firmada por el responsable de la seguridad (art. 28.2). Como dato accesorio: si concurrieran impedimentos de **fuerza mayor no imputables** a la entidad, el plazo de dos años podría extenderse **tres meses**.

Criterios de evaluación

Criterio	Puntos
Procedimiento de conformidad correcto para categoría ALTA, con distintivo PDF-A y publicidad en sede	2,0
Identificación de la infracción del artículo 13.3 y de la excepción por ausencia justificada de recursos	1,0
Medidas compensatorias, su reflejo en la política y el punto de auditoría del anexo III	1,0
Las cuatro fases del artículo 8 con medidas asociadas	1,5
Doble notificación: CCN-CERT para el Ayuntamiento e INCIBE-CERT para el proveedor	1,0
Determinación del riesgo de reconexión por el CCN-CERT	0,5
Dimensión T, medida `mp.info.4` y no reversibilidad del sello de tiempo	1,5
Auditoría extraordinaria, reinicio del cómputo y reevaluación de la categoría	1,5

Fuentes

Tier 1 — Normativa aplicable

ID	Referencia
`[L40]`	Ley **40/2015, de 1 de octubre, de Régimen Jurídico del Sector Público** (BOE núm. 236, de 2 de octubre de 2015). **Norma de cabecera de los dos esquemas.** Preceptos citados y verificados literalmente contra el texto consolidado del BOE: **art. 3.1**, principios generales de actuación (once letras, de la `a)` a la `k)`); **art. 3.2**, que ordena que las Administraciones se relacionen entre sí «**a través de medios electrónicos, que aseguren la interoperabilidad y seguridad de los sistemas y soluciones adoptadas por cada una de ellas**»; **art. 155**, transmisiones de datos entre Administraciones; **art. 156**, rúbrica «**Esquema Nacional de Interoperabilidad y Esquema Nacional de Seguridad**», cuyo **apartado 1 define el ENI** y cuyo **apartado 2 define el ENS**; **art. 157**, reutilización de sistemas y aplicaciones, con la **obligación de consultar el directorio general antes de adquirir o desarrollar**; **art. 158**, transferencia de tecnología; y **disposición adicional novena**, que crea la **Comisión Sectorial de administración electrónica** y le atribuye tres funciones.
`[L39]`	Ley **39/2015, de 1 de octubre, del Procedimiento Administrativo Común de las Administraciones Públicas** (BOE núm. 236, de 2 de octubre de 2015). Se cita por los preceptos que **convierten a los dos esquemas en derecho aplicable al procedimiento**: **art. 26**, requisitos de validez del documento electrónico administrativo (los cinco de su apartado 2, entre ellos la **referencia temporal** y los **metadatos mínimos**); **art. 27.3**, que exige ajustarse «**al Esquema Nacional de Interoperabilidad, el Esquema Nacional de Seguridad y sus normas técnicas de desarrollo**» para que una copia sea auténtica; y **art. 70**, expediente administrativo, cuyo **apartado 3** ordena remitirlo «**de acuerdo con lo previsto en el Esquema Nacional de Interoperabilidad y en las correspondientes Normas Técnicas de Interoperabilidad**», completo, foliado, autentificado y con **índice autentificado**.
`[ENS]`	Real Decreto **311/2022, de 3 de mayo, por el que se regula el Esquema Nacional de Seguridad** (BOE núm. 106, de 4 de mayo de 2022; `BOE-A-2022-7191`). **Fuente central de la primera mitad del tema.** Estructura: **41 artículos en 7 capítulos**, 3 disposiciones adicionales, 1 transitoria, 1 derogatoria, 3 finales y **4 anexos**. Verificado contra el PDF consolidado: **art. 1** (objeto y remisión al art. 156.2 de la Ley 40/2015); **art. 2** (ámbito: todo el sector público **y las entidades privadas que le prestan servicios**); **art. 3** (concurrencia con el RGPD y la LOPDGDD); **art. 5** (los **siete principios básicos**); **arts. 6 a 11** (desarrollo de esos principios); **art. 12** (contenido mínimo de la política de seguridad, ocho letras); **arts. 13 a 27** (los **quince requisitos mínimos**); **art. 28** (**Declaración de Aplicabilidad** y medidas compensatorias); **art. 30** (perfiles de cumplimiento específicos); **art. 31** (auditoría **al menos cada dos años**, prórroga de **tres meses** por fuerza mayor); **art. 32** (informe del estado de la seguridad); **arts. 33 y 34** (**CCN-CERT**, **INCIBE-CERT**, **ESPDEF-CERT**); **art. 35.2** (el CCN como órgano competente para la interoperabilidad en ciberseguridad y criptografía); **art. 38** (**BÁSICA: autoevaluación; MEDIA y ALTA: certificación**); **arts. 40 y 41** (categorías y facultades); **disposición adicional segunda**

ID	Referencia
	(instrucciones técnicas de seguridad y guías **CCN-STIC serie 800**); **disposición transitoria única** (**24 meses** de adecuación); **anexo I** (dimensiones, niveles y categorías); **anexo II** (**73 medidas** en tres grupos, con su tabla de aplicación); **anexo III** (auditoría); **anexo IV** (glosario).
`[ENI]`	Real Decreto **4/2010, de 8 de enero, por el que se regula el Esquema Nacional de Interoperabilidad en el ámbito de la Administración Electrónica** (BOE núm. 25, de 29 de enero de 2010; `BOE-A-2010-1331`). **Fuente central de la segunda mitad del tema.** Estructura: **29 artículos en 12 capítulos**, 5 disposiciones adicionales, 2 transitorias, 1 derogatoria, 3 finales y 1 anexo con el glosario. Verificado contra el PDF consolidado: **art. 1** (objeto; **sigue remitiendo al art. 42 de la derogada Ley 11/2007**); **art. 4** (los **tres principios específicos**); **art. 5** (cualidad integral, con los **nueve momentos del ciclo de vida**); **art. 6** (carácter multidimensional **y la dimensión temporal**); **art. 7** (soluciones multilaterales); **arts. 8 y 9** (interoperabilidad organizativa, **nodos de interoperabilidad** e inventarios); **art. 10** (activos semánticos y **Centro de Interoperabilidad Semántica**); **art. 11** (**estándares abiertos**, con los cinco criterios de selección); **art. 12** (infraestructuras y servicios comunes); **art. 13** (la **Red SARA** presta la Red de comunicaciones de las AA. PP. españolas); **art. 15** (**hora oficial**, sincronizada con el **Real Instituto y Observatorio de la Armada**); **arts. 16 y 17** (licenciamiento, **cuatro libertades del software de fuentes abiertas**, **EUPL** y **Centro de Transferencia de Tecnología**); **arts. 18 a 20** (política de firma y plataformas de validación); **arts. 21 a 24** (recuperación y conservación: **trece medidas** de la letra `a)` a la `m)`, formatos y digitalización); **art. 22** (**la conservación se asegura aplicando el ENS**); **arts. 25 a 28** (conformidad); **art. 29** (actualización permanente); **disposición adicional primera** (las **23 normas técnicas previstas** y los **cuatro instrumentos**: SIA, CISE, CTT y DIR3).
`[RD1125]`	Real Decreto **1125/2024, de 5 de noviembre** (BOE de 6 de noviembre de 2024; `BOE-A-2024-22935`). **Última modificación de ambos esquemas.** Reasigna la competencia para aprobar las normas técnicas de interoperabilidad (disposición adicional primera, apartado 2, del ENI) y las instrucciones técnicas de seguridad (disposición adicional segunda del ENS) al **Ministerio para la Transformación Digital y de la Función Pública**, con publicación por **Resolución de la persona titular de la Secretaría de Estado de Función Pública**. Dato verificado en la ficha de análisis del BOE de los dos reales decretos.
`[RD203]`	Real Decreto **203/2021, de 30 de marzo**, por el que se aprueba el **Reglamento de actuación y funcionamiento del sector público por medios electrónicos** (BOE núm. 77, de 31 de marzo de 2021). Desarrolla reglamentariamente las leyes 39/2015 y 40/2015 y **modifica el ENI**: es la reforma que amplió la lista de normas técnicas de la disposición adicional primera con las letras `m)` a `v)` y actualizó los inventarios del artículo 9.
`[RD3-`	Real Decreto **3/2010, de 8 de enero**, primer Esquema Nacional de Seguridad, **derogado** por la disposición derogatoria única del RD 311/2022. Se cita solo para marcar diferencias históricas, todas verificadas contra su propio texto consolidado: los principios básicos eran **seis** —

ID	Referencia
`2010`	seguridad integral, gestión de riesgos, **prevención, reacción y recuperación**, líneas de defensa, reevaluación periódica y **función diferenciada**—; las dimensiones se enumeraban en el orden **D-A-I-C-T** (apartado 2 del anexo I) frente al **C-I-T-A-D** vigente; y el anexo II incluía epígrafes de cierre del tipo `«otros»` (`op.exp.11` , `mp.if.9` , `mp.per.9` , `mp.eq.9` , `mp.com.9` , `mp.info.9` , `mp.s.9`) que el RD 311/2022 **eliminó**, sustituyéndolos por el mecanismo de **medidas compensatorias** del artículo 28.3.
`[RGPD]`	Reglamento **(UE) 2016/679** (Reglamento General de Protección de Datos) y Ley Orgánica **3/2018, de 5 de diciembre** (LOPDGDD). Se citan por el **artículo 3 del ENS**, que ordena su aplicación concurrente y establece la **regla de prevalencia**: si del análisis de riesgos o de la evaluación de impacto resultan medidas **agravadas** respecto de las del ENS, prevalecen aquellas. Medida `mp.info.1` del anexo II.
`[IEA]`	Reglamento **(UE) 2024/903 del Parlamento Europeo y del Consejo, de 13 de marzo de 2024**, por el que se establecen medidas a fin de garantizar un alto nivel de interoperabilidad del sector público en toda la Unión (**Reglamento sobre la Europa Interoperable**). **En vigor el 11 de abril de 2024**, aplicable desde el **12 de julio de 2024**. Se cita por tres razones: es **directamente aplicable** sin transposición; maneja **cuatro capas de interoperabilidad** —jurídica, organizativa, semántica y técnica—, una más que el ENI; e introduce la **evaluación de la interoperabilidad**, el **portal Europa Interoperable**, las **cajas de arena regulatorias** y la obligación de designar **autoridades nacionales competentes y un punto de contacto único**.
`[EIDAS]`	Reglamento **(UE) 910/2014** (eIDAS), modificado por el Reglamento **(UE) 2024/1183, de 11 de abril de 2024**, que crea la **cartera europea de identidad digital**. Marco de la identificación y la firma electrónicas sobre el que se apoyan los artículos 18 a 20 del ENI y la medida `mp.info.3` del ENS.
`[NIS2]`	Directiva **(UE) 2022/2555** (NIS2). **Pendiente de transposición en España a agosto de 2026**: el anteproyecto de Ley de Coordinación y Gobernanza de la Ciberseguridad se aprobó en Consejo de Ministros el **14 de enero de 2025** y no se ha publicado en el BOE. Se cita para situar el ENS en el marco europeo de ciberseguridad y para advertir de que este bloque del temario puede cambiar.
`[RDL12-2018]`	Real Decreto-ley **12/2018, de 7 de septiembre**, de seguridad de las redes y sistemas de información (transposición de la Directiva NIS original), y **Real Decreto 43/2021, de 26 de enero**, que lo desarrolla. Se citan por los **artículos 33 y 34 del ENS**, que remiten a ellos para la coordinación de los CSIRT y la **Plataforma de Notificación y Seguimiento de Ciberincidentes**.

ID	Referencia
[LSN]	Ley **36/2015, de 28 de septiembre, de Seguridad Nacional**. Citada por el **artículo 1.3 del ENS**, que integra los sistemas de información del sector público en los recursos del **Sistema de Seguridad Nacional**.
[CE]	**Constitución Española**. Títulos competenciales de ambos esquemas: el **ENI** se dicta al amparo del art. **149.1.18.ª**; el **ENS**, al amparo de los arts. **149.1.18.ª, 149.1.21.ª y 149.1.29.ª** (bases del régimen jurídico, telecomunicaciones y seguridad pública).

Tier 2 — Normas técnicas, instrucciones técnicas y guías

ID	Referencia
`[NTI]`	**Las doce Normas Técnicas de Interoperabilidad publicadas**, verificadas una a una en el BOE. **Resolución de 19 de julio de 2011** de la Secretaría de Estado para la Función Pública (BOE de 30 de julio de 2011), siete normas: **Digitalización de documentos** (`BOE-A-2011-13168`), **Documento electrónico** (`13169`), **Expediente electrónico** (`13170`), **Política de firma electrónica y de certificados de la Administración** (`13171`), **Procedimientos de copiado auténtico y conversión entre documentos electrónicos** (`13172`), **Requisitos de conexión a la red de comunicaciones de las Administraciones públicas españolas** (`13173`) y **Modelo de datos para el intercambio de asientos entre las entidades registrales** (`13174`). **Resolución de 28 de junio de 2012** de la Secretaría de Estado de Administraciones Públicas, tres normas: **Política de gestión de documentos electrónicos** (`BOE-A-2012-10048`), **Protocolos de intermediación de datos** (`10049`) y **Relación de modelos de datos** (`10050`). **Resolución de 3 de octubre de 2012**: **Catálogo de estándares** (`BOE-A-2012-13501`). **Resolución de 19 de febrero de 2013**: **Reutilización de recursos de la información** (`BOE-A-2013-2380`).
`[ITS]`	**Las cuatro Instrucciones Técnicas de Seguridad publicadas**, verificadas en el portal oficial del ENS del CCN: **Informe del estado de la seguridad** (`BOE-A-2016-10108`), **Conformidad con el Esquema Nacional de Seguridad** (`BOE-A-2016-10109`), **Auditoría de la seguridad de los sistemas de información** (`BOE-A-2018-4573`) y **Notificación de incidentes de seguridad** (`BOE-A-2018-5370`). **No hay ninguna posterior a 2018.**
`[CCNSTIC]`	Series documentales **CCN-STIC** del **Centro Criptológico Nacional**, previstas en el artículo 34.1.b) y en la disposición adicional segunda del ENS. **Serie 800**, específica del ENS: **CCN-STIC 801** (responsabilidades y funciones), **803** (valoración de sistemas), **804** (guía de implantación), **806** (plan de adecuación), **808** (verificación del cumplimiento), **809** (declaración y certificación de conformidad), **825** (categorización), **844** (INES). Herramientas asociadas: **PILAR** (análisis y gestión de riesgos), **INES** (informe nacional del estado de la seguridad), **CLARA**, **ROCÍO**, **LUCÍA**, **CARMEN** y **MICROCLAUDIA**.
`[MAGERIT]`	**MAGERIT v3**: *Metodología de Análisis y Gestión de Riesgos de los Sistemas de Información*, del entonces Consejo Superior de Administración Electrónica. Método de referencia en España para el **artículo 14 del ENS** (análisis y gestión de riesgos) y para la medida `op.pl.1` . Tres libros: método, catálogo de elementos y guía de técnicas.
`[IS`	**UNE-EN ISO/IEC 27001** (sistemas de gestión de la seguridad de la información) e **ISO/IEC 27002** (controles). Marco internacional con el que el ENS se corresponde parcialmente. Se cita

ID	Referencia
`02 70 01 ]`	para explicar la diferencia estructural: la **certificación ISO 27001 es voluntaria y de gestión**; la **conformidad con el ENS es obligatoria y de cumplimiento normativo**.
`[ EI F ]`	**Marco Europeo de Interoperabilidad** (*European Interoperability Framework*, EIF), en su versión vinculada al Reglamento sobre la Europa Interoperable. Define las **cuatro capas** —jurídica, organizativa, semántica y técnica—, más la **gobernanza de la interoperabilidad** como capa transversal y el **modelo conceptual** de servicios públicos integrados. Es la referencia con la que hay que comparar el artículo 6 del ENI.
`[ SA RA ]`	**Red SARA** (Sistemas de Aplicaciones y Redes para las Administraciones), red de comunicaciones de las Administraciones públicas españolas conforme al **artículo 13 del ENI**, y su conexión con la red europea **TESTA**. Servicios asociados: **plataforma de intermediación de datos**, **Cl@ve**, **@firma**, **SIR**, **Notific@**, **Carpeta Ciudadana**.
`[ PA E ]`	**Portal de Administración Electrónica** (`administracionelectronica.gob.es`) de la Secretaría General de Administración Digital: catálogo de servicios y soluciones comunes, **Centro de Transferencia de Tecnología (CTT)**, **Centro de Interoperabilidad Semántica (CISE)**, **Sistema de Información Administrativa (SIA)** y **Directorio Común de Unidades Orgánicas y Oficinas (DIR3)**. Son los cuatro instrumentos de la disposición adicional primera, apartado 4, del ENI.

Tier 3 — Marco municipal del Ayuntamiento de Madrid

ID	Referencia
`[PSI-MAD]`	**Acuerdo de 7 de julio de 2022 de la Junta de Gobierno de la Ciudad de Madrid**, por el que se aprueba la **Política de Seguridad de la Información del Ayuntamiento de Madrid y de sus Organismos Públicos** (BOAM núm. 9177, de 11 de julio de 2022). Sustituye a la política aprobada por Acuerdo de **24 de mayo de 2017** (BOAM núm. 7913, de 26 de mayo de 2017) y adapta el marco municipal al RD 311/2022. Incorpora la figura del **responsable de seguridad delegado**. Es el instrumento que exige el **artículo 12 del ENS** en el Ayuntamiento.
`[CMSI]`	**Decreto del Alcalde de 17 de noviembre de 2021**, por el que se crea el **Comité Municipal de Seguridad de la Información** como órgano colegiado encargado de elaborar las propuestas de modificación y actualización de la Política de Seguridad de la Información. Materializa la letra `d)` del artículo 12.1 del ENS.
`[INSTR-MAD]`	**Resolución de 6 de marzo de 2024 de la Coordinadora General de la Alcaldía**, por la que se aprueba la **instrucción sobre los criterios generales de seguridad en el uso de los sistemas de información y servicios digitales** del Ayuntamiento de Madrid y sus Organismos Públicos (BOAM núm. 9589, de 11 de marzo de 2024). Es el nivel de **normativa de seguridad** (`org.2`) por debajo de la política.
`[ORD-MAD]`	**Ordenanza de Atención a la Ciudadanía y Administración Electrónica**, aprobada por Acuerdo del Pleno de **26 de febrero de 2019** (BOAM de 11 de marzo de 2019, en vigor desde el 12 de marzo de 2019). Marco municipal de la sede electrónica, el registro, la notificación y el expediente electrónicos, sobre los que se proyectan el ENI y el ENS.
`[IAM]`	**Organismo Autónomo Informática del Ayuntamiento de Madrid (IAM)**. Órgano que ejerce materialmente las funciones de **responsable del sistema** sobre la infraestructura municipal y que ejecuta los planes de adecuación al ENS. Contexto de los tres casos prácticos.
`[BOAM]`	**Bases de la convocatoria** del Cuerpo de Técnicos Auxiliares de Informática del Ayuntamiento de Madrid, **BOAM 10.032**, de donde procede el enunciado literal de este tema y la numeración del temario citada en las referencias cruzadas.